

DetectKB

راهنمای کاربری

پایگاه دانش مهندسی تشخیص

ویرایش ۲.۰ مهر ۱۴۰۵

فهرست فصل‌ها

- فصل ۱ آشنایی با DetectKB
- فصل ۲ شروع کار
- فصل ۳ قوانین تشخیص
- فصل ۴ ورود و خروج قوانین
- فصل ۵ پوشش MITRE ATT&CK
- فصل ۶ رویدادهای Sysmon
- فصل ۷ منابع لاگ
- فصل ۸ ابزارهای مهاجم
- فصل ۹ گروه‌های تهدید و بدافزارها
- فصل ۱۰ سناریوهای تحلیلی Splunk
- فصل ۱۱ Atomic Red Team و اعتبارسنجی در لب
- فصل ۱۲ گراف دانش
- فصل ۱۳ صفحات دانش
- فصل ۱۴ جست‌وجو و مستندسازی
- فصل ۱۵ مدیریت سامانه
- فصل ۱۶ میانبرهای صفحه‌کلید و ظاهر
- فصل ۱۷ پرسش‌های رایج و عیب‌یابی

درباره‌ی این راهنما. این راهنما کار با همه‌ی بخش‌های DetectKB را قدم‌به‌قدم توضیح می‌دهد. رابط کاربری سامانه انگلیسی است؛ برای اینکه دکمه‌ها و منوها را راحت پیدا کنید، نام آن‌ها دقیقاً همان‌طور که روی صفحه دیده می‌شوند به‌صورت پررنگ آمده است، مثل **Import rules**. کلیدهای صفحه‌کلید و مقادیر فنی به شکل **Ctrl+K** نوشته شده‌اند. تصاویر از محیط آزمایشی با حدود ۲۱۰۰ قانون واقعی از مخزن‌های عمومی Elastic، ESCU، Splunk، Sigma و Microsoft Sentinel گرفته شده‌اند. عددهای داخل تصاویر مربوط به همان داده‌ی نمونه است.

فصل ۱ – آشنایی با DetectKB

DetectKB یک پایگاه دانش برای تیم‌های مهندسی تشخیص (Detection Engineering) است. قوانین تشخیص، دانش پشت آن‌ها و منابع داده‌ای که به آن تکیه دارند در یک جا نگه داشته می‌شوند. سامانه از روی این داده‌ها نشان می‌دهد در برابر کدام تکنیک‌های مهاجم پوشش داریم، هر تشخیص به کدام داده وابسته است و کجا شکاف داریم.

مفاهیم پایه

مفهوم	توضیح
قانون تشخیص (Rule)	یک منطق شناسایی رفتار مخرب، همراه با کوئری (SPL، KQL، EQL یا Sigma)، شدت، وضعیت، تکنیک‌های ATT&CK و منبع داده.
وضعیت (Status)	draft پیش‌نویس · testing در حال تست · production فعال در محیط عملیاتی · deprecated کنار گذاشته شده.
شدت (Severity)	info · low · medium · high · critical
تکنیک ATT&CK	شناسه‌ی تکنیک مهاجم در چارچوب MITRE ATT&CK، مثل T1003.001 (استخراج حافظه‌ی LSASS). سامانه از نسخه‌ی v19.2 استفاده می‌کند.
رویداد Sysmon	نوع رویدادی که Sysmon ثبت می‌کند، مثل EID 1 (ساخت پروسه) یا EID 10 (دسترسی به پروسه).
منبع داده (Data Source)	جایی که لاگ از آن می‌آید، مثل Sysmon Operational Log. در سامانه به شکل یک صفحه‌ی دانش ثبت می‌شود.
ابزار مهاجم	فایل‌های مجاز سیستم‌عامل که مهاجم از آن‌ها سوءاستفاده می‌کند، از مخزن‌های LOLBAS، LOLDrivers و GTF0Bins.
صفحه‌ی دانش (Page)	هر محتوای متنی سامانه: قانون، مفهوم (Concept)، منبع داده، یادداشت (Note) و دستور SPL.

نقش‌ها و سطح دسترسی

هر کاربر یک یا چند نقش دارد. دکمه‌ها و منوهای کاربر اجازه‌ی استفاده از آن‌ها را ندارد، برایش نمایش داده نمی‌شوند.

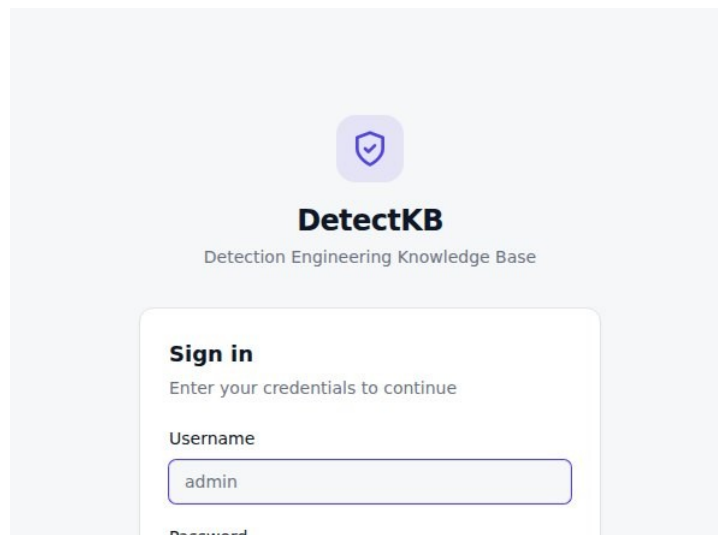
نقش	دسترسی
viewer	فقط مشاهده: صفحه‌ها، قوانین، تگ‌ها، گراف، پوشش ATT&CK و ساخت گزارش.
editor	همه‌ی دسترسی‌های viewer، به‌علاوه‌ی ساخت، ویرایش و حذف صفحه و قانون، ورود قوانین، مدیریت

نقش	دسترسی
	تگ و گرفتن پشتیبان.
admin	همه‌ی دسترسی‌ها، از جمله مدیریت کاربران، بازگردانی پشتیبان، گزارش فعالیت، انواع صفحه و به‌روزرسانی داده‌ی ابزارهای مهاجم.

فصل ۲ – شروع کار

ورود به سامانه

آدرس سامانه را در مرورگر باز کنید، نام کاربری و رمز عبور را وارد کنید و **Sign In** را بزنید. نام کاربری و رمز اولیه‌ی مدیر در پایان نصب نمایش داده می‌شود و در فایل `env` هم ثبت است.



شکل ۱ – صفحه‌ی ورود

نکته

اگر مدیر برای شما حساب ساخته یا رمزتان را بازنشانی کرده باشد، بعد از اولین ورود باید رمز جدیدی انتخاب کنید. تا رمز عوض نشود، سامانه به صفحه‌ی دیگری نمی‌رود. بعد از چند تلاش ناموفق، ورود برای ۱۵ دقیقه بسته می‌شود: ۱۰ تلاش اشتباه برای یک کاربر از یک دستگاه، یا ۳۰ تلاش اشتباه از یک دستگاه برای هر نام کاربری. پیام **Too many failed login attempts** زمان باقی‌مانده را می‌گوید. پیام خطای ورود عمداً نمی‌گوید نام کاربری اشتباه است یا رمز؛ این کار حدس زدن نام‌های کاربری را سخت می‌کند.

آشنایی با محیط

صفحه‌ی سامانه سه بخش ثابت دارد:

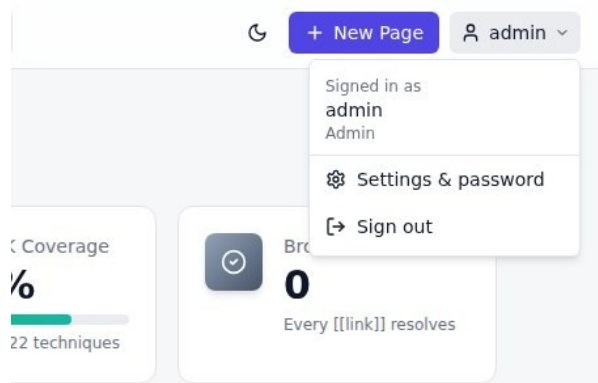
- **نوار کناری (سمت چپ):** دسترسی به همه‌ی بخش‌ها. بخش **Main** داشبورد است. بخش **Content** شامل فهرست صفحه‌ها، قوانین، پوشش ATT&CK، کتابخانه‌ی SPL، رویدادهای Sysmon، منابع لاگ، گروه‌های تهدید، سناریوهای تحلیلی، Atomic Red Team، ابزارهای مهاجم، منابع داده، مفاهیم و مستندسازی است.
- Saved views** نماهای ذخیره‌شده‌ی شماست. **Categories** دسته‌بندی صفحه‌هاست و با دکمه‌ی +

دسته‌ی جدید ساخته می‌شود. **Tools** جست‌وجو، گراف دانش، سلامت داده، به‌روزرسانی از مخزن‌های اصلی، لینک‌های شکسته، پشتیبان‌گیری و تنظیمات است. **Admin** فقط برای مدیر نمایش داده می‌شود. با **Collapse** پایین نوار، نوار کوچک می‌شود و فقط آیکون‌ها می‌مانند.

- **نوار بالا:** وضعیت اتصال به سرور (**Connected**)، جعبه‌ی جست‌وجوی سریع، دکمه‌ی تغییر حالت روشن و تاریک، دکمه‌ی **New Page** برای ساخت صفحه‌ی جدید، و **منوی کاربر** با نام شما.
- **محتوای اصلی:** صفحه‌ای که باز کرده‌اید. بالای هر صفحه مسیر آن (breadcrumb) نمایش داده می‌شود و با کلیک روی هر بخش مسیر، به آن برمی‌گردید.

منوی کاربر و خروج

با کلیک روی نام کاربری در گوشه‌ی نوار بالا، منوی کاربر باز می‌شود: نام و نقش شما، **Settings & password** برای رفتن به تنظیمات و تغییر رمز، و **Sign out** برای خروج.



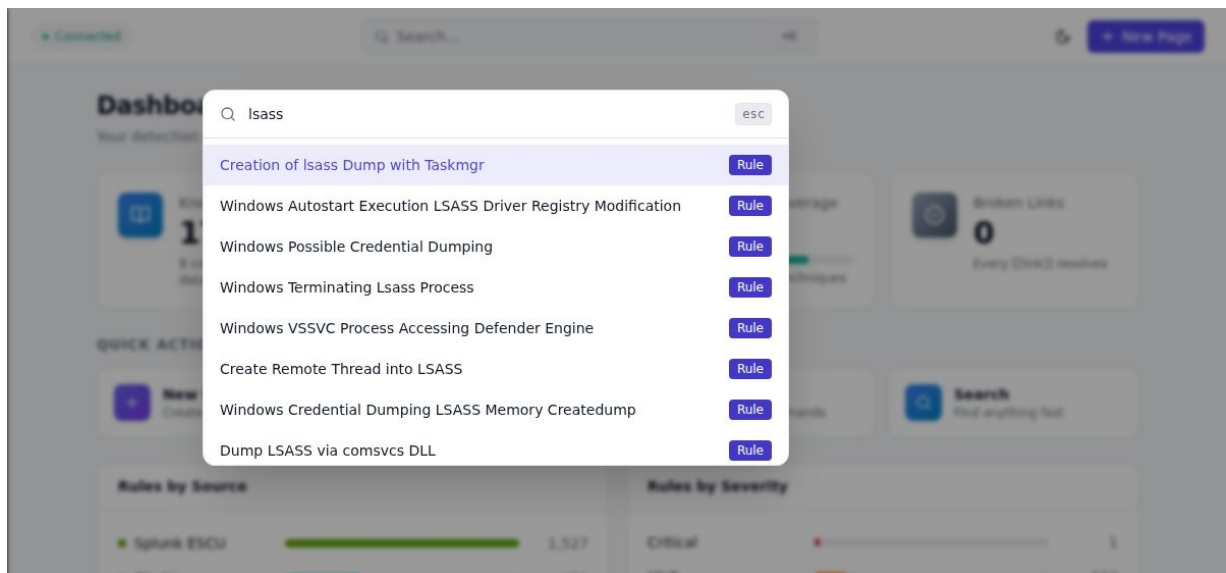
شکل ۲ – منوی کاربر

نکته

روی رایانه‌ی مشترک همیشه با **Sign out** خارج شوید. نشست ورود حداکثر ۲۴ ساعت معتبر است.

جست‌وجوی سریع

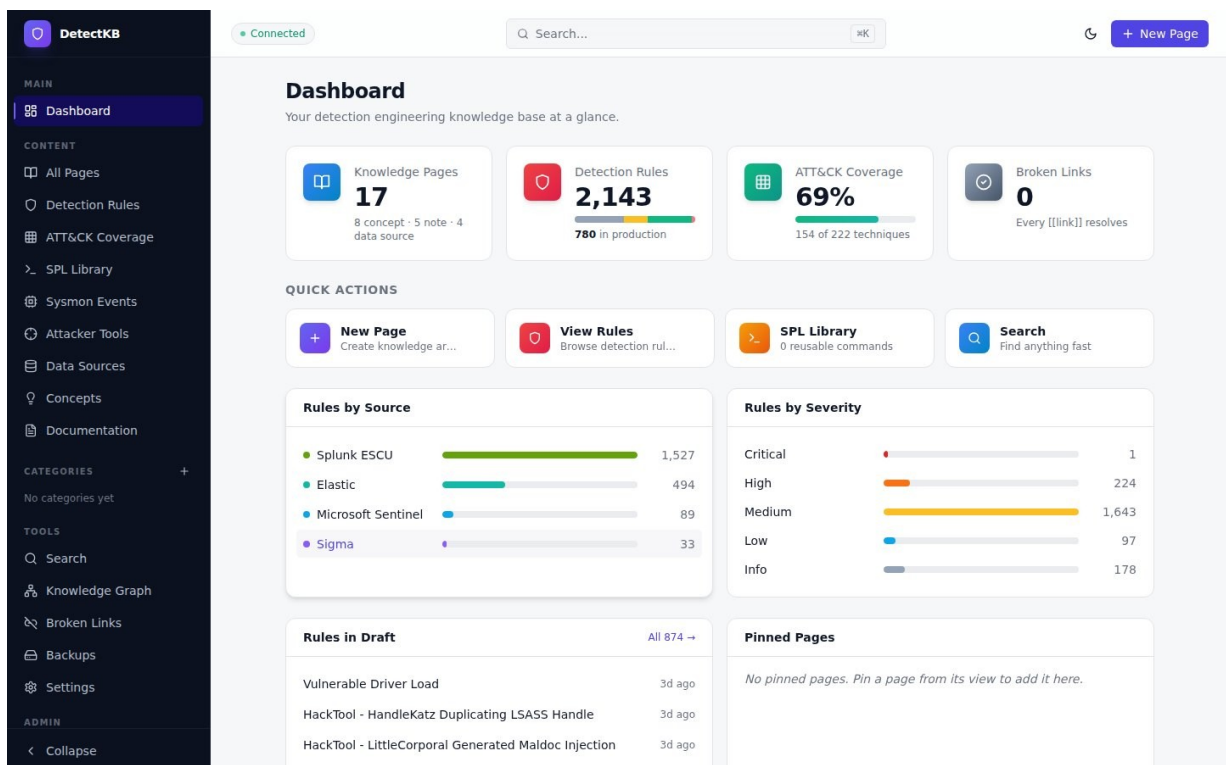
با **Ctrl+K** (در مک **⌘K**) یا کلیک روی جعبه‌ی **Search** در نوار بالا، پنجره‌ی جست‌وجوی سریع باز می‌شود. دست‌کم دو حرف تایپ کنید. نتیجه‌ها با کلیدهای جهت‌دار انتخاب و با **Enter** باز می‌شوند.



شکل ۳ - جستجوی سریع با Ctrl+K

داشبورد

داشبورد اولین صفحه بعد از ورود است و خلاصه‌ی وضعیت پایگاه دانش را نشان می‌دهد:



شکل ۴ - داشبورد

- **Knowledge Pages:** تعداد صفحه‌های دانش (بدون قوانین)، به تفکیک نوع.
- **Detection Rules:** تعداد کل قوانین، با نوار رنگی وضعیت‌ها و تعداد قوانین production.
- **ATT&CK Coverage:** درصد تکنیک‌های ATT&CK که دست‌کم یک قانون فعال دارند.
- **Broken Links:** تعداد لینک‌های ویکی که به صفحه‌ی ناموجود اشاره می‌کنند.

- **Rules by Source و Rules by Severity:** تعداد قوانین به تفکیک منبع و شدت. با کلیک روی هر ردیف، فهرست قوانین با همان فیلتر باز می‌شود.
 - **Rules in Draft:** آخرین قوانین پیش‌نویس. **Pinned Pages:** صفحه‌هایی که سنجاق کرده‌اید. **Recent Activity:** آخرین صفحه‌های ویرایش‌شده.
- همه‌ی کارت‌های بالای داشبورد قابل کلیک‌اند و صفحه‌ی مربوط را باز می‌کنند.

فصل ۳ – قوانین تشخیص

صفحه‌ی **Detection Rules** از نوار کناری باز می‌شود و مرکز کار با قوانین است.

The screenshot shows the DetectKB interface for managing Detection Rules. The sidebar on the left contains navigation links for MAIN (Dashboard), CONTENT (All Pages, Detection Rules, ATT&CK Coverage, SPL Library, Sysmon Events, Attacker Tools, Data Sources, Concepts, Documentation), CATEGORIES (No categories yet), TOOLS (Search, Knowledge Graph, Broken Links, Backups, Settings), and ADMIN (Collapse). The main panel is titled 'Detection Rules' and shows a total of 2,143 rules. It includes filters for Status (All), Severity (All), and Source (All). A table lists individual rules with their titles, statuses, severities, associated MITRE techniques, data sources, and update times.

Title	Status	Severity	MITRE Techniques	Data Source	Updated
Vulnerable HackSys Extreme Vulnerable Driver Load	Production	High	T1543.003	product:windows category:driver_load	3d ago
Driver Load From A Temporary Directory	Production	High	T1543.003	product:windows category:driver_load	3d ago
Vulnerable Driver Load	Draft	High	T1543.003 T1068	product:windows category:driver_load	3d ago
Malicious Driver Load	Production	High	T1543.003 T1068	product:windows category:driver_load	3d ago
PUA - Process Hacker Driver Load	Testing	High	T1543	product:windows category:driver_load	3d ago
Malicious Driver Load By Name	Testing	Medium	T1543.003 T1068	product:windows category:driver_load	3d ago
WinDivert Driver Load	Production	High	T1599.001 T1557.001	product:windows category:driver_load	3d ago
Vulnerable Driver Load By Name	Testing	Low	T1543.003 T1068	product:windows category:driver_load	3d ago

شکل ۵ – فهرست قوانین تشخیص

اجزای صفحه

- دکمه‌های بالا: **Save view** ذخیره‌ی فیلترها، **Export Sigma** خروجی **Import rules**، **Sigma** ورود قانون، و **New Rule** قانون جدید.
- **برچسب‌های وضعیت**: تعداد قوانین در هر وضعیت (Draft، Testing، Production، Deprecated). با کلیک روی هر کدام، فهرست به همان وضعیت فیلتر می‌شود و با کلیک دوباره فیلتر برداشته می‌شود.
- **جعبه‌ی جست‌وجو**: در عنوان، تکنیک، منبع داده، شناسه‌ی Sigma و منبع، و نام تگ جست‌وجو می‌کند.
- **فیلترها**: وضعیت (**Status**)، شدت (**Severity**) و منبع قانون (**Source**). گزینه‌ی **Written here** یعنی قوانینی که در خود سامانه نوشته شده‌اند.
- **دکمه‌ی تراکم**: آیکون کنار فیلترها، ردیف‌ها را فشرده یا راحت نمایش می‌دهد. انتخاب شما در همان مرورگر به خاطر سپرده می‌شود.
- **جدول**: عنوان (با منبع و تگ‌ها)، وضعیت، شدت، تکنیک‌های MITRE، منبع داده و زمان آخرین تغییر.
- **پایین جدول**: تعداد نتیجه‌ها، تعداد ردیف در هر صفحه (۲۵، ۵۰ یا ۱۰۰) و دکمه‌های رفتن به صفحه‌ی بعد و قبل.

جست‌وجو، فیلتر و مرتب‌سازی

با کلیک روی سر ستون‌های **Updated**، **Title**، **Status**، **Severity**، فهرست بر همان ستون مرتب می‌شود. کلیک دوباره ترتیب را برعکس می‌کند. شدت و وضعیت به ترتیب منطقی خودشان مرتب می‌شوند، نه الفبایی.

با کلیک روی شناسه‌ی یک تکنیک در جدول، مثل **T1003.001**، فقط قوانین همان تکنیک نشان داده می‌شوند. با کلیک روی برچسب منبع، مثل **Sigma**، هم فقط قوانین همان منبع می‌مانند. فیلتر تکنیک بالای جدول با علامت × نمایش داده می‌شود و با کلیک روی × برداشته می‌شود.

The screenshot displays the 'Detection Rules' management page. At the top, there are buttons for 'Save view', 'Export Sigma', 'Import rules', and 'New Rule'. Below these, a status filter bar shows counts for Draft (1), Testing (0), Production (0), and Deprecated (0). A search bar and three dropdown filters (Status: All, Severity: Critical, Source: All) are present. The main table lists rules with columns: Title, Status, Severity, MITRE Techniques, Data Source, and Updated. One rule is listed: 'Potential Invoke-Mimikatz PowerShell Script' (Draft, Critical) associated with MITRE techniques T1003, T1003.001, and T1003.002, sourced from 'PowerShell Logs', and updated '3d ago'. A 'Showing 1-1 of 1 rule' indicator and a 'Per page 50' dropdown are at the bottom of the table.

شکل ۶ – فهرست قوانین با فیلتر شدت critical، مرتب‌شده بر اساس عنوان

نکته

همه‌ی فیلترها، جست‌وجو و شماره‌ی صفحه در آدرس صفحه (URL) ذخیره می‌شوند. می‌توانید آدرس را برای همکاران بفرستید تا دقیقاً همین فهرست را ببینند. دکمه‌ی Back مرورگر هم فیلتر قبلی را برمی‌گرداند.

پیش‌نمایش کناری

با کلیک روی عنوان یک قانون، جزئیات آن در یک پنل کنار فهرست باز می‌شود و فهرست سر جایش می‌ماند. این پنل برای مرور سریع چند قانون پشت‌سرهم است.

☒	Driver Load From A Temporary Directory	Production	High	T1543.003	product:windows category:driver_load	3d ago
☒	Vulnerable Driver Load	Draft	High	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	Malicious Driver Load	Production	High	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	PUA - Process Hacker Driver Load	Testing	High	T1543	product:windows category:driver_load	3d ago
☐	Malicious Driver Load By Name	Testing	Medium	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	WinDivert Driver Load	Production	High	T1599.001 T1557.001	product:windows category:driver_load	3d ago
☐	Vulnerable Driver Load By Name	Testing	Low	T1543.003 T1068	product:windows category:driver_load	3d ago
☐	PUA - System Informer Driver Load	Production	Medium	T1543	product:windows category:driver_load	3d ago
☐	Vulnerable WinRing0 Driver Load	Testing	High	T1543.003	product:windows category:driver_load	3d ago
☐	LSASS Access From Potentially White-Listed Processes	Draft		T1003.001	product:windows category:process_access	3d ago
☐	Credential Dumping Attempt Via WerFault	Testing		T1003.001	product:windows category:process_access	3d ago
☐	Potential Credential Dumping Attempt Via LSASS	Testing	Medium	T1003.001	product:windows category:process_access	3d ago

شکل ۸ - نوار عملیات گروهی و منوی تغییر وضعیت

- **Select all ... matching**: اگر تمامی قوانین صفحه را انتخاب کرده باشید، این گزینه تمامی قوانین منطبق با فیلتر فعلی را انتخاب می‌کند، حتی آن‌هایی که در صفحه‌های بعدی‌اند.
- **Status و Severity**: تغییر وضعیت یا شدت تمامی قوانین انتخاب‌شده.
- **Tag**: افزودن یا حذف یک تگ. نام تگ را بنویسید و **Add tag** یا **Remove tag** را بزنید.
- **Export Sigma**: خروجی Sigma فقط از قوانین انتخاب‌شده.
- **Delete**: حذف قوانین انتخاب‌شده، بعد از تأیید.
- **x** یا کلید **Esc**: انتخاب را پاک می‌کند.

توجه

حذف گروهی قابل بازگشت نیست. صفحه‌ی قانون، کوئری‌ها، لینک‌ها و تاریخچه‌اش حذف می‌شوند. اگر مطمئن نیستید، قبل از حذف پشتیبان بگیرید (فصل ۱۴).

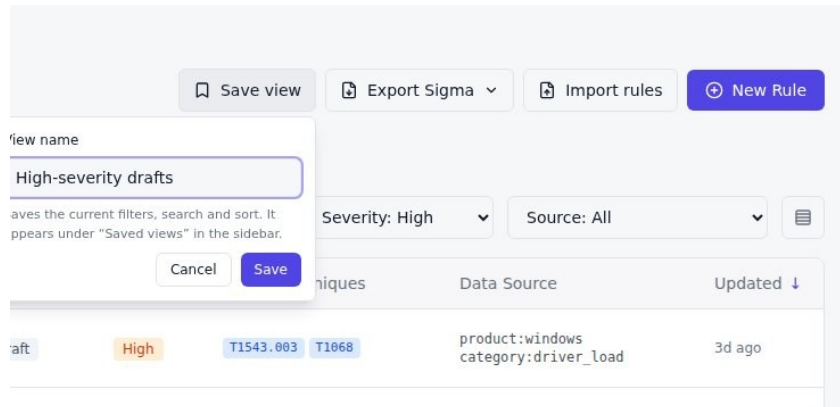
نماهای ذخیره‌شده

اگر ترکیبی از فیلترها را زیاد استفاده می‌کنید، مثلاً «قوانین draft با شدت high»، آن را ذخیره کنید:

1. فیلترها، جست‌وجو و مرتب‌سازی را تنظیم کنید.

2. روی **Save view** بالای صفحه کلیک کنید.

3. یک نام وارد کنید (سامانه نامی از روی فیلترها پیشنهاد می‌دهد) و **Save** را بزنید.

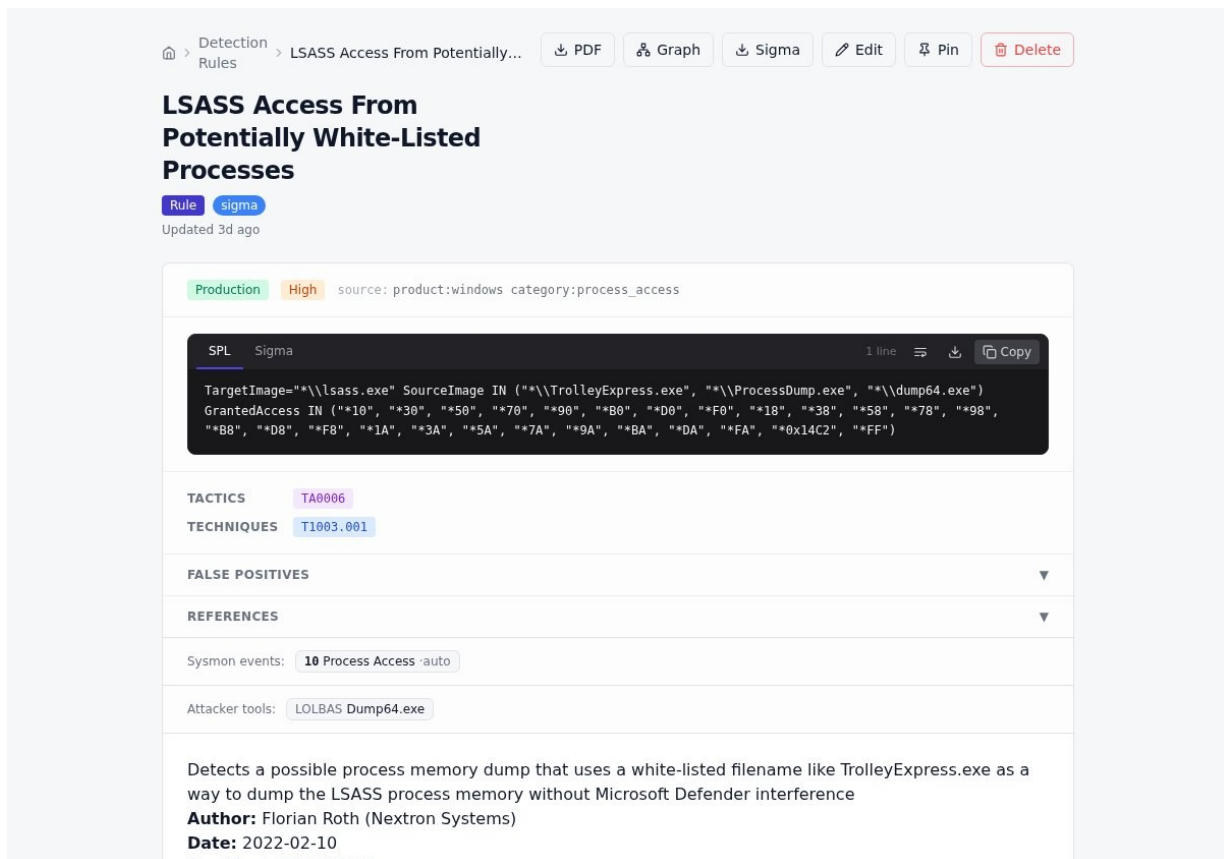


شکل ۹ – ذخیره‌ی نما

نما در بخش **Saved views** نوار کناری اضافه می‌شود و با یک کلیک همان فیلترها را برمی‌گرداند. برای حذف، ماوس را روی نام نما نگه دارید و **x** را بزنید. نماها برای هر کاربر جدا هستند. این دکمه در صفحه‌ی **All Pages** و گراف دانش هم هست.

صفحه‌ی قانون

با **Open page** در پیش‌نمایش، یا **Ctrl+کلیک** روی عنوان، صفحه‌ی کامل قانون باز می‌شود.



شکل ۱۰ – صفحه‌ی یک قانون Sigma

- **دکمه‌های بالا: PDF** خروجی PDF از صفحه، **Graph** نمایش قانون در گراف دانش، **Sigma** دانلود فایل **Edit**، **Sigma** ویرایش، **Pin** سنجاق به داشبورد، و **Delete** حذف.
- **کادر کوئری‌ها:** کوئری‌های قانون در تب‌های جدا: **SPL**، کوئری اصلی قوانین Elastic و Sentinel (مثل **EQL** یا **KQL**)، **Sigma**، و فایل اصلی واردشده (**Original** ...). هر تب دکمه‌های کپی (**Copy**)، دانلود و شکستن خطوط بلند دارد. آخرین تبی که انتخاب کرده‌اید در قانون بعدی هم باز می‌ماند.
- **Tactics / Techniques:** با کلیک روی هر شناسه، فهرست قوانین همان تکنیک یا تاکتیک باز می‌شود.
- **False Positives, References, Test Notes:** با کلیک باز می‌شوند.
- **Sysmon events:** رویدادهایی که قانون به آن‌ها وابسته است. برچسب **auto** یعنی سامانه آن را از کوئری تشخیص داده است.
- **Attacker tools:** ابزارهای LOLBAS، GTF0Bins یا LOLDrivers که در کوئری قانون آمده‌اند.
- **Backlinks:** صفحه‌هایی که با لینک ویکی به این قانون اشاره کرده‌اند.
- **نشان اعتبارسنجی:** کنار وضعیت و شدت قانون، نتیجه‌ی آخرین تست قانون در لب نمایش داده می‌شود (مثل **Validated** یا **Failed in lab**). بخش **Lab validation · Atomic Red Team** تاریخچه‌ی تست‌ها، فرم ثبت نتیجه و تست‌های پیشنهادی را دارد (فصل ۱۱).

Detection Rules > Potential Credential Access via...
PDF Graph Sigma Edit Pin Delete

Potential Credential Access via LSASS Memory Dump

Rule elastic
Updated 3d ago

Testing High source: Sysmon

EQL

Original Elastic

12 lines

Copy

```

process where host.os.type == "windows" and event.code == "10" and
winlog.event_data.TargetImage : "?:\\WINDOWS\\system32\\lsass.exe" and

/* dbgcore.dll hosts MiniDumpWriteDump on modern Windows; dbgcore-only traces are non-dump usage */
winlog.event_data.CallTrace : "**dbgcore*" and

/* crash handlers */
not process.executable : (
  "?:\\Windows\\System32\\WerFault.exe",
  "?:\\Windows\\SysWOW64\\WerFault.exe",
  "?:\\Windows\\System32\\WerFaultSecure.exe"
)
          
```

TACTICS

TA0006 TA0002

TECHNIQUES

T1003 T1003.001 T1106

REFERENCES

▼

Sysmon events:

10 Process Access · auto

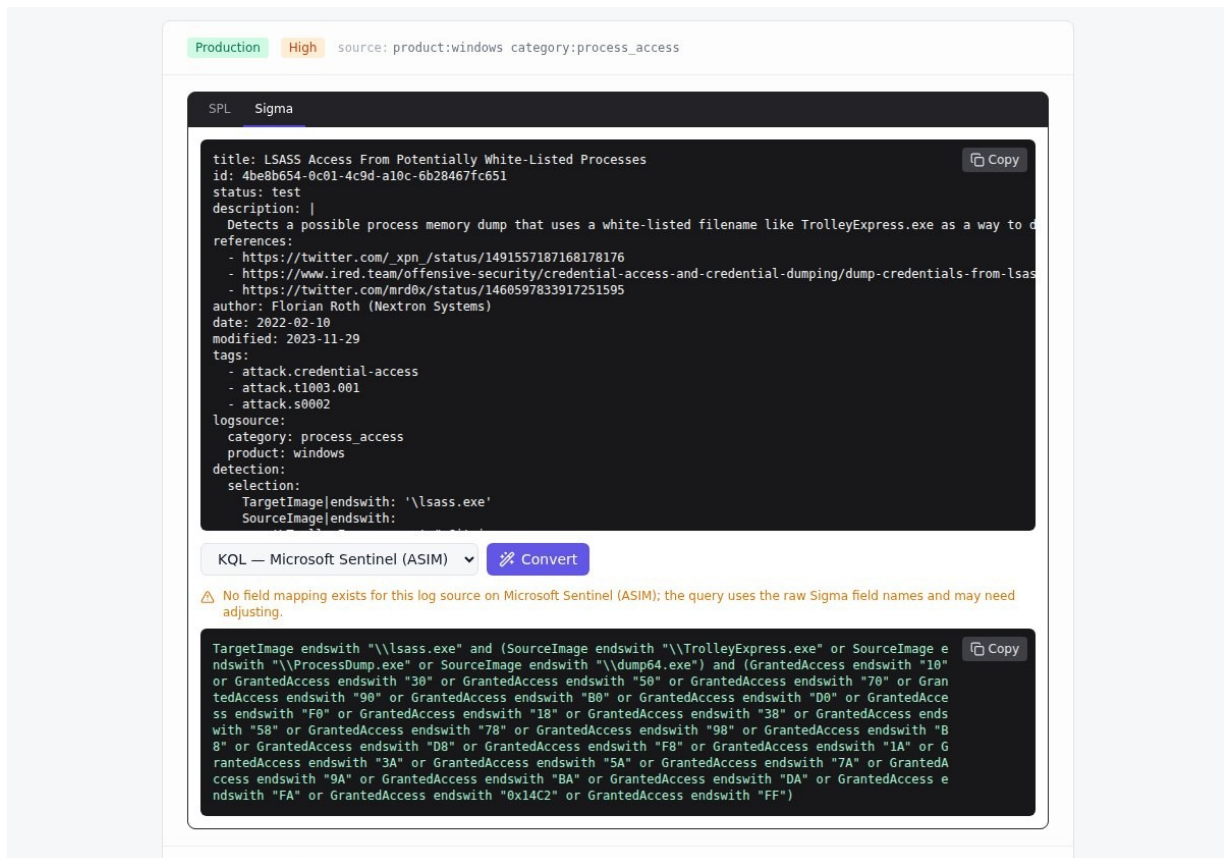
Identifies suspicious access to LSASS handle from a call trace pointing to DBGHelp.dll or DBGCore.dll, which both export the MiniDumpWriteDump method that can be used to dump LSASS memory content in

شکل ۱۱ – قانون Elastic با تب کوئری EQL و فایل اصلی

تبدیل Sigma به زبان SIEM

برای قانونی که منبع Sigma دارد، می‌توانید کوئری را برای SIEM خودتان بسازید:

1. در کادر کوئری‌ها، تب **Sigma** را باز کنید.
2. زبان مقصد را انتخاب کنید: **SPL — Splunk**، **KQL — Microsoft Defender XDR**، **KQL — Microsoft Sentinel (ASIM)**، **EQL — Elastic (ECS)** یا **Lucene — Elastic (ECS)**.
3. **Convert** را بزنید. کوئری ساخته‌شده زیر آن نمایش داده می‌شود و با **Copy** کپی می‌شود.



شکل ۱۲ – تبدیل قانون Sigma به KQL برای Microsoft Sentinel

نکته

اگر برای منبع لاگ قانون نگاشت فیلدی در زبان مقصد وجود نداشته باشد، پیام زردرنگی نمایش داده می‌شود. در این حالت کوئری با نام‌های اصلی فیلدهای Sigma ساخته شده و باید آن را با نام فیلدهای محیط خود تطبیق دهید.

ساخت و ویرایش قانون

برای قانون جدید، **New Rule** را در صفحه قوانین بزنید. برای ویرایش، **Edit** را در صفحه قانون بزنید. فرم دو بخش دارد:

🏠 > Pages > Edit: Detect Credential Dumpin...

Edit Page

Cancel Save

Title *

Detect Credential Dumping through LSASS access

Type Category Tags (comma-separated)

Rule — None — splunk-escu ☐ Pinned

Content Type [[Page Title]] to link pages

B I [Icons] [Icons]

The following analytic detects attempts to read LSASS memory, indicative of credential dumping. It leverages Sysmon EventCode 10 and checks for "PROCESS_VM_READ" with query information access on lsass.exe.

How to implement

This search needs Sysmon Logs and a sysmon configuration, which includes EventCode 10 with lsass.exe. This search uses an input macro named `sysmon`. We strongly recommend that you specify your environment-specific configurations (index, source, sourcetype, etc.) for Windows Sysmon logs. Replace the macro definition with configurations for your Splunk environment. The search also uses a post-filter macro designed to filter out known false positives.

Data sources

- Sysmon EventID 10

Analytic stories

- Detect Zerologon Attack
- CISA AA23-347A
- Credential Dumping
- BlackSuit Ransomware

The following analytic detects attempts to read LSASS memory, indicative of credential dumping. It leverages Sysmon EventCode 10 and checks for "PROCESS_VM_READ" with query information access on lsass.exe.

How to implement

This search needs Sysmon Logs and a sysmon configuration, which includes EventCode 10 with lsass.exe. This search uses an input macro named `sysmon`. We strongly recommend that you specify your environment-specific configurations (index, source, sourcetype, etc.) for Windows Sysmon logs. Replace the macro definition with configurations for your Splunk environment. The search also uses a post-filter macro designed to filter out known false positives.

Detection Rule Details

شکل ۱۳ – بخش بالای فرم: عنوان، نوع، دسته، تگ‌ها و متن توضیح

- **Title:** عنوان قانون (اجباری).
- **Type:** نوع صفحه. برای قانون، **Rule** است.
- **Category** و **Tags:** دسته‌بندی و تگ‌ها. تگ‌ها را با ویرگول جدا کنید.
- **Pinned:** سنجاق کردن صفحه به داشبورد.
- **Content:** توضیح قانون به زبان Markdown. سمت چپ متن را می‌نویسید و سمت راست نتیجه را می‌بینید. برای لینک به صفحه‌ی دیگر، [] تایپ کنید (فصل ۱۲).

Detection Rule Details

Status

Testing

Severity

Medium

SPL Query

```

`sysmon`
EventCode=10
TargetImage="*\\lsass.exe"

...

Convert GrantedAccess from hexadecimal to decimal.
Match "PROCESS_VM_READ" with either "PROCESS_QUERY_LIMITED_INFORMATION" or
"PROCESS_QUERY_INFORMATION", which represent the either the "0x1010" or "0x1410" hexadecimal
masks

```

Copy

Other query language (KQL, EQL, ES|QL, Lucene)

Sigma rule (optional — source for SPL/KQL/EQL conversion and Sigma export)

MITRE Tactics

TA0006, TA0003

Comma-separated tactic IDs

MITRE Techniques

T1003.001

Comma-separated technique IDs

Data Source

Sysmon EventID 10

False Positives

The activity may be legitimate. Other tools can access lsass for legitimate reasons, and it's possible this event could be generated in those cases. In these cases, false positives should be fairly obvious and you may need to tweak the search to eliminate noise.

شکل ۱۴ – بخش Detection Rule Details: وضعیت، شدت، کوئری‌ها و ATT&CK

فیلد	توضیح
Status / Severity	وضعیت و شدت قانون.
SPL Query	کوئری Splunk قانون.
Other query language	کوئری به زبان دیگر (KQL, EQL, ES QL, Lucene) و انتخاب زبان آن.
Sigma rule	متن YAML قانون Sigma (اختیاری). از روی آن می‌شود کوئری ساخت و خروجی Sigma گرفت. با گزینه‌ی تبدیل به Splunk، نتیجه مستقیم در SPL Query قرار می‌گیرد.
MITRE Tactics	شناسه‌ی تاکتیک‌ها با ویرگول، مثل TA0006, TA0003.
MITRE Techniques	شناسه‌ی تکنیک‌ها با ویرگول، مثل T1003.001.
Data Source	منبع داده‌ی قانون به صورت متن.
False Positives	مواردی که ممکن است قانون به اشتباه هشدار بدهد.
References	منابع و لینک‌ها، هر کدام در یک خط.
Test Notes	روش تست، نتیجه‌ی مورد انتظار و پیش‌نیازهای محیط.
Sysmon events	رویدادهایی که قانون به آن‌ها وابسته است (پایین فرم).

System Event ID

False Positives

The activity may be legitimate. Other tools can access lsass for legitimate reasons, and it's possible this event could be generated in those cases. In these cases, false positives should be fairly obvious and you may need to tweak the search to eliminate noise.

References

<https://www.microsoft.com/en-us/security/blog/2022/10/05/detecting-and-preventing-lsass-credential-dumping-attacks/>
<https://attack.mitre.org/techniques/T1003/001/>

One URL per line

Test Notes

Describe how to test this rule, expected results, environment requirements...

Sysmon events

Events this page depends on. Links are also detected automatically from the SPL query / Sigma logsource (e.g. EventCode=10 with Sysmon, or category: process_access) when you save.

1 Process Creation

2 File Creation Time Changed

3 Network Connection

4 Sysmon Service State Changed

5 Process Terminated

6 Driver Loaded

7 Image Loaded

8 CreateRemoteThread

9 RawAccessRead

10 Process Access (auto)

11 FileCreate

12 Registry Object Created/Deleted

13 Registry Value Set

14 Registry Key/Value Renamed

15 FileCreateStreamHash

16 ServiceConfigurationChange

17 Pipe Created

18 Pipe Connected

19 WMI EventFilter Activity

20 WMI EventConsumer Activity

21 WMI ConsumerToFilter Binding

22 DNS Query

23 File Delete Archived

24 Clipboard Change

25 Process Tampering

26 File Delete Detected

27 File Block Executable

28 File Block Shredding

29 File Executable Detected

شکل ۱۵ – انتخاب رویدادهای Sysmon؛ رویداد 10 به طور خودکار تشخیص داده شده است

سامانه هنگام ذخیره، رویدادهای Sysmon را از کوئری (مثل `EventCode=10`) یا logsource قانون Sigma (مثل `category: process_access`) خودکار تشخیص می‌دهد. رویدادهای خودکار با **(auto)** مشخص شده‌اند. با کلیک روی هر رویداد، آن را دستی اضافه یا حذف می‌کنید.

در پایان **Save** را بزنید. **Cancel** بدون ذخیره برمی‌گردد.

فصل ۴ – ورود و خروج قوانین

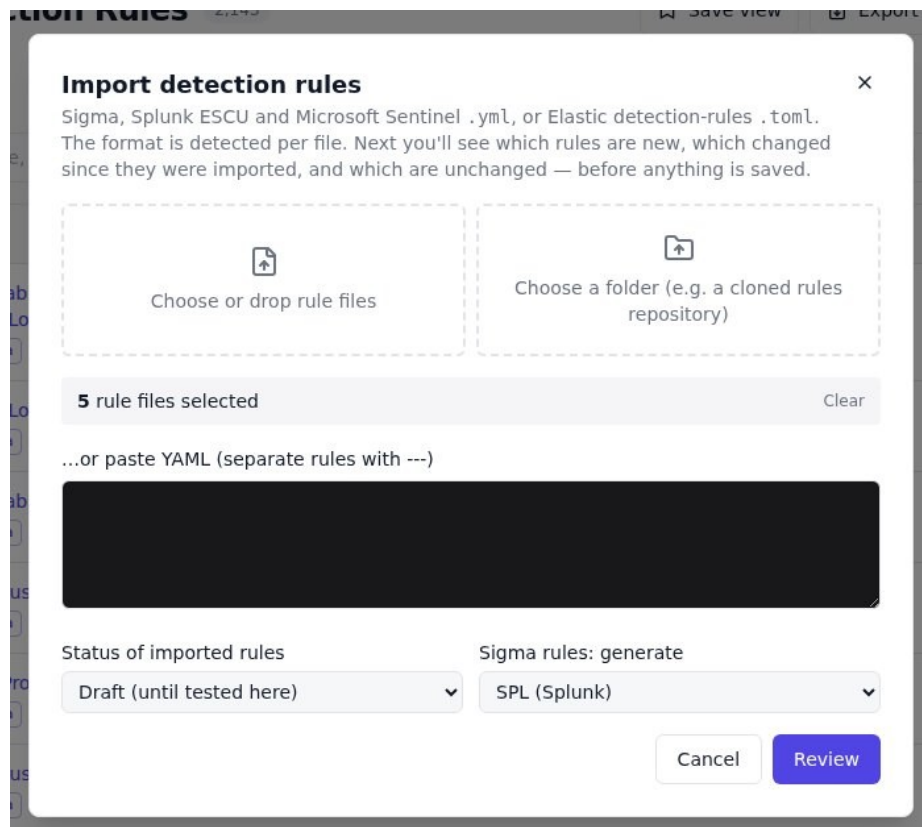
قوانین را می‌توانید از مخزن‌های عمومی یا فایل‌های خودتان وارد کنید. قالب‌های پشتیبانی‌شده:

- **Sigma** – فایل `.yaml`
- **Splunk ESCU** (security_content) – فایل `.yaml`
- **Microsoft Sentinel** – فایل `.yaml`
- **Elastic detection-rules** – فایل `.toml`

قالب هر فایل خودکار تشخیص داده می‌شود و می‌توانید چند قالب را با هم وارد کنید.

مراحل ورود

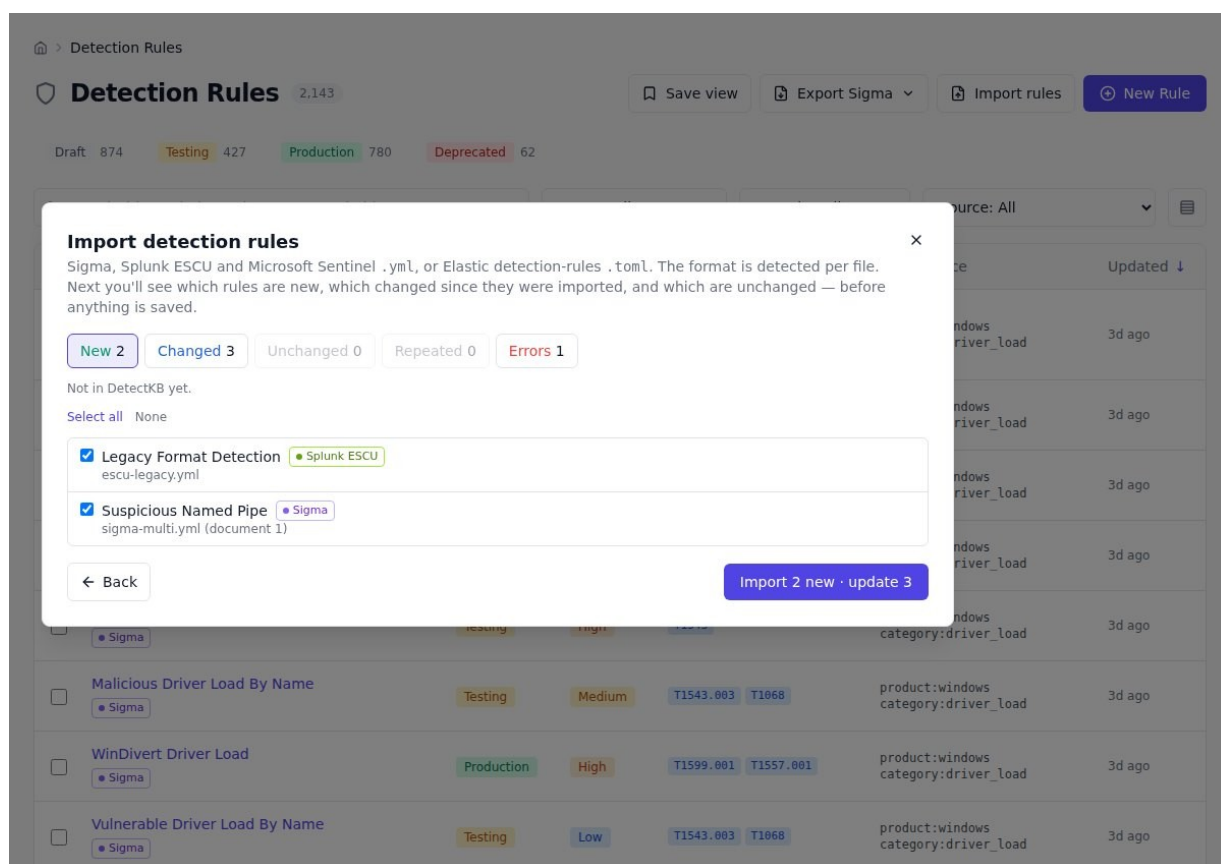
1. در صفحه‌ی قوانین، **Import rules** را بزنید.
2. فایل‌ها را انتخاب یا روی کادر رها کنید (**Choose or drop rule files**)، یا یک پوشه‌ی کامل انتخاب کنید (**Choose a folder**)، مثلاً پوشه‌ی clone شده‌ی مخزن SigmaHQ. می‌توانید متن YAML را هم مستقیم در کادر پایین بچسبانید. چند قانون را با --- از هم جدا کنید.
3. در **Status of imported rules** مشخص کنید قوانین با وضعیت **Draft** وارد شوند (پیشنهادی) یا وضعیت اعلام‌شده در منبع حفظ شود.
4. در **Sigma rules: generate** مشخص کنید برای قوانین Sigma کوئری SPL ساخته شود یا نه.
5. **Review** را بزنید. هنوز چیزی ذخیره نشده است.



شکل ۱۶ — پنجره‌ی ورود قوانین

بازبینی قبل از ذخیره

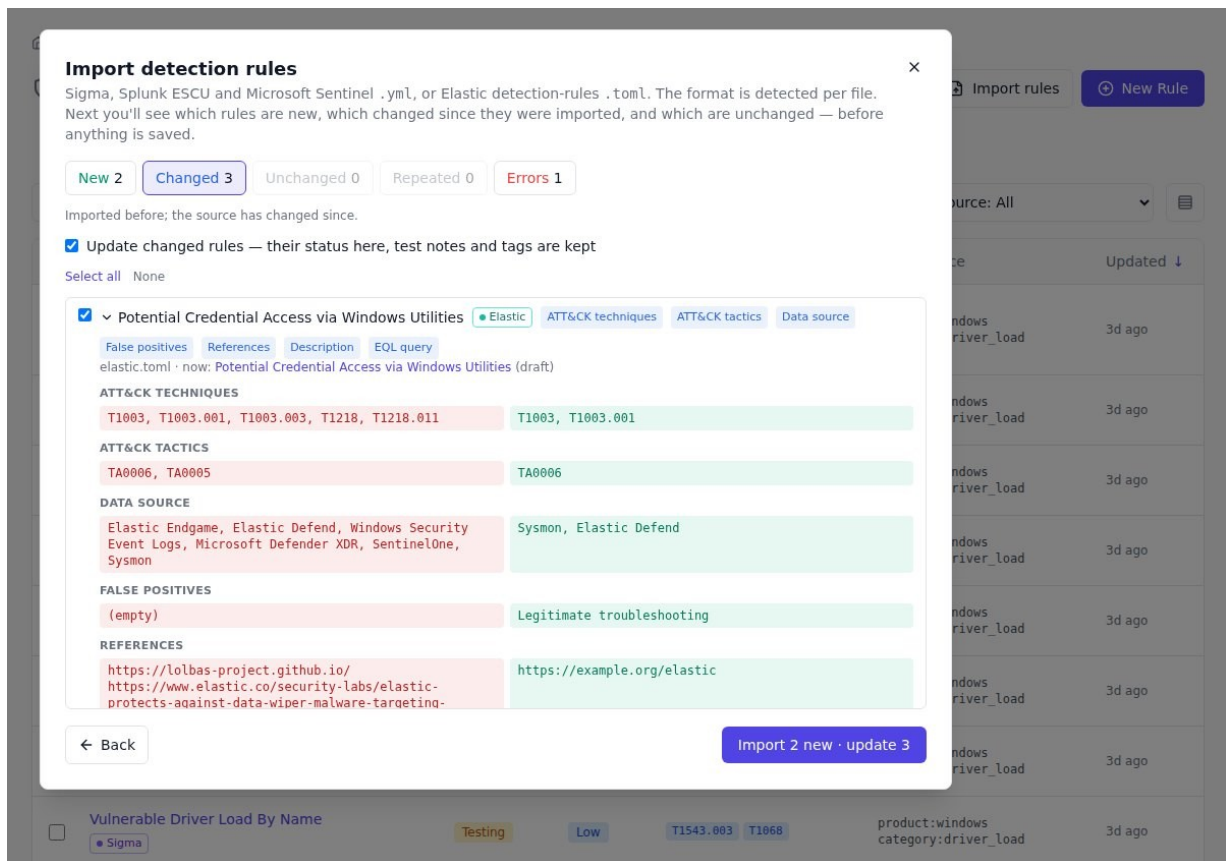
در مرحله‌ی بازبینی، قوانین در پنج دسته قرار می‌گیرند:



شکل ۱۷ – صفحه‌ی بازبینی: دسته‌ی قوانین جدید

دسته	معنی	رفتار
New	قانونی که هنوز در سامانه نیست.	ساخته می‌شود؛ می‌توانید تیک هر کدام را بردارید.
Changed	قبلاً وارد شده، ولی منبع اصلی از آن زمان تغییر کرده است.	اگر Update changed rules روشن باشد، به‌روز می‌شود.
Unchanged	قبلاً وارد شده و با منبع یکسان است.	نادیده گرفته می‌شود.
Repeated	همین قانون در همین آپلود قبلاً آمده است.	نادیده گرفته می‌شود.
Errors	فایل خوانده نشد، مثلاً به دلیل YAML نامعتبر یا فیلد ناقص.	نادیده گرفته می‌شود و علت خطا نمایش داده می‌شود.

در دسته‌ی **Changed**، با کلیک روی عنوان هر قانون، تفاوت فیلدها دیده می‌شود: مقدار فعلی با زمینه‌ی قرمز و مقدار جدید با زمینه‌ی سبز.



شکل ۱۸ – تفاوت فیلد به فیلد یک قانون تغییرکرده

نکته

اگر قانون جدیدی هم نام یک قانون موجود باشد، سامانه آن را به عنوان «احتمالاً همان تشخیص از منبعی دیگر» علامت می‌زند. با **Leave those out** می‌توانید همه‌ی این موارد را کنار بگذارید. در به‌روزرسانی یک قانون، وضعیت فعلی آن در سامانه، یادداشت‌های تست و تگ‌ها حفظ می‌شوند.

در پایان، دکمه‌ی پایین (مثلاً **Import 2 new · update 3**) را بزنید. بعد از ورود، فهرست قوانین ساخته‌شده، به‌روزرشده، نادیده‌گرفته‌شده و خطاها نمایش داده می‌شود.

توجه

قوانین منابع دیگر برای مدل داده‌ی همان محصول نوشته شده‌اند، مثل Elastic ECS، Splunk CIM یا جدول‌های Sentinel. قبل از استفاده، نام فیلدها، index و sourcetype را با محیط خود تطبیق دهید و قانون را در وضعیت testing تست کنید.

بهروزرسانی از مخزن‌های اصلی

مخزن‌های عمومی مثل (ESCU) Splunk security_content، SigmaHQ، Elastic detection-rules و مدام قانون جدید اضافه یا قانون‌های قبلی را اصلاح می‌کنند. صفحه‌ی **Upstream Updates** (در بخش Tools) نشان می‌دهد از آخرین بار چه چیزی تغییر کرده است. سامانه هیچ چیزی را خودکار وارد نمی‌کند؛ فقط فهرست می‌دهد و شما انتخاب می‌کنید.

- **کارت هر منبع:** تعداد قانون‌های تغییرکرده و جدید، زمان آخرین بررسی و دکمه‌ی **Check now**. سامانه هر ۷ روز یک بار منابع فعال (تیک **Weekly**) را خودکار بررسی می‌کند. منبعی که از آن قانون وارد کرده‌اید خودکار فعال است. برای SigmaHQ می‌توانید بسته را انتخاب کنید: **Core** (قانون‌های stable و test)، **Core+** (به‌علاوه‌ی experimental) یا **All rules**.
- **Check a folder:** برای سرور بدون اینترنت، یا برای Microsoft Sentinel. پوشه‌ی قانون‌ها (مثلاً یک clone از مخزن) را انتخاب کنید تا با قانون‌های فعلی مقایسه شود.

قانون‌های تغییرکرده

در تب **Changed** قانون‌هایی آمده که قبلاً وارد کرده‌اید و منبع اصلی آن‌ها را عوض کرده است. با کلیک روی هر قانون، تغییرات فیلدبه‌فیلد نمایش داده می‌شود: نسخه‌ی فعلی شما با رنگ قرمز و نسخه‌ی جدید با رنگ سبز. لینک **Updates ...** قانون فعلی شما را باز می‌کند.

The screenshot displays the 'Upstream Updates' section of the DetectKB interface. At the top, it indicates 'New and changed rules in the repositories your rules came from. Nothing is imported until you choose it - checked every 7 days.' Below this, there are four panels for different rule sources: SigmaHQ, Splunk security_content (ESCU), Elastic detection-rules, and Uploaded files. Each panel shows the status of rules (e.g., '0 changed', '1352 new') and a 'Check now' button. A 'Check a folder' button is also present. Below the panels, there are filters for 'Changed (1)', 'New (1353)', and 'All sources'. A search bar is available for finding rules by title, technique, or path. A checkbox for 'Convert Sigma to SPL' is also shown. The main content area displays a list of rules, with the first rule being 'Jscript Execution Using Cscript App' from the 'Splunk ESCU' source. This rule is marked as 'Testing' and 'Changed: Description T1059.007'. The description of the rule states: 'The following analytic detects the execution of JScript using the cscript.exe process. It leverages data from Endpoint Detection and Response (EDR) agents, focusing on process and command-line telemetry. This behavior is significant because JScript files are typically executed by wscript.exe, making cscript.exe execution unusual and potentially indicative of malicious activity, such as the FIN7 group's tactics. If confirmed malicious, this activity could allow attackers to execute arbitrary scripts, leading to code execution, data exfiltration, or further system compromise. ## How to implement...'. The rule is also marked as 'Medium' severity. The interface includes a 'Apply the changes' button and a 'Dismiss' button.

شکل ۱۹ – قانونی که در مخزن اصلی تغییر کرده، با نمایش تفاوت‌ها

قانون‌های جدید

در تب **New** قانون‌هایی آمده که هنوز ندارید. گزینه‌ی **For my telemetry** (پیش‌فرض روشن) فقط قانون‌هایی را نشان می‌دهد که روی لاگ‌هایی کار می‌کنند که قانون‌های Production یا testing شما همین الان از آن‌ها استفاده می‌کنند؛ یعنی به احتمال زیاد آن لاگ را جمع می‌کنید. این قانون‌ها برچسب سبز **Your telemetry** دارند. **Show the file** اصلی قانون را نشان می‌دهد.

The screenshot shows the 'Upstream Updates' section of the DetectKB interface. It features four panels for different rule sources: SigmaHQ, Splunk security_content (ESCU), Elastic detection-rules, and Uploaded files. Each panel displays the number of changed and new rules, a 'Check now' button, and a 'Weekly' checkbox. Below these panels is a table of updates with columns for source, title, status, and severity. The table lists several updates, including 'AADInternals PowerShell Cmdlets Execution - PsScript' and 'Abusable DLL Potential Sideloads From Suspicious Location'. At the bottom, there are buttons for 'Import', 'Dismiss', and 'Convert Sigma to SPL'.

شکل ۲۰ – قانون‌های جدید SigmaHQ که روی تله‌متری فعلی شما کار می‌کنند

وارد کردن یا رد کردن

1. قانون‌های موردنظر را تیک بزنید (یا **Select all on this page**).
2. برای قانون‌های جدید، **Keep the source's status** وضعیت منبع را نگه می‌دارد؛ در غیر این صورت قانون به صورت draft وارد می‌شود. **Convert Sigma to SPL** برای قانون‌های Sigma کوئری SPL می‌سازد.
3. **Apply the changes** (در تب Changed) یا **Import** (در تب New) را بزنید. وضعیت قانون‌های موجود تغییر نمی‌کند.
4. **Dismiss** قانون را از فهرست حذف می‌کند. اگر منبع بعداً دوباره همان قانون را تغییر دهد، دوباره نمایش داده می‌شود.

نکته

اگر کوئری قانونی را که در لب تست کرده‌اید با نسخه‌ی جدید جایگزین کنید، وضعیت اعتبارسنجی آن به **Retest** تغییر می‌کند (فصل ۱۱).

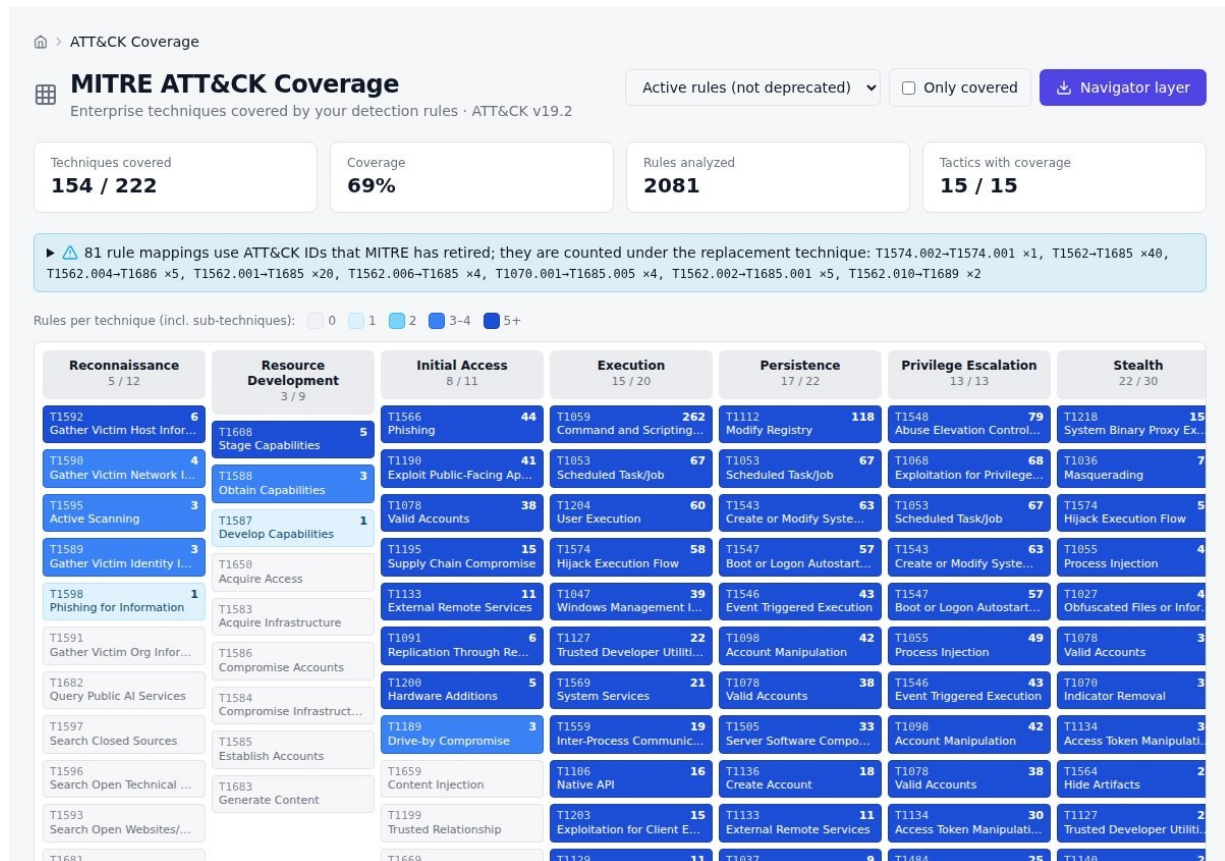
در صفحه‌ی **Data Health**، بررسی **Imported rules changed upstream** همین قانون‌های تغییرکرده را فهرست می‌کند.

خروجی Sigma

- **همه‌ی قوانین:** منوی **Export Sigma** در صفحه‌ی قوانین. گزینه‌ی **Rules with a Sigma source** فقط قوانینی را که منبع Sigma دارند خروجی می‌دهد. گزینه‌ی **All rules** برای بقیه‌ی قوانین هم یک اسکلت Sigma می‌سازد که باید کامل شود.
- **قوانین انتخاب‌شده:** **Export Sigma** در نوار عملیات گروهی.
- **یک قانون:** دکمه‌ی **Sigma** در صفحه‌ی قانون.

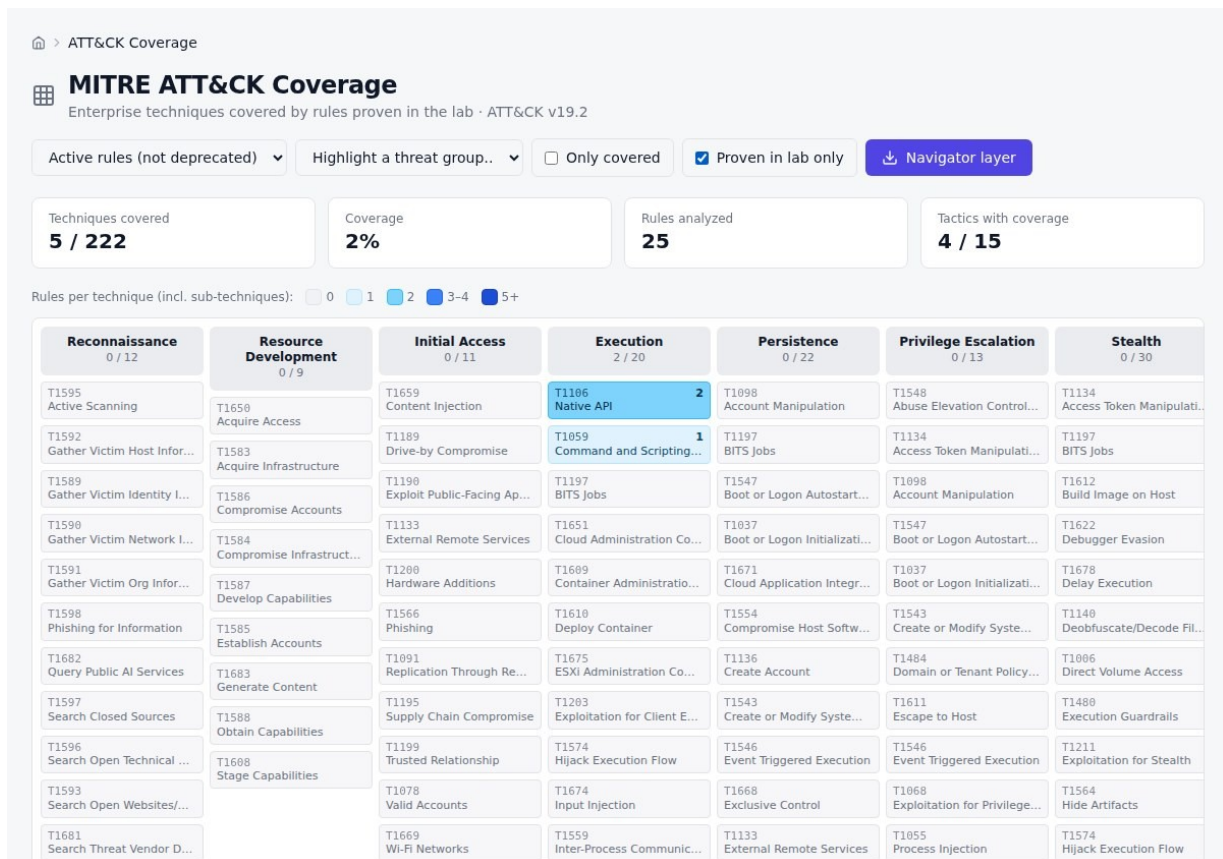
فصل ۵ – پوشش MITRE ATT&CK

صفحه **ATT&CK Coverage** ماتریس کامل ATT&CK Enterprise را نشان می‌دهد. هر ستون یک تاکتیک است و هر خانه یک تکنیک.



شکل ۲۱ – ماتریس پوشش ATT&CK

- **کارت‌های بالا:** تعداد تکنیک‌های پوشش داده‌شده، درصد پوشش، تعداد قوانین بررسی‌شده و تعداد تاکتیک‌هایی که دست‌کم یک قانون دارند.
- **رنگ خانه‌ها:** تعداد قوانین تکنیک و زیرتکنیک‌هایش. هر چه تیره‌تر، قوانین بیشتر. خاکستری یعنی بدون قانون. راهنمای رنگ بالای ماتریس است.
- **فیلتر وضعیت:** پیش‌فرض همه قوانین به‌جز deprecated حساب می‌شوند. می‌توانید فقط **Production** یا **Production + testing** را ببینید.
- **Only covered:** فقط تکنیک‌های دارای قانون.
- **Proven in lab only:** فقط قوانینی را حساب می‌کند که آخرین تستشان در لب حمله را تشخیص داده است (فصل ۱۱). این «پوشش اثبات‌شده» است، در برابر پوشش ادعاشده‌ی حالت عادی.
- **Navigator layer:** دانلود لایه برای ATT&CK Navigator، ابزار رسمی MITRE. اگر **Proven in lab** روشن باشد، لایه هم فقط پوشش اثبات‌شده را دارد.



شکل ۲۲ – پوشش اثبات‌شده: فقط قوانینی که در لب تست و تأیید شده‌اند

با کلیک روی هر خانه، جزئیات آن تکنیک زیر ماتریس باز می‌شود: قوانینی که مستقیم به تکنیک نگاشت شده‌اند، وضعیت پوشش هر زیرتکنیک، و لینک به سایت MITRE، زنجیره‌ی تشخیص و گراف دانش.

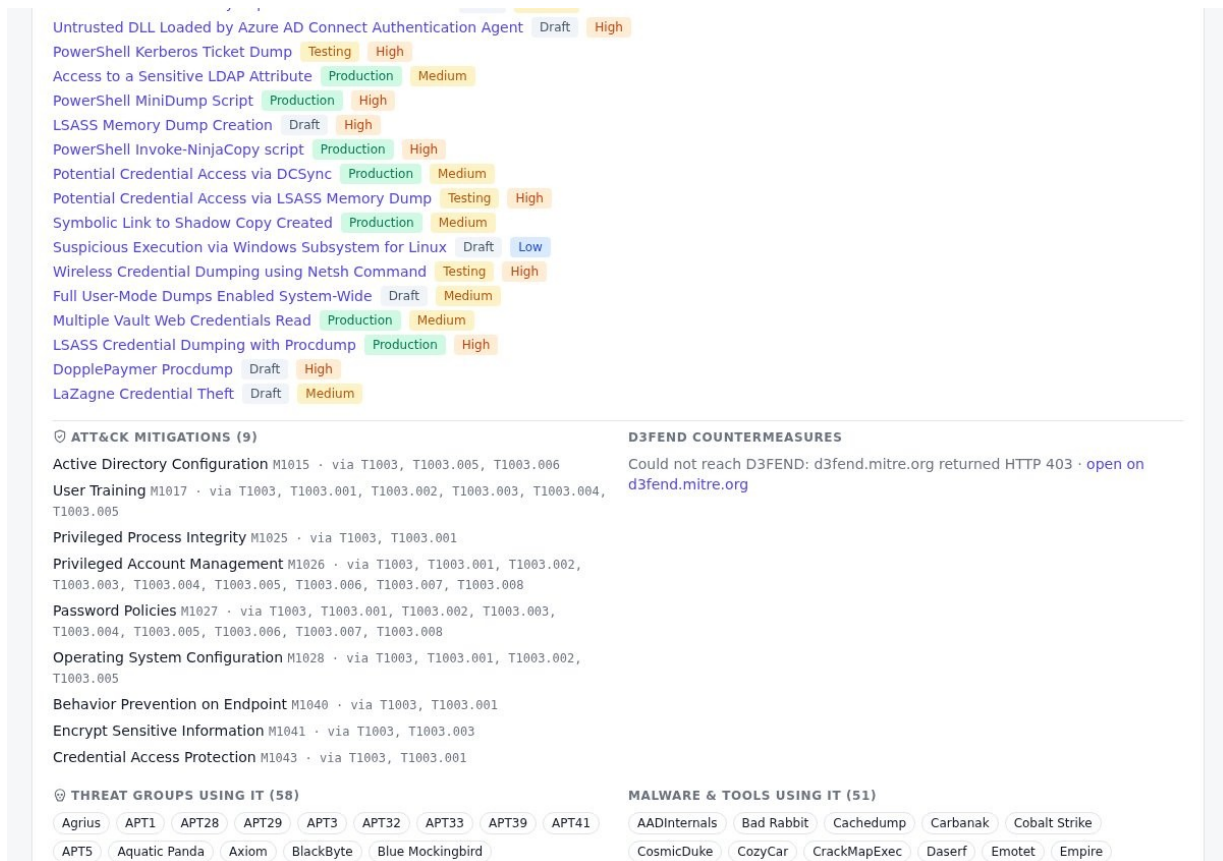
The screenshot displays the DetectKB interface. On the left, a vertical list of MITRE TTPs is shown, including T1538 Cloud Service Dashboard, T1526 Cloud Service Discovery, T1619 Cloud Storage Object Di..., T1613 Container and Resource..., T1622 Debugger Evasion, T1652 Device Driver Discovery, T1680 Local Storage Discovery, T1614 System Location Discov..., T1124 System Time Discovery, and T1673 Virtual Machine Discovery. The right pane shows the details for T1003 OS Credential Dumping, including links to attack.mitre.org, detection chain, and graph. Below this, a table lists rules mapped to T1003 (57) with columns for rule name, status, and severity.

Rule Name	Status	Severity
PetitPotam Suspicious Kerberos TGT Request	Draft	Medium
Windows Mimikatz Binary Execution	Production	Medium
Windows Post Exploitation Risk Behavior	Production	Info
Detect Mimikatz With PowerShell Script Block Logging	Production	Medium
Attacker Tools On Endpoint	Production	Medium
Enable WDigest UseLogonCredential Registry	Testing	Medium
Windows Remote Access Software BRC4 Loaded DLL	Production	Medium
Windows LAPS Password Gathering Via PowerShell Script	Production	Medium
PowerShell 4104 Hunting	Production	Info
Potential LSASS Memory Dump via PssCaptureSnapshot	Production	High
Suspicious LSASS Access via MalSecLogon	Draft	High

شکل ۲۳ – جزئیات تکنیک T1003 و زیرتکنیک‌های آن

زیر فهرست قوانین، اطلاعات دفاعی و تهدیدی همان تکنیک آمده است:

- **ATT&CK mitigations:** کنترل‌های پیشگیرانه‌ای که MITRE برای این تکنیک پیشنهاد می‌کند، مثل Credential Access Protection. ماوس را روی هر مورد نگه دارید تا توضیحش را ببینید؛ با کلیک، صفحه‌ی آن در سایت MITRE باز می‌شود.
- **D3FEND countermeasures:** اقدامات دفاعی D3FEND، دسته‌بندی‌شده بر اساس تاکتیک دفاعی (Harden، Detect، Isolate و ...). این بخش هنگام باز کردن تکنیک از d3fend.mitre.org خوانده و ذخیره می‌شود. اگر سرور به اینترنت دسترسی نداشته باشد، به جای فهرست، لینک صفحه‌ی D3FEND آن تکنیک نمایش داده می‌شود.
- **Threat groups using it و Malware & tools using it:** گروه‌های مهاجم و بدافزارها و ابزارهایی که طبق ATT&CK از این تکنیک استفاده کرده‌اند. با کلیک روی هر کدام، صفحه‌ی پوشش آن باز می‌شود (فصل ۹).



شکل ۲۴ – کاهش‌دهنده‌ها، اقدامات D3FEND و گروه‌هایی که از T1003 استفاده می‌کنند

پایین همین بخش، **Atomic Red Team tests** تست‌های آماده‌ی آن تکنیک و زیرتکنیک‌هایش را فهرست می‌کند. کنار هر تست تعداد قوانینی آمده که تله‌متری آن تست را می‌بینند؛ **no rule sees it** یعنی هیچ قانونی رویدادهای آن تست را نمی‌خواند. کنار قوانین هم نشان اعتبارسنجی‌شان نمایش داده می‌شود.

Privileged Account Management M1026 · via T1003, T1003.001, T1003.002, T1003.003, T1003.004, T1003.005, T1003.006, T1003.007, T1003.008

Password Policies M1027 · via T1003, T1003.001, T1003.002, T1003.003, T1003.004, T1003.005, T1003.006, T1003.007, T1003.008

Operating System Configuration M1028 · via T1003, T1003.001, T1003.002, T1003.005

Behavior Prevention on Endpoint M1040 · via T1003, T1003.001

Encrypt Sensitive Information M1041 · via T1003, T1003.003

Credential Access Protection M1043 · via T1003, T1003.001

⊕ **THREAT GROUPS USING IT (58)**

Agrius APT1 APT28 APT29 APT3 APT32 APT33 APT39 APT41

APT5 Aquatic Panda Axiom BlackByte Blue Mockingbird

BRONZE BUTLER Chimera Cleaver Daggerfly Dragonfly Earth Lusca

Ember Bear FIN13 FIN6 FIN8 +34 more

MALWARE & TOOLS USING IT (51)

AADInternals Bad Rabbit Cachedump Carbanak Cobalt Strike

CosmicDuke CozyCar CrackMapExec Daserf Emotet Empire

esentuti Fgdump GreyEnergy gsecdump HOMEFRY HOPLIGHT

IceApple Impacket Koadic LaZagne Lizar Lslsass Mafalda

+27 more

ATOMIC RED TEAM TESTS (54, 49 SEEN BY A RULE)

Gsecdump Windows 2 Sees its telemetry

Credential Dumping with NPPSpy Windows 6 Sees its telemetry

Dump svchost.exe to gather RDP credentials Windows 7 Sees its telemetry

Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using list) Windows 5 Sees its telemetry

Retrieve Microsoft IIS Service Account Credentials Using AppCmd (using config) Windows 5 Sees its telemetry

Dump Credential Manager using keymgr.dll and rundll32.exe Windows 7 Sees its telemetry

Send NTLM Hash with RPC Test Connection Windows 5 Sees its telemetry

T1003.001 Dump LSASS.exe Memory using ProcDump Windows 26 Sees its telemetry

+46 more Open in Atomic Red Team

SUB-TECHNIQUES (7 / 8 COVERED)

T1003.001 LSASS Memory

Creation of lsass Dump with Taskmgr Testing Medium

Windows Possible Credential Dumping Testing Medium Validated

Create Remote Thread into LSASS Production Medium

Dump LSASS via comsvcs DLL Production Medium Validated

Dump LSASS via procDump Draft Medium Validated

T1003.002 Security Account Manager

Windows Sensitive Registry Hive Dump Via CommandLine Draft

Medium

Windows Rapid Authentication On Multiple Hosts Testing Medium

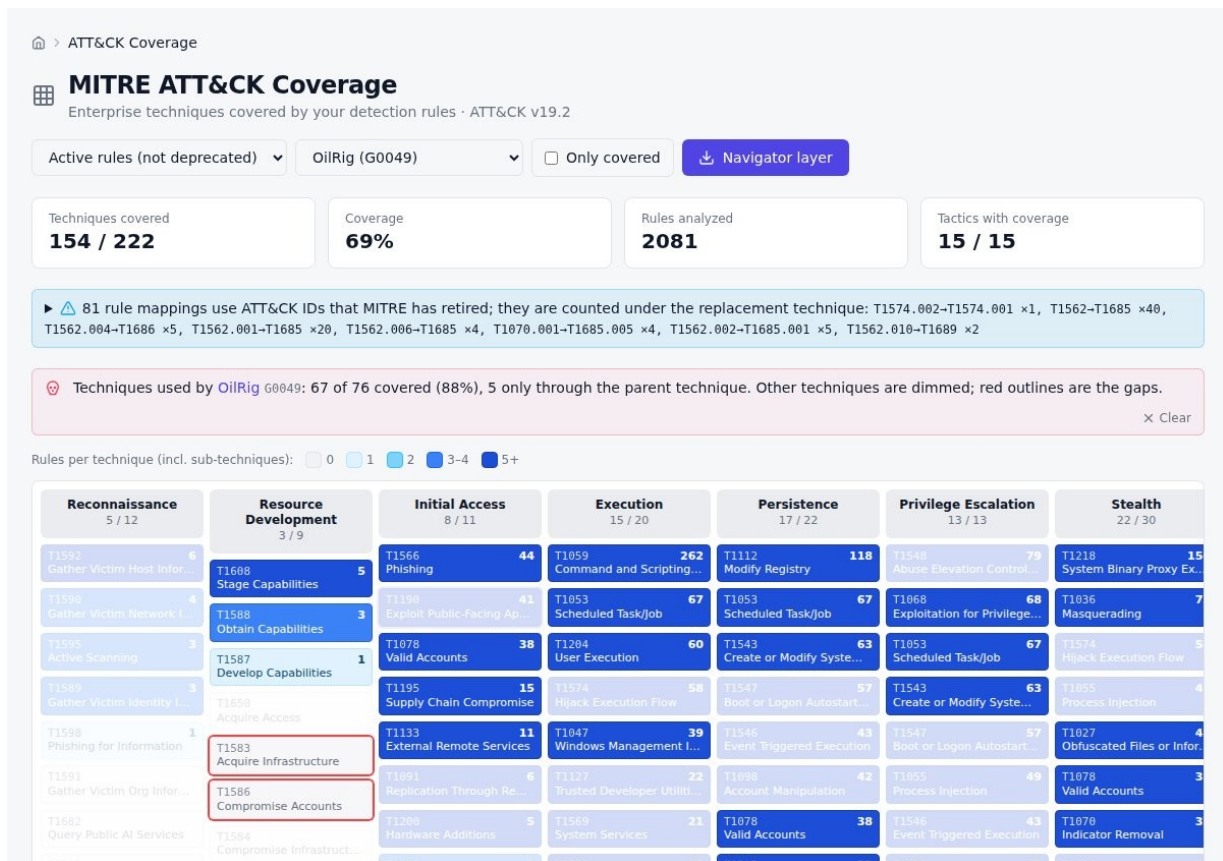
SAM Database File Access Attempt Draft Info

Esentuti SAM Copy Draft Info

شکل ۲۵ – تست‌های Atomic Red Team تکنیک T1003 و قوانین زیرتکنیک‌ها با نشان Validated

نمایش تکنیک‌های یک گروه مهاجم روی ماتریس

از منوی **Highlight a threat group...** بالای صفحه یک گروه را انتخاب کنید (یا از صفحه‌ی گروه، **In the ATT&CK matrix** را بزنید). تکنیک‌هایی که آن گروه استفاده می‌کند روشن می‌مانند و بقیه کمرنگ می‌شوند. تکنیک‌های آن گروه که هیچ قانونی ندارند **کادر قرمز** می‌گیرند؛ این‌ها شکاف‌های شما در برابر همان گروه‌اند. کادر بالای ماتریس درصد پوشش را نشان می‌دهد و **Clear** حالت عادی را برمی‌گرداند.



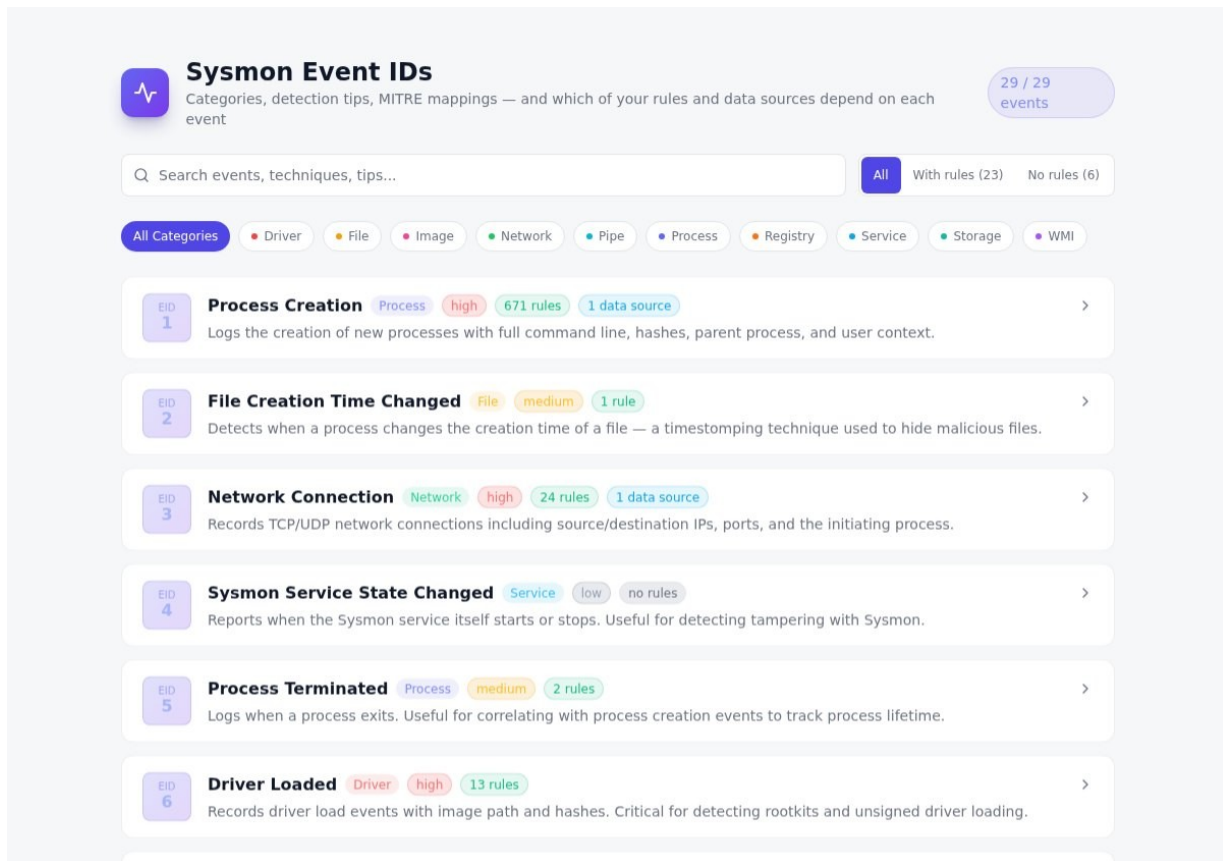
شکل ۲۶ – تکنیک‌های گروه OilRig (APT34) روی ماتریس پوشش

نکته

MITRE گاهی شناسه‌ی تکنیک‌ها را بازنشسته و با شناسه‌ی دیگری جایگزین می‌کند. اگر قوانین شما از شناسه‌ی بازنشسته استفاده کنند، کادر آبی بالای ماتریس آن‌ها را نشان می‌دهد. سامانه این قوانین را زیر شناسه‌ی جایگزین حساب می‌کند، ولی بهتر است نداشت قانون را اصلاح کنید.

فصل ۶ – رویدادهای Sysmon

صفحه‌ی **Sysmon Events** مرجع همه‌ی رویدادهای Sysmon است. کنار هر رویداد، قوانین و منابع داده‌ای که به آن وابسته‌اند نمایش داده می‌شود.



شکل ۲۷ – فهرست رویدادهای Sysmon

- هر کارت: شماره‌ی رویداد (EID)، نام، دسته، ارزش تشخیصی (high، medium، low) و تعداد قوانین و منابع داده‌ی وابسته.
 - جست‌وجو در نام، توضیح، تکنیک‌ها و نکته‌ها. فیلتر دسته‌ها (Process، Network، Registry و ...).
 - **With rules** و **No rules**: رویدادهای دارای قانون و بدون قانون.
- با کلیک روی هر کارت، جزئیات آن باز می‌شود: فهرست قوانین وابسته (با وضعیت و شدت)، منابع داده، فیلدهای کلیدی، نکته‌های تشخیص و تکنیک‌های مرتبط. اگر قوانین زیاد باشند، اول ۵۰ قانون نمایش داده می‌شود و **Show all** بقیه را نشان می‌دهد.

EID 10

Process Access

Process

high

44 rules

1 data source

Logs when one process opens a handle to another — key indicator for credential dumping (LSASS access).

DETECTION RULES USING THIS EVENT (44)

Access LSASS Memory for Dump Creation	Draft	Medium	auto
CMSTP Execution Process Access	Production	High	auto
Credential Dumping Activity By Python Based Tool	Draft	High	auto
Credential Dumping Attempt Via Svchost	Draft	High	auto
Credential Dumping Attempt Via WerFault	Production	High	auto
Detect Credential Dumping through LSASS access	Testing	Medium	auto
Function Call From Undocumented COM Interface EditionUpgradeManager	Deprecated	Medium	auto
HackTool - CobaltStrike BOF Injection Pattern	Testing	High	auto
HackTool - Generic Process Access	Production	High	auto
HackTool - HandleKatz Duplicating LSASS Handle	Draft	High	auto
HackTool - LittleCorporal Generated Maldoc Injection	Draft	High	auto
HackTool - SysmonEnte Execution	Production	High	auto
LSASS Access From Potentially White-Listed Processes	Production	High	auto
LSASS Memory Access by Tool With Dump Keyword In Name	Production	High	auto
Lsass Memory Dump via Comsvcs DLL	Testing	High	auto
Potential Credential Access via DuplicateHandle in LSASS	Draft	Medium	auto
Potential Credential Access via LSASS Memory Dump	Testing	High	auto
Potential Credential Dumping Activity Via LSASS	Testing	Medium	auto
Potential Direct Syscall of NtOpenProcess	Draft	Medium	auto
Potential LSASS Memory Dump via PssCaptureSnapShot	Production	High	auto
Potentially Suspicious GrantedAccess Flags On LSASS	Production	Medium	auto
Remote LSASS Process Access Through Windows Remote Management	Production	High	auto
Rubeus Kerberos Ticket Exports Through Winlogon Access	Draft	Medium	auto
Spoolsv Suspicious Process Access	Production	Medium	auto
Suspicious LSASS Access via MalSecLogon	Draft	High	auto
Suspicious LSASS Access Via MalSecLogon	Draft	High	auto
Suspicious Lsass Process Access	Draft	Medium	auto
Suspicious Process Access of MsMpEng by WerFaultSecure - EDR-Freeze	Production	High	auto
Suspicious Process Access to LSASS with Dbgcore/Dbghelp DLLs	Draft	High	auto
Suspicious Process Access via Direct System Call	Testing	High	auto
Suspicious Process Creation CallTrace	Draft	Medium	auto

شکل ۲۸ — جزئیات رویداد 10 (Process Access) و قوانین وابسته

برچسب **auto** کنار یک قانون یعنی سامانه وابستگی را خودکار از کوئری تشخیص داده است. وابستگی دستی از فرم ویرایش قانون تعیین می‌شود (فصل ۳).

فصل ۷ – منابع لاگ

بسیاری از قوانین به داده‌ای غیر از Sysmon تکیه دارند: لاگ Security ویندوز، PowerShell، Sysmon for Linux، auditd، رویدادهای (CrowdStrike، Microsoft Defender XDR، Elastic Defend، SentinelOne) EDR و لاگ‌های ابری. صفحه‌ی **Log Sources** همه‌ی این منابع و رویدادهایشان را نشان می‌دهد و مشخص می‌کند هر قانون کدام را می‌خواند.

The screenshot shows the 'Log Sources' page in DetectKB. On the left, a sidebar lists log sources under 'WINDOWS' and 'LINUX'. Under 'WINDOWS', 'Windows Security' is highlighted with 898 events. The main panel shows 'Windows Security' with 898 rules and 69 events. A table lists events with their corresponding rules and data sources.

Event	Rules	Data sources
Any event (product-level)	166	
4688 · Process creation	516	
5136 · Directory service object modified	38	
4663 · Attempt to access an object	25	
4624 · Successful logon	22	
5145 · Network share object checked for access	15	
4625 · Failed logon	13	
4698 · Scheduled task created	12	
4768 · Kerberos TGT requested	12	
4662 · Operation performed on an object	11	
4769 · Kerberos service ticket requested	10	
5137 · Directory service object created	9	
4738 · User account changed	8	
4720 · User account created	6	
4728 · Member added to security-enabled global group	6	

شکل ۲۹ – منبع Windows Security و قوانینی که رویداد 4688 را می‌خواند

- **ستون چپ:** منابع لاگ، دسته‌بندی‌شده بر اساس سکو (Windows، Linux، EDR، Identity، Cloud و ...). عدد کنار هر منبع تعداد قوانینی است که از آن استفاده می‌کنند.
- **جدول رویدادها:** رویدادهای منبع انتخاب‌شده با تعداد قوانین و صفحه‌های منبع داده. ردیف **Any event** (product-level) قوانینی است که فقط نام محصول را آورده‌اند، نه رویداد مشخص؛ مثلاً قوانین Elastic که می‌گویند «Elastic Defend».
- با کلیک روی یک رویداد، قوانینی که آن را می‌خوانند زیر جدول نمایش داده می‌شوند.
- **Rules یا In the rule list:** فهرست قوانین را با همین منبع یا رویداد فیلتر می‌کند.
- **What if we lose it?:** تحلیل اثر قطع همین منبع یا رویداد را در گراف باز می‌کند (فصل ۱۱).
- منبع **Sysmon** صفحه‌ی مرجع جداگانه‌ی خودش را دارد (فصل ۶).

منبع لاگ هر قانون از کجا می‌آید؟

سامانه منبع لاگ را از خود قوانین استخراج می‌کند و بعد از ذخیره یا ورود هر قانون به‌روز می‌کند:

منبع قانون	از کجا خوانده می‌شود
Splunk ESCU	فهرست <code>data_source</code> فایل اصلی، مثل «Windows Event Log Security 4688» یا «CrowdStrike ProcessRollup2».
Elastic	تگ‌های «Data Source»: مثل Elastic Defend؛ اگر کوئری روی <code>event.code</code> لاگ Security فیلتر کند، همان رویدادها.
Microsoft Sentinel	جدول‌هایی که قانون می‌خواند (مثل DeviceProcessEvents) و شماره‌ی <code>EventID</code> در کوئری <code>SecurityEvent</code> .
Sigma	بخش <code>logsource</code> ؛ مثلاً <code>process_creation</code> ویندوز علاوه بر <code>Sysmon 1</code> ، رویداد Security 4688 را هم دارد.
قوانین دستی	فیلد Data source قانون و شماره‌ی رویدادهای Security در کوئری.

نکته

برای اینکه قانونی که خودتان نوشته‌اید به منبع درست وصل شود، نام آن را در فیلد **Data source** قانون به همان شکل ESCU بنویسید؛ مثلاً `Windows Event Log Security 4624, Powershell Script Block Logging 4104`.

روی صفحه‌ی هر قانون، زیر رویدادهای `Sysmon`، نوار **Log events** منابع لاگ آن قانون را نشان می‌دهد.

منشأ هر ارتباط

کنار هر ارتباط برچسبی نشان می‌دهد این ارتباط از کجا آمده و چقدر قابل اعتماد است:

برچسب	معنی
official	از داده‌ی رسمی MITRE ATT&CK؛ مثل تکنیک‌های یک گروه یا کاهش‌دهنده‌ها.
declared (بدون برچسب)	خود قانون آن را نام برده است: فیلد منبع داده، جدول‌های <code>logsource</code> ، <code>Sentinel</code> یا فیلد <code>ATT&CK</code> قانون.
manual	کاربر آن را دستی ثبت کرده است.
inferred	سامانه آن را استنتاج کرده، مثلاً از فیلتر <code>EventID</code> در کوئری یا نگاشت دسته‌ی <code>Sigma</code> ؛ خود قانون آن را نام نبرده است. کادر خط‌چین دارد.

معنی	برچسب
نام ابزار مهاجم در متن قانون پیدا شده است؛ ممکن است قانون واقعاً آن را تشخیص ندهد. کادر خط چین دارد.	text match

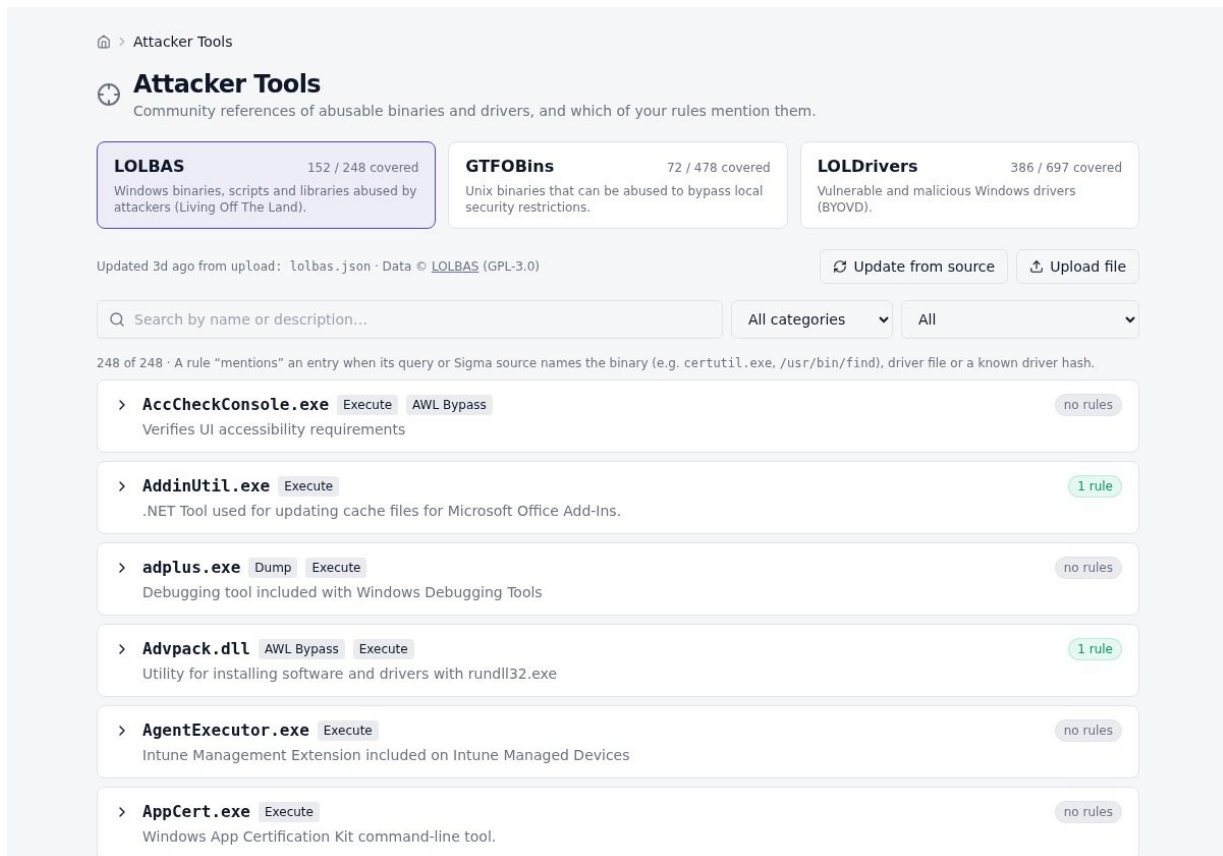
نکته

اگر قانونی به چند رویداد با هم نیاز دارد (در ESCU با «AND»، مثلاً «Sysmon EventID 1 AND Sysmon EventID 11»)، سامانه این شرط را نگه می‌دارد. در تحلیل اثر، قطع هر کدام از آن رویدادها قانون را از کار انداخته حساب می‌کند.

فصل ۸ – ابزارهای مهاجم

صفحه‌ی **Attacker Tools** سه مرجع شناخته‌شده را نشان می‌دهد:

- **LOLBAS**: فایل‌ها، اسکریپت‌ها و کتابخانه‌های ویندوز که مهاجم از آن‌ها سوءاستفاده می‌کند.
- **GTFOBins**: فایل‌های یونیکس که برای دور زدن محدودیت‌ها استفاده می‌شوند.
- **LOLDrivers**: درایورهای آسیب‌پذیر یا مخرب ویندوز.



شکل ۳۰ – فهرست ابزارهای LOLBAS

- **کارت‌های بالا:** با کلیک روی هر کارت، مرجع مربوط انتخاب می‌شود. عدد کارت نشان می‌دهد چند ابزار دست‌کم یک قانون دارند.
- **جست‌وجو و فیلترها:** جست‌وجو در نام و توضیح، فیلتر دسته (مثل Execute یا Download) و فیلتر دارای قانون یا بدون قانون.
- کنار هر ابزار تعداد قوانینی که به آن اشاره کرده‌اند نمایش داده می‌شود. **no rules** یعنی هیچ قانونی آن را پوشش نمی‌دهد.
- با کلیک روی هر ابزار، جزئیات آن باز می‌شود: کاربردهای سوءاستفاده، دستور نمونه، تکنیک‌های ATT&CK، منابع و فهرست قوانینی که به آن اشاره دارند.

▼ **Certutil.exe** Download ADS Encode Decode 30 rules
Windows binary used for handling certificates

DETECTION RULES MENTIONING IT (30)

WinRAR Spawning Shell Application	Draft	Medium
Windows Suspicious React or Next.js Child Process	Draft	Medium
WinRM Spawning a Process	Production	Medium
Wscript Or Cscript Suspicious Child Process	Draft	Medium
Certutil exe certificate extraction	Testing	Medium
Windows Office Product Spawned Uncommon Process	Draft	Medium
Windows Suspicious Child Process Spawned From WebServer	Production	Medium
Windows Suspicious VMWare Tools Child Process	Draft	Medium
Windows SCCM Smeexec Spawned a Suspicious Child Process	Testing	Medium
LOLBAS Network Connection On Uncommon Port	Production	Medium
Cisco NVM - Suspicious Download From File Sharing Website	Draft	Medium
Suspicious PDF Reader Child Process	Production	Low
Creation or Modification of Root Certificate	Production	Low
Execution via MSSQL xp_cmdshell Stored Procedure	Testing	Medium
Process Created with a Duplicated Token	Testing	Medium
Suspicious Child Process via Azure VM CustomScript Extension	Draft	Medium
Potential Execution via FileFix Phishing Attack	Draft	High
Delayed Execution via Ping	Production	Low
Suspicious Child Process of PaperCut Server Component	Draft	High
Suspicious JetBrains TeamCity Child Process	Testing	Medium
MsiExec Service Child Process With Network Connection	Deprecated	Medium
Potential IIS Web Shell File Creation	Production	High
Suspicious MS Office Child Process	Testing	Medium
Suspicious Microsoft HTML Application Child Process	Draft	High
Command Obfuscation via Unicode Modifier Letters	Production	High
Suspicious MS Outlook Child Process	Testing	Low
Suspicious Execution from a Mounted Device	Production	Medium
Suspicious CertUtil Commands	Draft	Medium
Suspicious ScreenConnect Client Child Process	Production	Medium
WMI Spawning Suspicious Child Process (Living off the Land)	Testing	High

شکل ۳۱ – جزئیات و قوانینی که به آن اشاره دارند

بهروزرسانی داده‌ها (مدیر)

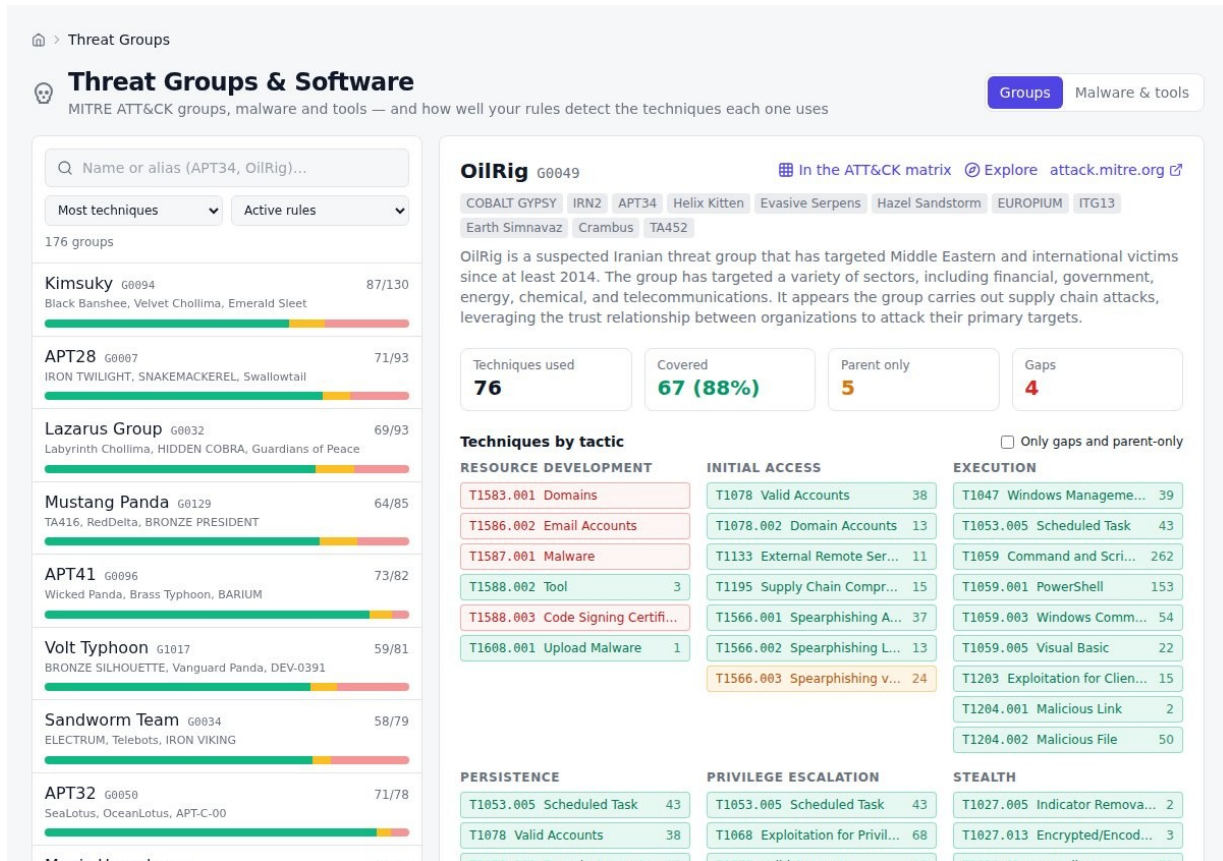
- **Update from source:** دانلود آخرین نسخه از سایت رسمی هر مرجع. سرور باید به اینترنت دسترسی داشته باشد.

- **Upload file:** برای سرورهای بدون اینترنت. فایل JSON رسمی مرجع را روی سیستم دیگری دانلود و این‌جا بارگذاری کنید.

سامانه با مقایسه‌ی کوئری و منبع Sigma هر قانون با نام ابزارها، خودکار پیدا می‌کند کدام قانون به کدام ابزار اشاره دارد. این اطلاعات بعد از هر تغییر خودکار به‌روز می‌شود.

فصل ۹ – گروه‌های تهدید و بدافزارها

صفحه **Threat Groups** گروه‌های مهاجم شناخته‌شده (مثل APT34/OilRig یا APT29)، بدافزارها و ابزارهای مهاجم را از پایگاه MITRE ATT&CK نشان می‌دهد و برای هر کدام مشخص می‌کند قوانین شما چه سهمی از تکنیک‌هایش را تشخیص می‌دهند. این همان سؤال همیشگی است: «در برابر فلان گروه چقدر آماده‌ایم؟»



شکل ۳۲ – پوشش تکنیک‌های گروه OilRig

- **تب‌ها: Groups** برای گروه‌های مهاجم و **Malware & tools** برای بدافزارها و ابزارها.
- **فهرست سمت چپ:** جست‌وجو در نام و نام‌های دیگر (مثلاً APT34 گروه OilRig را پیدا می‌کند). مرتب‌سازی بر اساس بیشترین تکنیک، بیشترین شکاف، بهترین پوشش یا نام. عدد کنار هر مورد یعنی «تکنیک‌های پوشش‌داده‌شده / کل تکنیک‌ها».
- **نوار رنگی:** سبز یعنی پوشش‌داده‌شده، زرد یعنی فقط قانون روی تکنیک والد وجود دارد، قرمز یعنی شکاف.
- **فیلتر وضعیت:** پوشش با قوانین فعال، فقط Production، یا Production + testing حساب شود.

جزئیات یک گروه

- **کارت‌ها:** تعداد تکنیک‌های گروه، تعداد و درصد پوشش‌داده‌شده، تعداد **Parent only** و تعداد شکاف‌ها.

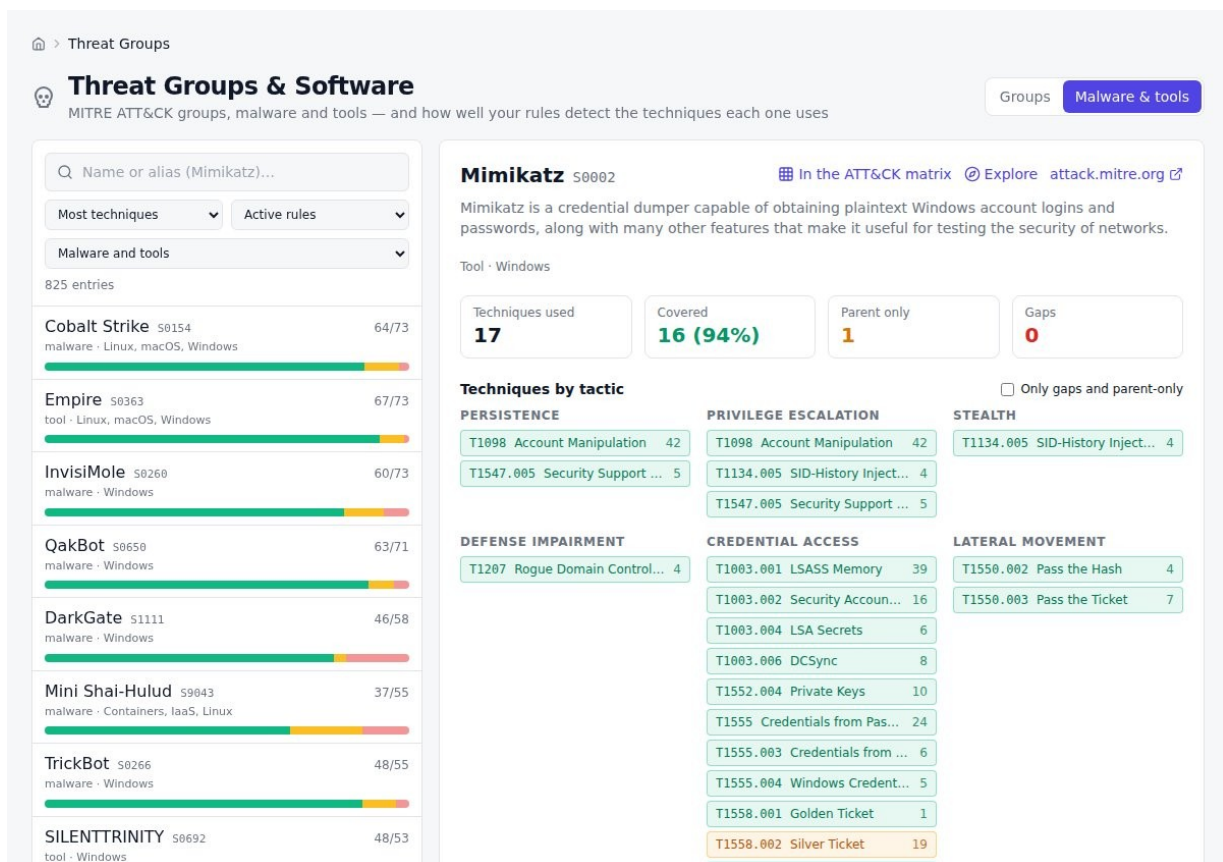
- **Techniques by tactic**: تکنیک‌های گروه، دسته‌بندی‌شده بر اساس تاکتیک، با همان رنگ‌بندی. با کلیک روی هر تکنیک، زنجیره‌ی تشخیص آن باز می‌شود. گزینه‌ی **Only gaps and parent-only** فقط کمبودها را نشان می‌دهد.
- **Malware and tools it uses**: بدافزارها و ابزارهای گروه با پوشش هر کدام.
- **In the ATT&CK matrix**: تکنیک‌های گروه را روی ماتریس پوشش نشان می‌دهد (فصل ۵). **Explore** گروه را در گراف دانش باز می‌کند.

نکته

Parent only یعنی گروه از یک زیرتکنیک استفاده می‌کند (مثلاً T1003.001) ولی قوانین شما فقط به تکنیک والد (T1003) نگاشت شده‌اند. چنین قانونی ممکن است آن زیرتکنیک را تشخیص بدهد یا ندهد؛ بررسی کنید.

بدافزارها و ابزارها

در تب **Malware & tools** همین اطلاعات برای هر بدافزار یا ابزار نمایش داده می‌شود، به‌علاوه‌ی نوع، سکوها و گروه‌هایی که از آن استفاده کرده‌اند. فیلتر نوع، بدافزارها را از ابزارها جدا می‌کند.



شکل ۳۳ – پوشش تکنیک‌های Mimikatz

این داده‌ها همراه سامانه نصب می‌شوند و به اینترنت نیاز ندارند. با به‌روزرسانی داده‌ی ATT&CK، گروه‌ها و بدافزارها هم به‌روز می‌شوند.

فصل ۱۰ – سناریوهای تحلیلی Splunk

Splunk قوانین ESCU را در قالب **Analytic Story** دسته‌بندی می‌کند؛ هر سناریو یک حمله یا تهدید مشخص است، مثل Volt Typhoon یا Ransomware، و قوانینی که آن را تشخیص می‌دهند. صفحه‌ی **Analytic Stories** این سناریوها را نشان می‌دهد.

شکل ۳۴ – سناریوی Volt Typhoon با قوانین و تکنیک‌هایش

- **فهرست سمت چپ:** جست‌وجو و مرتب‌سازی بر اساس تعداد قوانین، تعداد قوانین Production یا نام. عدد کنار هر سناریو یعنی «قوانین Production / همه‌ی قوانین».
- **جزئیات:** توضیح سناریو و روایت کامل آن (**Show the narrative**)، نوار وضعیت قوانین، تکنیک‌های ATT&CK که قوانینش تشخیص می‌دهند و فهرست قوانین.
- تکنیکی که کادر خط‌چین قرمز دارد، فقط قوانین deprecated دارد.
- **In the rule list:** فهرست قوانین را با همین سناریو فیلتر می‌کند؛ مثلاً برای تغییر وضعیت گروهی قوانین یک سناریو.

سناریوها با ورود قوانین ESCU خودکار ساخته می‌شوند، چون هر قانون نام سناریوهایش را دارد. توضیح و روایت سناریوها از پوشه‌ی stories مخزن رسمی splunk/security_content می‌آید:

- **Download missing descriptions:** دانلود توضیح سناریوهایی که هنوز توضیح ندارند. سرور در اولین اجرا این کار را خودکار انجام می‌دهد.
 - **Upload story files:** برای سرورهای بدون اینترنت. فایل‌های YAML پوشه‌ی stories را روی سیستم دیگری دریافت و این‌جا بارگذاری کنید.
- روی صفحه‌ی هر قانون ESCU، نوار **Analytic stories** سناریوهای آن قانون را نشان می‌دهد.

فصل ۱۱ – Atomic Red Team و اعتبارسنجی در لب

اینکه قانونی به تکنیک T1003.001 نگاشت شده، یعنی **ادعا** می‌کند آن حمله را تشخیص می‌دهد. برای اینکه مطمئن شویم، باید حمله را در یک محیط آزمایشی (لب) واقعاً انجام دهیم و ببینیم Splunk هشدار می‌دهد یا نه. **Atomic Red Team** مجموعه‌ای از تست‌های کوچک و آماده‌ی حمله برای هر تکنیک ATT&CK است و DetectKB برای هر قانون می‌گوید کدام تست‌ها را اجرا کنید و نتیجه را نگه می‌دارد.

توجه

DetectKB خودش هیچ تستی اجرا نمی‌کند و به ماشین‌های لب وصل نمی‌شود. تست‌ها را خودتان روی ماشین قربانی در لب اجرا می‌کنید. تست‌ها حمله‌ی واقعی‌اند. فقط روی ماشین‌های ایزوله‌ی لب اجرا شوند، هرگز روی سیستم‌های عملیاتی. راه‌اندازی لب در سند جداگانه‌ی [docs/lab-setup](https://docs/atomic-red-team/lab-setup) آمده است.

روند کار

1. در DetectKB قانون (یا تکنیک) را باز کنید و تستی را که باید قانون را فعال کند پیدا کنید.
2. دستور آماده‌ی تست را کپی کنید و روی ماشین قربانی در لب اجرا کنید.
3. چند دقیقه بعد در Splunk لب ببینید قانون هشدار داده یا نه.
4. نتیجه را در DetectKB ثبت کنید. وضعیت قانون خودکار به‌روز می‌شود.

صفحه‌ی Atomic Red Team

صفحه‌ی **Atomic Red Team** در نوار کناری همه‌ی تست‌ها را نشان می‌دهد (حدود ۱۹۰۰ تست برای بیش از ۳۰۰ تکنیک). سمت چپ فهرست تست‌ها با جست‌وجو و فیلتر است و سمت راست جزئیات تست انتخاب‌شده.

Atomic Red Team

Small attack tests per ATT&CK technique, the telemetry each should produce, and the rules it should trigger

Export rules for Splunk Update from GitHub Upload files

1,878 tests for 344 techniques · updated 13h ago

Search tests, technique IDs or GUIDs...

All platforms Any executor Any rules

1,878 tests

T1001.002 Steganographic Tarball Embedding
Windows · PowerShell 2 Sees its telemetry

T1001.002 Embedded Script in Image Execution...
Windows · PowerShell 2 Sees its telemetry

T1001.002 Execute Embedded Script in Image vi...
Linux · sh 2 rules, none see it

T1003 Gsecdump
Windows · cmd 2 Sees its telemetry

T1003 Credential Dumping with NPPSpy
Windows · PowerShell 6 Sees its telemetry

T1003 Dump svchost.exe to gather RDP creden...
Windows · PowerShell 7 Sees its telemetry

T1003 Retrieve Microsoft IIS Service Account Cr...
Windows · PowerShell 5 Sees its telemetry

T1003 Retrieve Microsoft IIS Service Account Cr...

Dump LSASS.exe Memory using comsvcs.dll

On GitHub

T1003.001 LSASS Memory · test #2

Windows PowerShell Needs admin

The memory of lsass.exe is often dumped for offline credential theft attacks. This can be achieved with a built-in dll.

Upon successful execution, you should see the following file created \$env:TEMP\lsass-comsvcs.dmp.

Run it in the lab with the Invoke-AtomicRedTeam PowerShell module · DetectKB never runs tests itself

Invoke-AtomicTest T1003.001 -TestGuids 2536dee2-12fb-459a-8c37-971844fa73be Copy

Add -GetPrereqs first to fetch its tools, and -Cleanup afterwards. Only on an isolated test machine.

python attack_range.py simulate -t <target> -a T1003.001:2536dee2-12fb-459a-8c37-971844fa73be Copy

Or with Splunk Attack Range (replace <target> with the victim's name in your range).

COMMAND Copy

```
C:\Windows\System32\rundll32.exe C:\Windows\System32\comsvcs.dll, MiniDump (Get-Process lsass).id $env:TEMP\lsass-comsvcs.dmp full
```

TELEMETRY IT SHOULD PRODUCE (5)

Sysmon 1 · Process Creation process creation inferred

Windows Security 4688 · Process creation process creation inferred

PowerShell 4104 · Script block loading PowerShell script block inferred

شکل ۳۵ – صفحه‌ی Atomic Red Team و جزئیات یک تست

- **فیلترها:** پلتفرم (Windows، Linux و ...)، نوع اجرا (PowerShell، cmd، sh، bash، Manual)، و وضعیت قوانین: **A rule sees its telemetry** (قانونی رویدادهای تست را می‌بیند)، **No rule sees its telemetry** و **No rule for the technique** (شکاف پوشش).
- **Run it in the lab:** خط آماده‌ی **Invoke-AtomicTest** برای اجرا با ماژول **Invoke-AtomicRedTeam**، و خط معادل برای **Splunk Attack Range**. دکمه‌ی **Copy** آن را کپی می‌کند. قبل از اجرا با **-GetPrereqs** ابزارهای تست را دریافت کنید و بعد از آن با **-Cleanup** پاک‌سازی کنید.
- **Command:** دستور حمله با مقادیر پیش‌فرض پرشده؛ **Show the #{placeholders}** نسخه‌ی خام را نشان می‌دهد. **Inputs، Prerequisites و Cleanup** هم زیر آن آمده‌اند.
- **Telemetry it should produce:** رویدادهایی که اجرای تست باید تولید کند، مثل **Sysmon 10** برای دسترسی به **lsass** یا **4104** برای **PowerShell**. این‌ها را سامانه از روی دستور حدس زده و برچسب **inferred** دارند.

قوانین هر تست

بخش **Rules for ...** قوانین همان تکنیک را در چهار دسته نشان می‌دهد:

Linux - sn
2 rules, none see it

T1003 Gsecdump

Windows - cmd

2 Sees its telemetry

T1003 Credential Dumping with NPPSpy

Windows - PowerShell

6 Sees its telemetry

T1003 Dump svchost.exe to gather RDP creden...

Windows - PowerShell

7 Sees its telemetry

T1003 Retrieve Microsoft IIS Service Account Cr...

Windows - PowerShell

5 Sees its telemetry

T1003 Retrieve Microsoft IIS Service Account Cr...

Windows - PowerShell

5 Sees its telemetry

T1003 Dump Credential Manager using keymgr...

Windows - PowerShell

7 Sees its telemetry

T1003 Send NTLM Hash with RPC Test Connection

python attack_range.py simulate -t <target> -a T1003.001:2536dee2-12fb-459a-8c3
Copy

Or with Splunk Attack Range (replace <target> with the victim's name in your range).

COMMAND

Copy

C:\Windows\System32\rundll32.exe C:\windows\System32\comsvcs.dll, MiniDump (Get-Process ls
ass).id \$env:TEMP\lsass-comsvcs.dmp full

TELEMETRY IT SHOULD PRODUCE (5)

Sysmon 1 - Process Creation

process creation

Inferred

Windows Security 4688 - Process creation

process creation

Inferred

PowerShell 4104 - Script block logging

PowerShell script block

Inferred

Sysmon 10 - Process Access

access to the lsass process

Inferred

Sysmon 7 - Image Loaded

DLL or assembly loaded

Inferred

Inferred from the platform, the executor and what the command does, assuming Sysmon, process-creation auditing and PowerShell script block logging are on.

RULES FOR T1003.001 (78)

31 Sees its telemetry

The rule reads telemetry this test is expected to produce, so it may fire. Only running the test proves it.

Access LSASS Memory for Dump Creation

Draft

sysmon:10

Attacker Tools On Endpoint

Production

tagged with the parent technique

sysmon:1, windows-security:4688

Credential Dumping Activity By Python Based Tool

Draft

sysmon:10

Credential Dumping Attempt Via WerFault

Production

sysmon:10

Detect Credential Dumping through LSASS access

Testing

sysmon:10

Detect Mimikatz With PowerShell Script Block Logging

Production

tagged with the parent technique

windows-powershell:4104

Dump LSASS via comsvcs DLL

Production

sysmon:1, windows-security:4688

Dump LSASS via procdump

Draft

sysmon:1, windows-security:4688

HackTool - Generic Process Access

Production

sysmon:10

HackTool - HandleKatz Duplicating LSASS Handle

Draft

sysmon:10

LSASS Access From Potentially White-Listed Processes

Production

sysmon:10

LSASS Memory Access by Tool With Dump Keyword In Name

Production

sysmon:10

+19 more

شکل ۳۶ — تله‌متری مورد انتظار و قوانین مرتبط با یک تست

دسته	معنی
Sees its telemetry	قانون رویدادی را می‌خواند که این تست تولید می‌کند؛ احتمالاً با این تست فعال می‌شود. فقط اجرای تست آن را ثابت می‌کند.
Needs the EDR	قانون به داده‌ی یک EDR (مثل CrowdStrike یا Defender XDR) وابسته است و فقط جایی کار می‌کند که آن محصول نصب باشد.
Other telemetry	هم‌تکنیک است، ولی رویدادی را می‌خواند که این تست تولید نمی‌کند.
No telemetry links	قانون هیچ منبع لاگ شناخته‌شده‌ای ندارد و سامانه نمی‌تواند قضاوت کند.

نکته

قانونی که روی تکنیک مادر (مثلاً T1003) تگ خورده، برای تست‌های زیرتکنیک‌ها (T1003.001) هم حساب می‌شود؛ برعکس آن نه.

ثبت نتیجه‌ی یک اجرا برای چند قانون

بعد از اجرای یک تست، معمولاً می‌خواهید نتیجه را برای همه‌ی قوانین مرتبط ثبت کنید. در جزئیات تست، بخش **Lab results** را پیدا کنید و **Record a run** را بزنید:

1. زمان اجرا (**Run at**)، محیط (مثلاً **Defender excluded** · **WIN-VICTIM**) و در صورت نیاز یادداشت را وارد کنید.
2. برای هر قانون نتیجه را انتخاب کنید. دکمه‌های **set all** کنار هر دسته، نتیجه‌ی همه‌ی قوانین آن دسته را یکجا تعیین می‌کنند. قانونی که روی «-» بماند ثبت نمی‌شود.
3. **Save results** را بزنید.

شکل ۳۷ – ثبت نتیجه‌ی یک اجرا برای قوانین مرتبط و تاریخچه‌ی اجراهای تست

زیر فرم، تاریخچه‌ی اجراهای همین تست با نتیجه‌ی هر قانون نمایش داده می‌شود.

نتیجه‌ها

نتیجه	کی انتخاب کنیم
Detected	قانون برای این اجرا هشدار داد.
Not detected	حمله اجرا شد و لاگش در Splunk هست، ولی قانون هشدار نداد.
Partly detected	قانون فقط بخشی از حمله را گرفت.
Blocked (did not run)	آنتی‌ویروس یا EDR جلوی اجرای تست را گرفت؛ قانون واقعاً آزموده نشد.
Test error	تست به درستی اجرا نشد (مثلاً پیش‌نیاز نداشت).

نکته

نتیجه‌های **Blocked** و **Test error** در تاریخچه می‌مانند ولی وضعیت قانون را تغییر نمی‌دهند، چون چیزی درباره‌ی خود قانون نمی‌گویند.

اعتبارسنجی در صفحه‌ی قانون

در صفحه‌ی هر قانون، بخش **Atomic Red Team** · **Lab validation** را باز کنید. بالای آن وضعیت قانون و توضیحش، سپس تاریخچه‌ی تست‌ها (زمان، تست، نتیجه، محیط و مدرک، ثبت‌کننده) و در پایان **Tests to run**، یعنی تست‌های پیشنهادی همین قانون با خط آماده‌ی اجرا آمده است.

The screenshot shows the 'Lab validation' section of a rule in DetectKB. The rule is titled 'LSASS Access From Potentially White-Listed Processes' and is a Sigma rule. It has a 'Validated' status and was updated 51m ago. The rule's source is 'product:windows' and its category is 'process_access'. The rule's content is displayed in a code block, showing a Sigma rule for detecting LSASS access from potentially white-listed processes. The 'TACTICS' section shows 'TA0006' and the 'TECHNIQUES' section shows 'T1003.001'. The 'FALSE POSITIVES' and 'REFERENCES' sections are empty. The 'LAB VALIDATION' section shows a 'Validated' status and a message: 'Its latest lab test detected the attack, with the current query, within the last 90 days.' Below this, there is a table with columns: 'When', 'Test', 'Result', 'Environment / evidence', and 'By'. The table contains one row: '10/1/2026, 7:40:00 AM', 'Dump LSASS.exe Memory using ProcDump', 'Detected', 'WIN-VICTIM · Defender excluded', and 'admin'. The 'TESTS TO RUN' section shows a message: 'Tests for T1003.001. "Sees its telemetry" means the rule reads an event the test should produce — run the test in a lab to prove the rule fires.' Below this, there is a code block with the command: 'Invoke-AtomicTest T1003.001 -TestGuids 0be2230c-9ab3-4ac2-8826-3199b9a0ebf8'.

شکل ۳۸ — نشان Validated در بالای قانون و بخش Lab validation

برای ثبت یک نتیجه فقط برای همین قانون، **Record a result** را بزنید. تست را از فهرست انتخاب کنید (تست‌هایی که قانون تله‌متری‌شان را می‌بیند با ✓ مشخص شده‌اند) یا **Another test** را برای تستی غیر از Atomic Red Team بزنید. در **Evidence** شناسه‌ی هشدار یا جستجوی Splunk را بنویسید تا بعداً قابل پیگیری باشد.

LAB VALIDATION - ATOMIC RED TEAM

Validated Its latest lab test detected the attack, with the current query, within the last 90 days.

Test
T1003.001#1 Dump LSASS.exe Memory using ProcDump ✓

Result
Detected

Run at
10/01/2026, 08:35 AM

Environment
e.g. WIN-VICTIM, Defender excluded

Evidence
Alert ID, search job, event count...

Notes

Save Cancel

When	Test	Result	Environment / evidence	By
10/1/2026, 7:40:00 AM	Dump LSASS.exe Memory using ProcDump	Detected	WIN-VICTIM · Defender excluded	admin

TESTS TO RUN

Tests for T1003.001. "Sees its telemetry" means the rule reads an event the test should produce — run the test in a lab to prove the rule fires.

Invoke-AtomicTest T1003.001 -TestGuids 0be2230c-9ab3-4ac2-8826-3199b9a0ebf8 Copy

T1003.001#1 Dump LSASS.exe Memory using ProcDump Windows · cmd Sees its telemetry sysmon:10

T1003.001#2 Dump LSASS.exe Memory using comsvcs.dll Windows · PowerShell Sees its telemetry sysmon:10

T1003.001#6 Offline Credential Theft With Mimikatz Windows · cmd Sees its telemetry sysmon:10

T1003.001#8 Dump LSASS.exe Memory using Out-Minidump.ps1 Windows · PowerShell Sees its telemetry sysmon:10

T1003.001#9 Create Mini Dump of LSASS.exe using ProcDump Windows · cmd Sees its telemetry sysmon:10

T1003.001#11 Dump LSASS with createdump.exe from .Net v5 Windows · PowerShell Sees its telemetry sysmon:10

T1003.001#12 Dump LSASS.exe using imported Microsoft DLLs Windows · PowerShell Sees its telemetry sysmon:10

T1003.001#13 Dump LSASS.exe using lolbin rdrleakdiag.exe Windows · PowerShell Sees its telemetry sysmon:10

+6 more

شکل ۳۹ — فرم ثبت نتیجه در صفحه‌ی قانون

وضعیت اعتبارسنجی قانون

وضعیت هر قانون از آخرین نتیجه‌ی معتبرش می‌آید:

وضعیت	یعنی
Validated	آخرین تست، حمله را تشخیص داد؛ با همین کوئری و در ۹۰ روز اخیر.
Partly validated	آخرین تست بخشی از حمله را تشخیص داد.
Failed in lab	آخرین تست حمله را تشخیص نداد.
Retest	کوئری قانون بعد از آخرین تست تغییر کرده، یا آخرین تست قدیمی‌تر از ۹۰ روز است. در تاریخچه، اجراهای قبل از تغییر کوئری با query changed since مشخص می‌شوند.
Not tested	هیچ نتیجه‌ای برای قانون ثبت نشده است.

نتیجه‌ی اشتباه را با آیکون سطل زباله کنار آن در تاریخچه حذف کنید. ثبت و حذف نتیجه به دسترسی ویرایش قانون (editor یا admin) نیاز دارد.

اگر قانون هشدار نداد

Not detected همیشه به این معنی نیست که قانون خراب است. قبل از اصلاح قانون، این‌ها را بررسی کنید:

علت احتمالی	چطور بفهمیم
حمله اصلاً اجرا نشد	خروجی تست روی ماشین قربانی. در این صورت نتیجه را Blocked یا Test error ثبت کنید.
لاگ تولید نشد (Audit یا Sysmon)	در Splunk در بازه‌ی زمان تست، <code>index=sysmon</code> یا <code>index=win</code> را جستجو کنید.
لاگ به Splunk نرسید	اگر همان جستجو خالی است، Forwarder یا index را بررسی کنید.
ماکرو یا فیلتر قانون	کوئری قانون را دستی و بدون فیلتر انتهایی اجرا کنید.
قانون برای نسخه‌ی دیگری از حمله است	دستور تست را با منطق قانون مقایسه کنید.

فقط وقتی لاگ حمله در Splunk هست ولی قانون آن را نمی‌گیرد، قانون واقعاً به بازبینی نیاز دارد.

خروجی قوانین برای Splunk لب

برای اینکه قوانین در Splunk لب اجرا شوند، باید آن‌ها را آن‌جا تعریف کنید. **Export rules for Splunk** در بالای صفحه‌ی Atomic Red Team یک فایل `savedsearches.conf` می‌سازد:

- **Rules:** قوانین Production، Production و testing، یا همه به‌جز deprecated.
- **Only:** فقط قوانین تکنیک‌هایی که تست Atomic دارند، یا همه‌ی قوانین.
- در جزئیات هر تست، **Export its ... rules for Splunk** فقط قوانینی را که تله‌متری همان تست را می‌بینند خروجی می‌دهد.

هر قانون در این فایل یک جستجوی ذخیره‌شده است که هر ۵ دقیقه روی ۱۵ دقیقه‌ی اخیر اجرا می‌شود و اگر نتیجه داشته باشد هشدار می‌دهد. فایل را در `$SPLUNK_HOME/etc/apps/<app>/local/` روی Splunk لب بگذارید و Splunk را دوباره راه‌اندازی کنید. فقط قوانینی که کوئری SPL دارند در خروجی می‌آیند. قوانین ESCU به اپ‌های ES Content Update و CIM روی Splunk لب نیاز دارند.

به‌روزرسانی تست‌ها (مدیر)

- **Download from GitHub / Update from GitHub:** دریافت فهرست تست‌ها از مخزن رسمی `redcanaryco/atomic-red-team`. سرور در اولین اجرا این کار را خودکار انجام می‌دهد.
- **Upload files:** برای سرور بدون اینترنت؛ فایل `atomics/Indexes/index.yaml` یا فایل‌های تکنیک (`atomics/T*/T*.yaml`) را بارگذاری کنید.

نکته

نتیجه‌های ثبت‌شده بخشی از پشتیبان JSON هستند و با بازگردانی برمی‌گردند.

فصل ۱۲ – گراف دانش

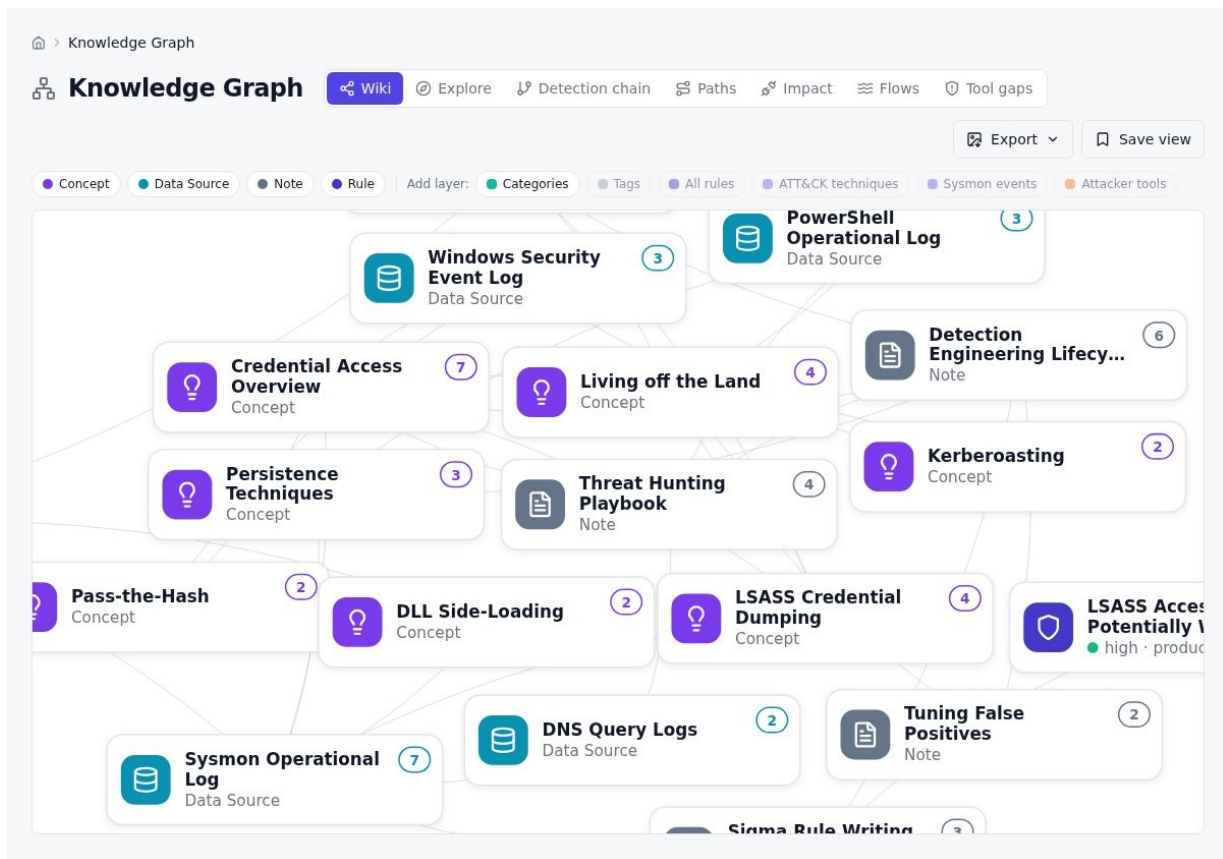
صفحه‌ی **Knowledge Graph** همه‌ی ارتباط‌ها را یک‌جا نشان می‌دهد: صفحه‌ها و لینک‌هایشان، قوانین، تکنیک‌ها، رویدادهای Sysmon و منابع لاگ دیگر، ابزارهای مهاجم، گروه‌های تهدید، بدافزارها، کاشش‌دهنده‌ها، سناریوهای تحلیلی، تگ‌ها و دسته‌ها. گراف هفت نما دارد که با تب‌های بالای صفحه انتخاب می‌شوند:

نما	کاربرد
Wiki	صفحه‌های دانش و لینک‌های بین آن‌ها.
Explore	شروع از یک گره و باز کردن قدم‌به‌قدم همسایه‌ها.
Detection chain	زنجیره‌ی یک تکنیک: تاکتیک ← تکنیک ← قوانین ← رویدادهای لاگ ← منابع داده.
Paths	کوتاه‌ترین مسیرهای ارتباطی بین دو گره.
Impact	اگر یک منبع لاگ، رویداد یا منبع داده قطع شود، چه چیزی از کار می‌افتد.
Flows	جریان تشخیص‌ها از منابع لاگ به تاکتیک‌های ATT&CK.
Tool gaps	ابزارهای مهاجم و تکنیک‌هایی که هیچ قانونی پوششان نمی‌دهد.

وضعیت هر نما در آدرس صفحه ذخیره می‌شود؛ می‌توانید آن را با **Save view** ذخیره کنید یا لینکش را بفرستید.

Wiki

صفحه‌های دانش و لینک‌های ویکی بینشان نمایش داده می‌شوند. هر رنگ یک نوع صفحه است. با چرخ ماوس بزرگ‌نمایی کنید و با کشیدن، گراف را جابه‌جا کنید. با کلیک روی هر گره، پنل جزئیات آن باز می‌شود. با دکمه‌های لایه‌ها می‌توانید قوانین، تکنیک‌ها، رویدادهای Sysmon و لاگ، ابزارها، سناریوهای تحلیلی، گروه‌های تهدید، بدافزارها، کاشش‌دهنده‌ها، تگ‌ها و دسته‌ها را هم به گراف اضافه کنید. لایه‌های بزرگ مثل بدافزارها گراف را شلوغ می‌کنند؛ برای آن‌ها نمای Explore مناسب‌تر است.

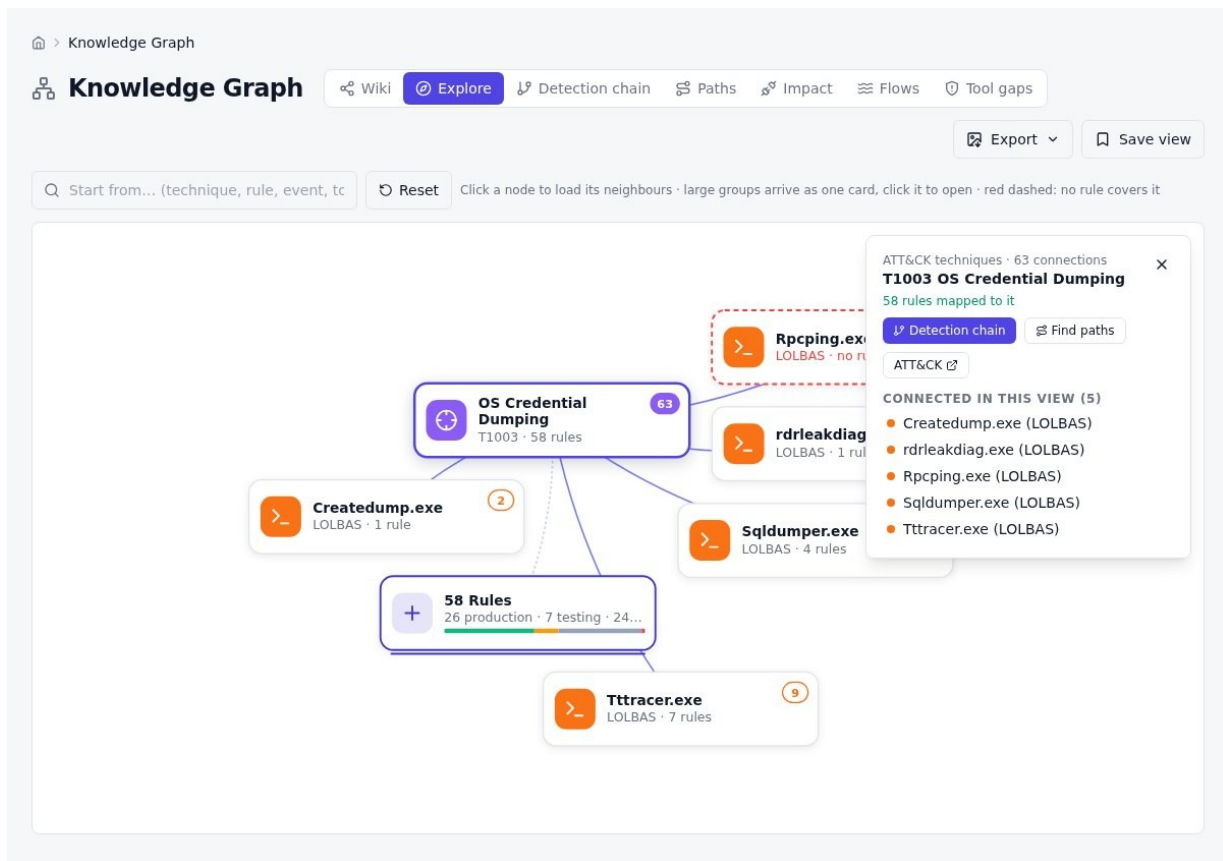


شکل ۴۰ - نمای Wiki

Explore

مناسب‌ترین نما برای کاوش. یک نقطه‌ی شروع انتخاب کنید: در جعبه‌ی **Start from**... جست‌وجو کنید یا یکی از گره‌های پیشنهادی را بزنید. سپس:

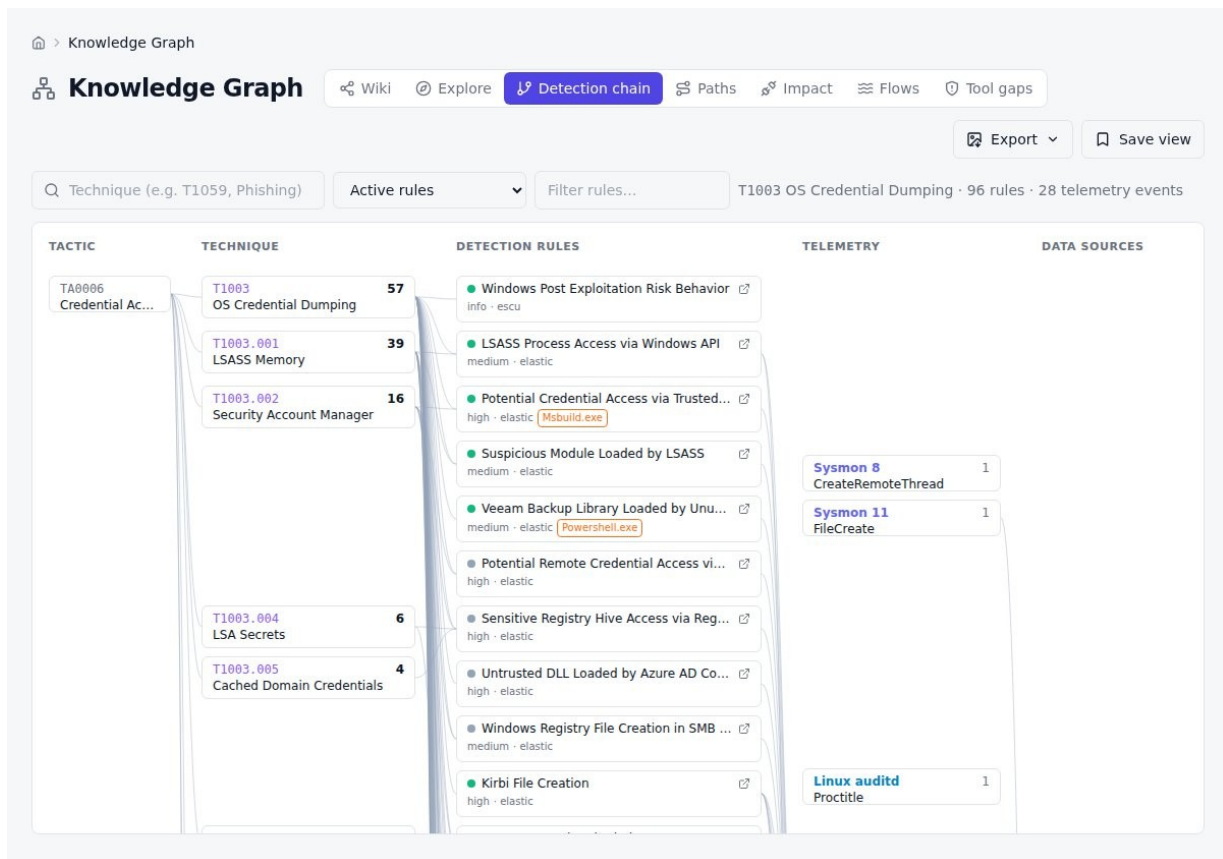
- با کلیک روی هر کارت، همسایه‌هایش بار می‌شوند. عدد گوشه‌ی کارت تعداد کل ارتباط‌های آن است.
- گروه‌های بزرگ، مثلاً ۵۸ قانون یک تکنیک، به شکل یک **کارت گروهی** با نوار وضعیت نمایش داده می‌شوند. با کلیک روی کارت، اعضا ۲۵ تا ۲۵ تا باز می‌شوند.
- کارت با **خط‌چین قرمز** و عبارت **no rules** یعنی ابزار یا تکنیکی که هیچ قانونی پوششش نمی‌دهد: یک شکاف تشخیص.
- در پنل کنار گراف: **Detection chain** زنجیره‌ی تکنیک، **Find paths** یافتن مسیر از این گره، **Start from here** شروع دوباره از این گره، و **Hide** پنهان کردن گره.
- **Reset** گراف را به نقطه‌ی شروع برمی‌گرداند.



شکل ۴۱ – نمای Explore حول تکنیک T1003

Detection chain

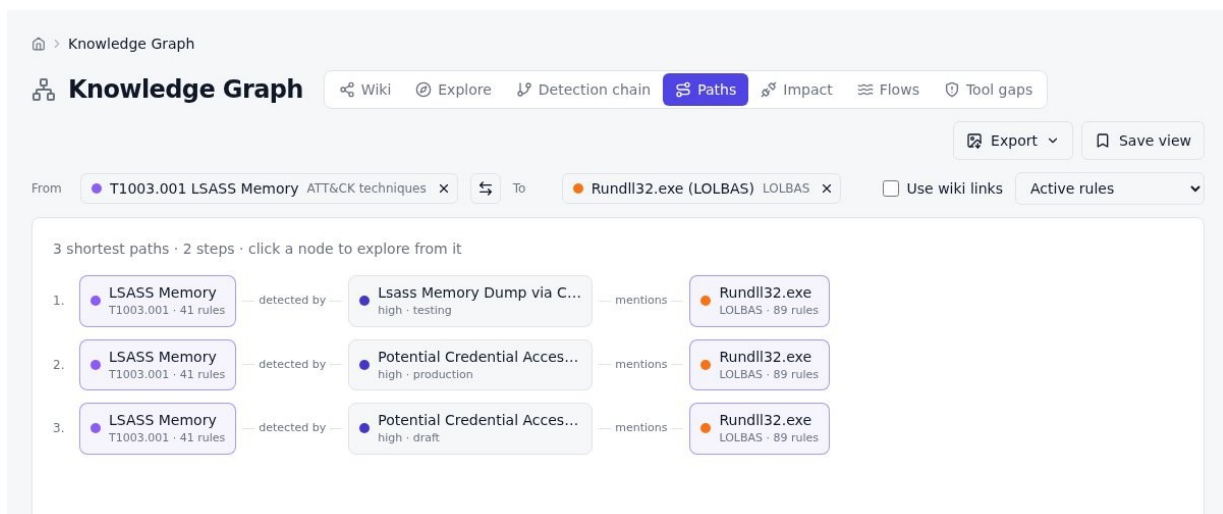
یک تکنیک را انتخاب کنید تا زنجیره‌ی کامل تشخیص آن در ستون‌ها نمایش داده شود: تاکتیک‌ها، تکنیک و زیرتکنیک‌ها، قوانین، رویدادهای لاگ (ستون **Telemetry**: Sysmon، Windows Security، EDR و ...) و منابع داده. ابزارهای مهاجمی که قوانین به آن‌ها اشاره دارند هم نشان داده می‌شوند. ماوس را روی هر مورد ببرید تا مسیر آن پررنگ شود؛ با کلیک، مسیر ثابت می‌ماند. فیلتر وضعیت و جست‌وجو در قوانین هم بالای صفحه است.



شکل ۴۲ - زنجیره‌ی تشخیص T1003

Paths

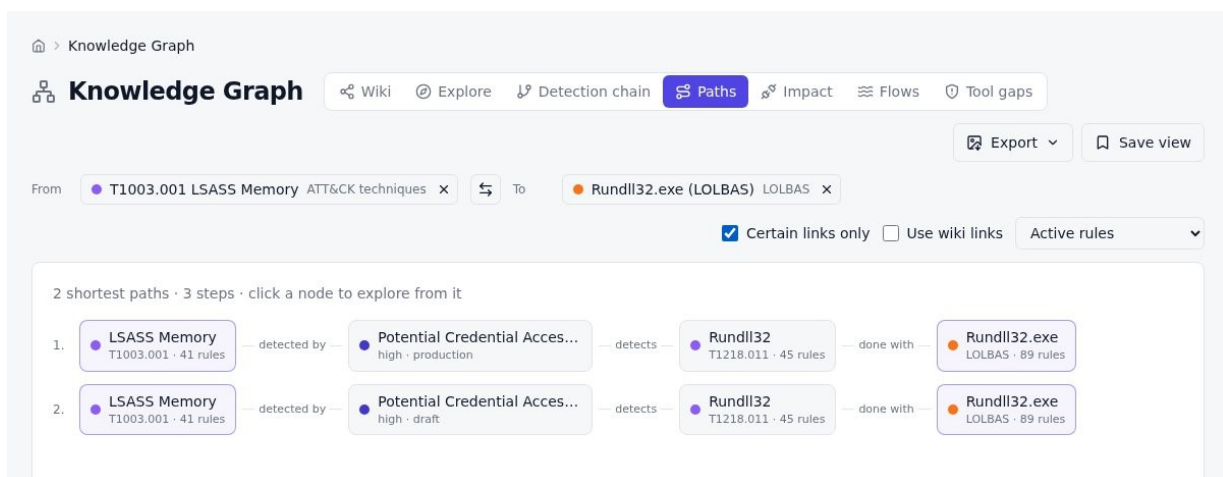
دو گره را در **From** و **To** انتخاب کنید. سامانه کوتاه‌ترین مسیرهای بینشان را نشان می‌دهد، مثلاً «این ابزار از طریق کدام قوانین به این تکنیک می‌رسد؟». روی هر قدم نوع رابطه نوشته شده است، مثل **detects** (قانون، تکنیک را تشخیص می‌دهد) یا **mentions** (قانون به ابزار اشاره می‌کند). با کلیک روی هر گره مسیر، نمای Explore از آن گره شروع می‌شود. دکمه‌ی **↶** مبدأ و مقصد را جابه‌جا می‌کند.



شکل ۴۳ - مسیرهای بین T1003.001 و rundll32.exe

مسیرها فقط از روابط مدل تشخیص می‌گذرند:

- ابزار – تکنیکی که برای آن به کار می‌رود (نگاشت LOLBAS و LOLDrivers)
 - قانون – تکنیکی که تشخیص می‌دهد، و ابزاری که در متنش آمده
 - قانون – رویداد Sysmon یا رویداد لاگ دیگر – منبع داده‌ای که آن رویداد را فراهم می‌کند
 - زیرتکنیک – تکنیک والد
 - گروه تهدید، بدافزار یا کاهش‌دهنده – تکنیک‌هایش؛ و سناریوی تحلیلی – قوانینش (این‌ها فقط ابتدا یا انتهای مسیرند)
- مثلاً مسیر از گروه APT29 تا رویداد Windows Security 4688 نشان می‌دهد کدام تکنیک‌های این گروه با قوانینی که این رویداد را می‌خوانند تشخیص داده می‌شوند.
- چند قاعده برای معتبر ماندن مسیرها:
- تگ‌ها و دسته‌ها هیچ‌وقت گره میانی نیستند.
 - رویداد Sysmon یا لاگ فقط یک قانون را به یک منبع داده وصل می‌کند. دو قانونی که هر دو از یک رویداد استفاده می‌کنند، به این دلیل به هم مرتبط حساب نمی‌شوند.
 - قوانین deprecated به‌طور پیش‌فرض کنار گذاشته می‌شوند. با منوی وضعیت بالای صفحه می‌توانید فقط Production، Production + testing یا همه را انتخاب کنید.
 - لینک‌های ویکی و صفحات Concept و Note فقط با گزینهی **Use wiki links** در مسیر می‌آیند. خود گره‌هایی که انتخاب کرده‌اید همیشه می‌توانند از لینک‌هایشان استفاده کنند. اگر مسیری پیدا نشود ولی با لینک‌های ویکی پیدا شود، سامانه پیشنهادش را می‌دهد.
 - از بین کوتاه‌ترین مسیرها، مسیرهایی انتخاب می‌شوند که کمترین هم‌پوشانی را داشته باشند، تا حداکثر ۸ مسیر متفاوت ببینید.
 - قدم‌هایی که ارتباطشان استنتاجی یا تطبیق متنی است، با خط‌چین و برچسب **inferred** یا **text match** نمایش داده می‌شوند. گزینهی **Certain links only** این قدم‌ها را کنار می‌گذارد و فقط مسیرهایی را نشان می‌دهد که همه‌ی ارتباط‌هایشان رسمی، اعلام‌شده یا دستی‌اند.



شکل ۴۴ – مسیرهای T1003.001 تا rundll32.exe فقط با ارتباط‌های قطعی

Impact – تحلیل اثر

برای جواب دادن به این سؤال: «اگر جمع‌آوری این داده قطع شود، چه چیزی از دست می‌رود؟»

1. آنچه قطع می‌شود را انتخاب کنید؛ ترکیب هم ممکن است:
2. **whole log sources...**: یک منبع لاگ کامل، مثل Sysmon یا Windows Security. عدد هر دکمه تعداد قوانینی است که از آن منبع استفاده می‌کنند.
3. **or single events of...**: یک منبع را از منو انتخاب کنید و روی رویدادهای مشخص آن کلیک کنید، مثلاً Windows Security 4688.
4. یا از منوی **If we stop collecting...** یک صفحه‌ی منبع داده انتخاب کنید تا تمامی رویدادهای آن حساب شوند.
5. انتخاب‌ها در ردیف **Selected** دیده می‌شوند و با ضربدر حذف می‌شوند. نتیجه فوراً نمایش داده می‌شود.

شکل ۴۵ – تحلیل اثر قطع کامل Sysmon

سامانه منابع لاگ هر قانون را جایگزین هم در نظر می‌گیرد: قانونی که هم Sysmon و هم Windows Security 4688 را می‌خواند، با قطع Sysmon از دست نمی‌رود و فقط تضعیف می‌شود. استثنا قوانینی است که به چند رویداد با هم نیاز دارند؛ کنار این قوانین عبارت **needs together** آمده و قطع هر کدام از آن رویدادها قانون را از کار می‌اندازد.

نتیجه	معنی
Rules lost	همه‌ی منابع لاگ قانون قطع شده و منبع دیگری هم برایش ثبت نشده است.

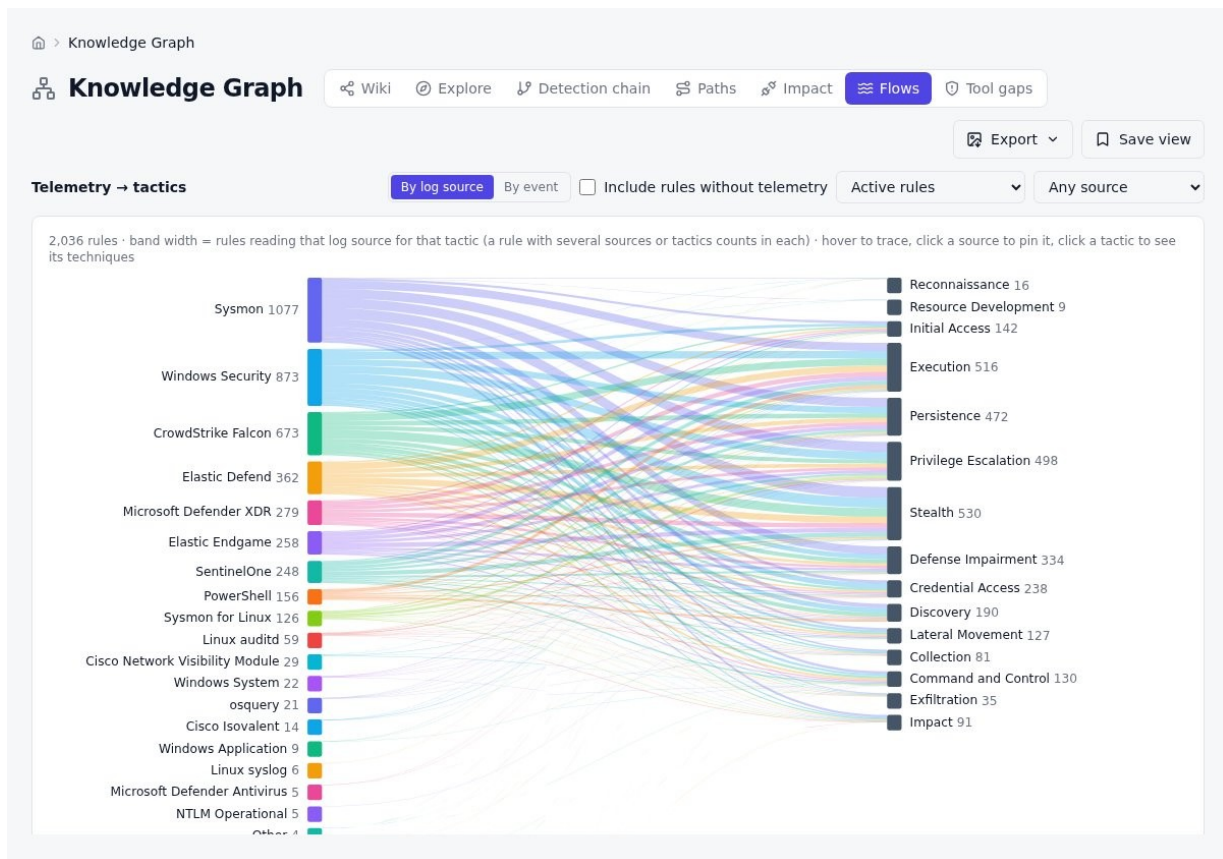
نتیجه	معنی
Rules at risk	همه‌ی منابع لاگ شناخته‌شده‌ی قانون قطع شده، ولی قانون منبع دیگری هم نام برده که سامانه نمی‌شناسد و شاید هنوز کار کند.
Rules degraded	بخشی از منابع لاگ قانون قطع شده و بقیه هنوز کار می‌کنند.
Techniques left uncovered	تکنیک‌هایی که همه‌ی قوانینشان از دست می‌رود. با کلیک، زنجیره‌ی تشخیص آن‌ها باز می‌شود.
Techniques weakened	تکنیک‌هایی که بخشی از قوانینشان را از دست می‌دهند. نوار رنگی سهم باقی‌مانده، در خطر و از دست رفته را نشان می‌دهد.

نکته

قوانینی که هیچ منبع لاگی برایشان شناخته نشده (معمولاً چون فیلد Data source ندارند) در این محاسبه نیستند. صفحه‌ی **Log Sources** نشان می‌دهد هر قانون به کدام منبع وصل شده است (فصل ۷).

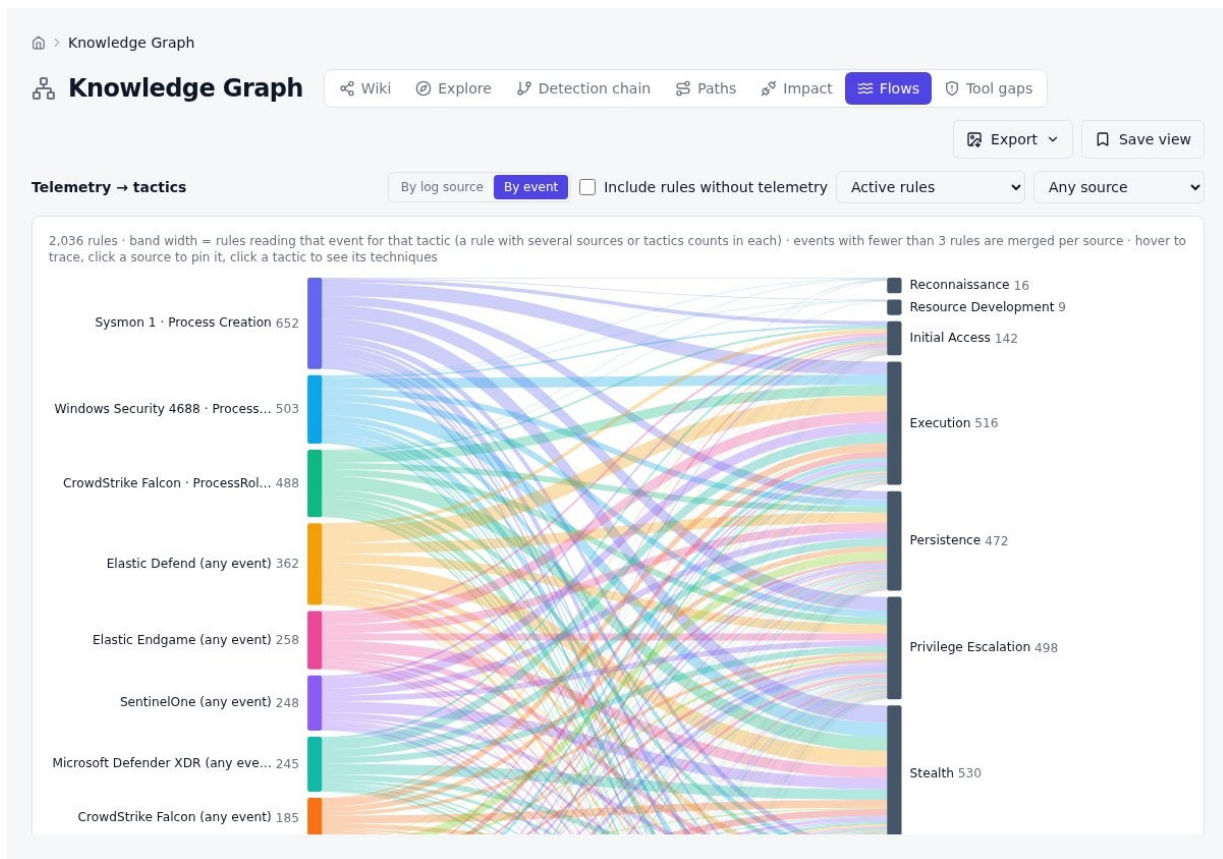
Flows – نمودار جریان

هر نوار نشان می‌دهد چند قانون از یک منبع لاگ (سمت چپ) برای یک تاکتیک ATT&CK (سمت راست) استفاده می‌کنند. پهنای نوار متناسب با تعداد قوانین است. با این نمودار معلوم می‌شود تشخیص هر تاکتیک به کدام داده متکی است.



شکل ۴۶ – نمودار جریان از منابع لاگ به تاکتیک‌ها

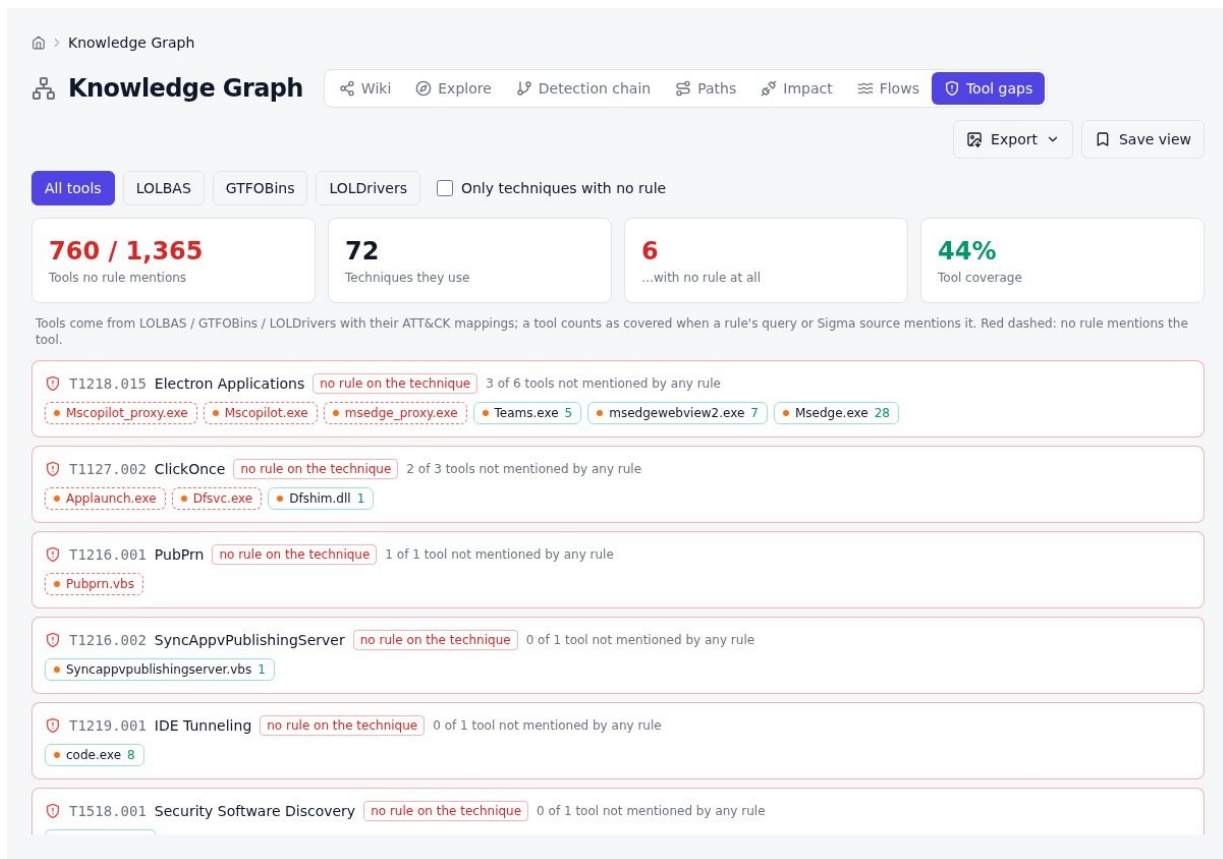
- **By log source / By event**: سمت چپ یا منابع لاگ کامل است (، Sysmon، Windows Security، CrowdStrike و ...) یا رویدادهای تکی. در حالت رویداد، رویدادهای کوچک (کمتر از ۳ قانون) هر منبع در یک گره «other events» جمع می‌شوند.
- ماوس را روی یک منبع یا تاکتیک ببرید تا جریان‌های آن پررنگ شود.
- با کلیک روی یک تاکتیک، نمودار به تکنیک‌های همان تاکتیک می‌رسد. با کلیک روی یک تکنیک، زنجیره‌ی تشخیص آن باز می‌شود.
- با کلیک روی یک منبع یا رویداد، پنبلی باز می‌شود: **What if we lose it?** تحلیل اثر همان منبع، **Rules** فهرست قوانینش و **Reference** صفحه‌ی مرجعش.
- فیلترهای بالا: وضعیت قوانین، منبع قوانین، و **Include rules without telemetry** برای افزودن قوانینی که هیچ منبع لاگی ندارند.



شکل ۴۷ – نمودار جریان در حالت رویداد

Tool gaps – شکاف ابزارها

این نما تکنیک‌هایی را فهرست می‌کند که ابزارهای شناخته‌شده می‌توانند، همراه با ابزارهایی که هیچ قانونی به آن‌ها اشاره نمی‌کند. تکنیک‌هایی که اصلاً قانون ندارند با آیکون هشدار و کادر قرمز، بالای فهرست قرار می‌گیرند.

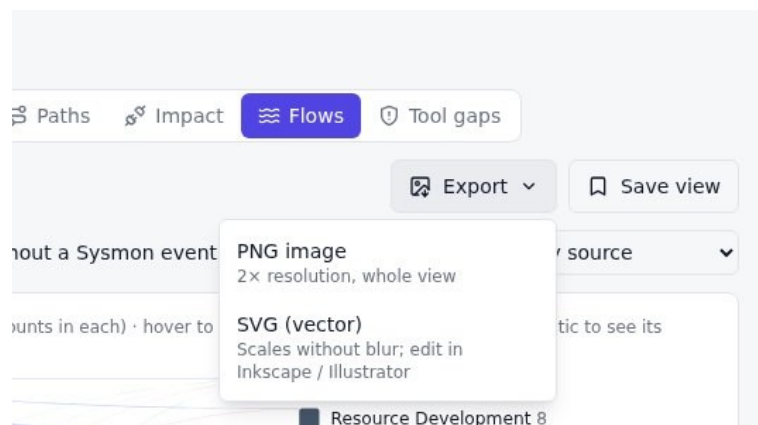


شکل ۴۸ – نمای Tool gaps

- ابزارهای خطچین قرمز در هیچ قانونی نیامده‌اند و ابزارهای سبز قانون دارند (با تعداد).
- فیلتر مرجع: **All tools**، **LOLBAS**، **GTF0Bins**، **LOLDrivers**. گزینه **Only techniques with no rule** فقط تکنیک‌های بدون قانون را نشان می‌دهد.
- با کلیک روی تکنیک، نمای Explore از آن شروع می‌شود و با کلیک روی ابزار، صفحه‌ی ابزار باز می‌شود.

خروجی تصویر

دکمه‌ی **Export** بالای گراف، نمای فعلی را ذخیره می‌کند:



شکل ۴۹ – منوی خروجی گراف

- **PNG image**: تصویر با وضوح دوبرابر از کل نما، حتی بخش‌هایی که دیده نمی‌شوند. برای همه‌ی نماها.
- **SVG (vector)**: تصویر برداری که بدون افت کیفیت بزرگ می‌شود. فقط برای نمای Flows.

فصل ۱۳ – صفحات دانش

غیر از قوانین، سامانه صفحه‌های دانش هم دارد: مفاهیم (**Concept**)، منابع داده (**Data Source**)، یادداشت‌ها (**Note**) و دستورهای SPL. همه با Markdown نوشته می‌شوند و با لینک ویکی به هم وصل‌اند.

فهرست همه‌ی صفحه‌ها

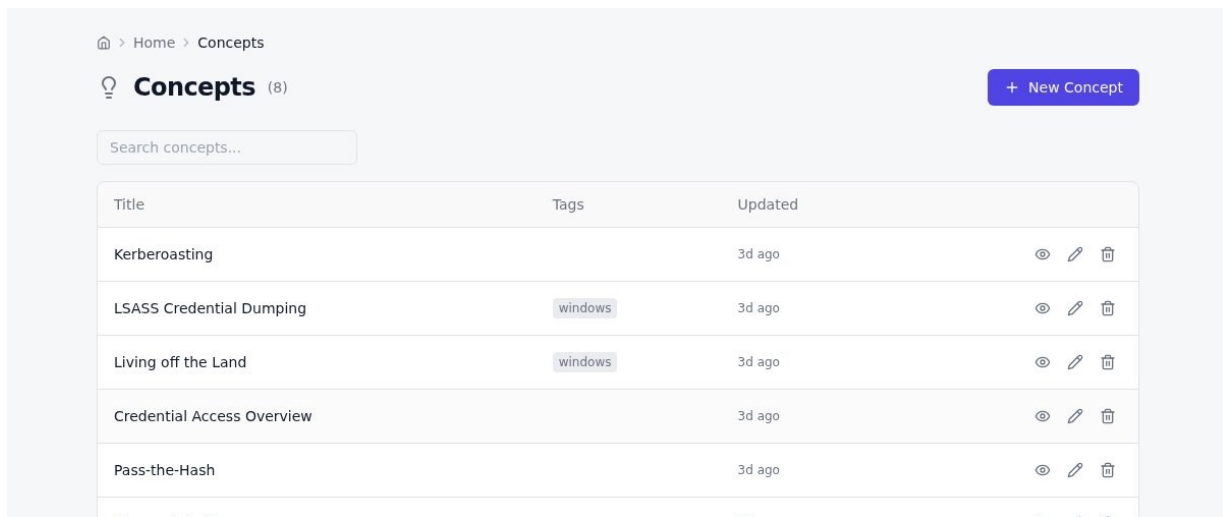
صفحه‌ی **All Pages** همه‌ی صفحه‌ها، از جمله قوانین، را نشان می‌دهد.

The screenshot displays the 'All Pages' section of the DetectKB interface. At the top, there's a header with 'All Pages' and a count of 2,160. Below this are filter buttons for 'All 2,160', 'Concept 8', 'Data Source 4', 'Note 5', 'Rule 2,143', and 'SPL Command 0'. A search bar is also present. Below the filters are tag buttons: 'All tags', 'splunk-escu (1527)', 'elastic (494)', 'sentinel (89)', 'sigma (33)', 'guide (5)', and 'windows (4)'. The main part of the image is a table with the following columns: Title, Type, Tags, and Updated. The table lists 12 items, each with a title, a type (Concept, Data Source, or Note), one or more tags, and an update time (all listed as '3d ago'). Each row also has icons for viewing, editing, and deleting the page.

Title	Type	Tags	Updated
Kerberoasting	Concept		3d ago
LSASS Credential Dumping	Concept	windows	3d ago
Living off the Land	Concept	windows	3d ago
Sysmon Operational Log	Data Source	windows	3d ago
Detection Engineering Lifecycle	Note	guide	3d ago
Sigma Rule Writing Guide	Note	guide	3d ago
Atomic Red Team Testing	Note	guide	3d ago
Tuning False Positives	Note	guide	3d ago
Credential Access Overview	Concept		3d ago
Pass-the-Hash	Concept		3d ago
Process Injection	Concept		3d ago
DLL Side-Loading	Concept		3d ago

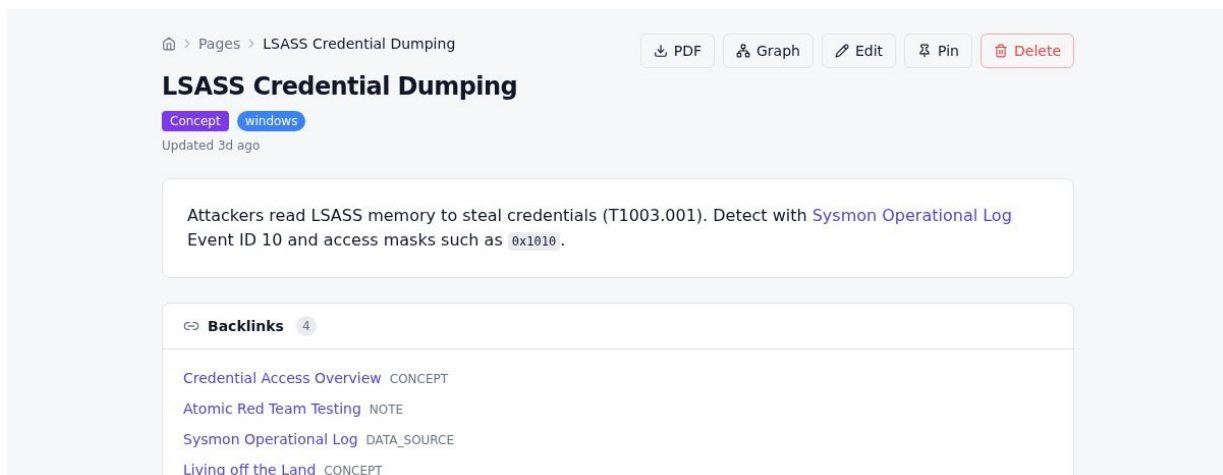
شکل ۵۰ – فهرست همه‌ی صفحه‌ها

- **دکمه‌های نوع:** فیلتر بر اساس نوع صفحه. عدد کنار هر نوع، تعداد صفحه‌های آن است.
 - **تگ‌ها:** فیلتر بر اساس تگ. پرکاربردترین تگ‌ها اول می‌آیند و بقیه پشت **more**.
 - **جست‌وجو:** در عنوان و متن صفحه‌ها.
 - مرتب‌سازی با کلیک روی سر ستون‌ها (عنوان، نوع، تاریخ)، و صفحه‌بندی پایین جدول.
 - دکمه‌های هر ردیف: مشاهده، ویرایش و حذف.
- صفحه‌های **Concepts** و **Data Sources** در نوار کناری همین فهرست‌اند، ولی فقط برای یک نوع صفحه.



شکل ۵۱ – فهرست مفاهیم

مشاهده‌ی صفحه



شکل ۵۲ – صفحه‌ی یک مفهوم با لینک ویکی و فهرست Backlinks

- لینک‌های ویکی با رنگ آبی نمایش داده می‌شوند و صفحه‌ی مقصد را باز می‌کنند. لینکی که صفحه‌اش وجود ندارد با رنگ دیگری نمایش داده می‌شود و با کلیک، ساخت آن صفحه شروع می‌شود.
- **Backlinks**: صفحه‌هایی که به این صفحه لینک داده‌اند.
- دکمه‌های بالا مثل صفحه‌ی قانون است: **Delete**، **PDF**، **Graph**، **Edit**، **Pin**.

ساخت و ویرایش صفحه

1. **New Page** را در نوار بالا بزنید، یا در فهرست Concepts و Data Sources دکمه‌ی ساخت همان نوع را.
2. عنوان، نوع، دسته و تگ‌ها را وارد کنید.
3. متن را در کادر **Content** با Markdown بنویسید.
4. **Save** را بزنید.

لینک ویکی: برای لینک به صفحه‌ی دیگر، [] تایپ کنید و چند حرف از عنوان صفحه را بنویسید. فهرست پیشنهادها باز می‌شود؛ با کلیدهای جهت‌دار انتخاب و با **Enter** درج کنید. نتیجه به شکل **[[عنوان صفحه]]** در متن قرار می‌گیرد.

The screenshot shows the 'Edit Page' interface for a page titled 'LSASS Credential Dumping'. The page has a 'Type' dropdown set to 'Concept', a 'Category' dropdown set to 'None', and 'Tags' set to 'windows'. The 'Content' area contains a paragraph about attackers reading LSASS memory and a 'Wiki link' dropdown menu showing suggestions like 'LSASS Memory Access by Tool With Dump Keyword In Name'.

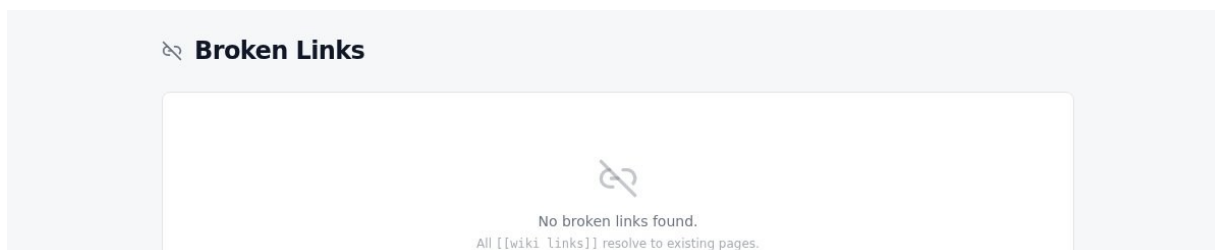
شکل ۵۳ – پیشنهاد صفحه هنگام نوشتن لینک ویکی

دسته‌بندی‌ها

در نوار کناری، کنار **Categories**، دکمه‌ی + را بزنید، نام و رنگ دسته را انتخاب کنید و ذخیره کنید. با کلیک روی نام دسته، صفحه‌های آن نمایش داده می‌شوند. دسته‌ی هر صفحه در فرم ویرایش آن تعیین می‌شود. با حذف یک دسته، صفحه‌هایش حذف نمی‌شوند و فقط بدون دسته می‌مانند.

لینک‌های شکسته

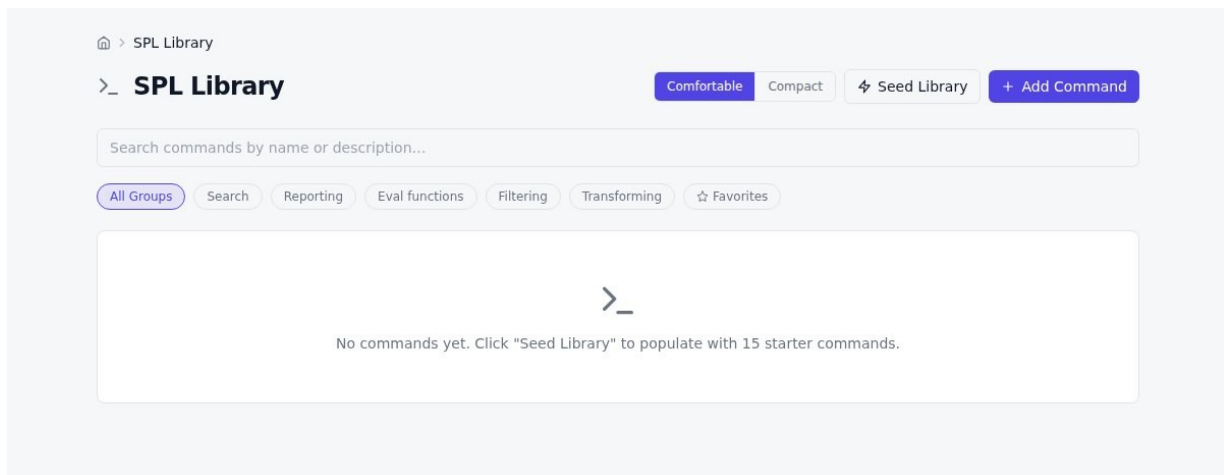
صفحه‌ی **Broken Links** همه‌ی لینک‌های ویکی را که به صفحه‌ی ناموجود اشاره می‌کنند فهرست می‌کند، همراه با صفحه‌ای که لینک در آن است. آن‌ها را اصلاح کنید یا صفحه‌ی مقصد را بسازید.



شکل ۵۴ – صفحه‌ی لینک‌های شکسته (در این نمونه لینک شکسته‌ای وجود ندارد)

کتابخانه‌ی SPL

صفحه‌ی **SPL Library** مجموعه‌ای از دستورهای پرکاربرد Splunk با نحو، توضیح، مثال و نکته‌هاست. با **Add Command** دستور جدید اضافه می‌شود. **Seed Library** مجموعه‌ی آغازینی از ۱۵ دستور رایج را اضافه می‌کند. فیلتر گروه‌ها (Search، Reporting، Eval functions و ...)، علامت‌گذاری علاقه‌مندی‌ها و دو حالت نمایش هم هست.

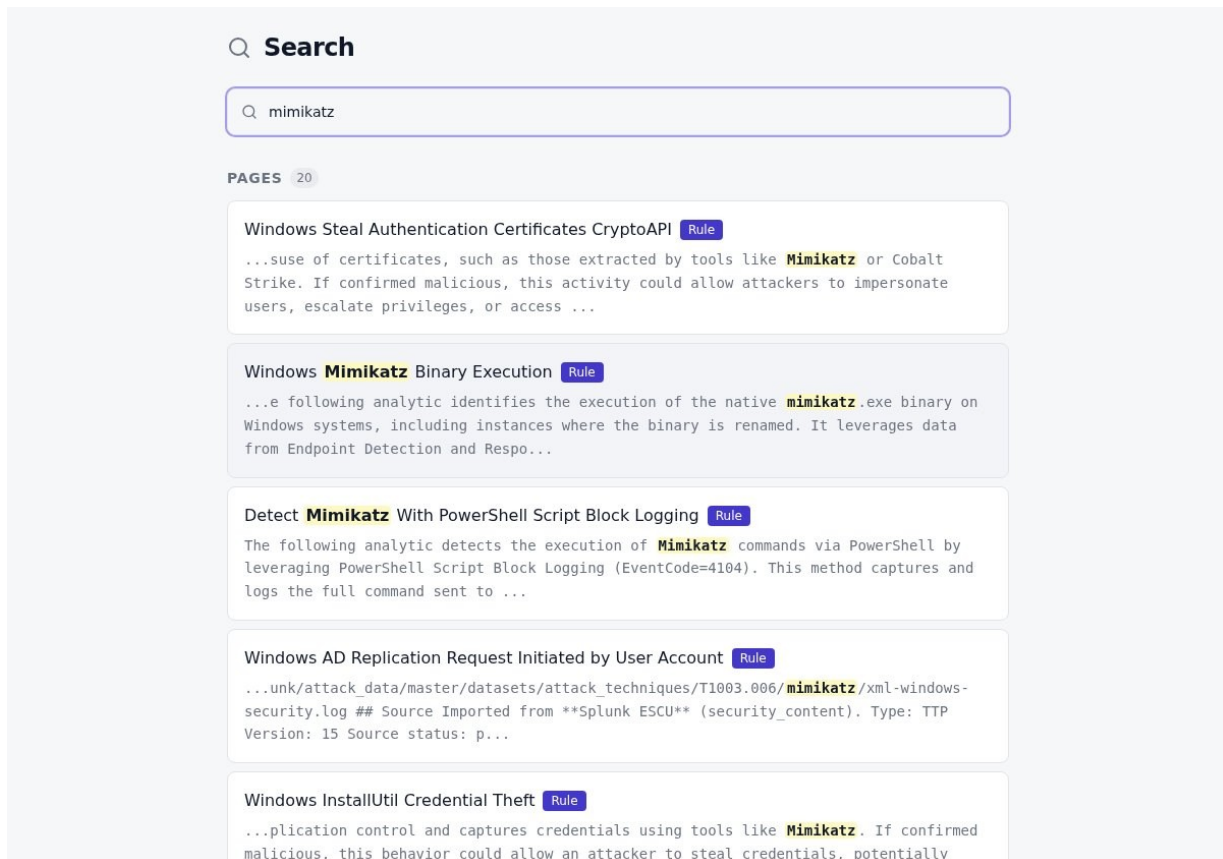


شکل ۵۵ – کتابخانه‌ی SPL

فصل ۱۴ – جست‌وجو و مستندسازی

جست‌وجو

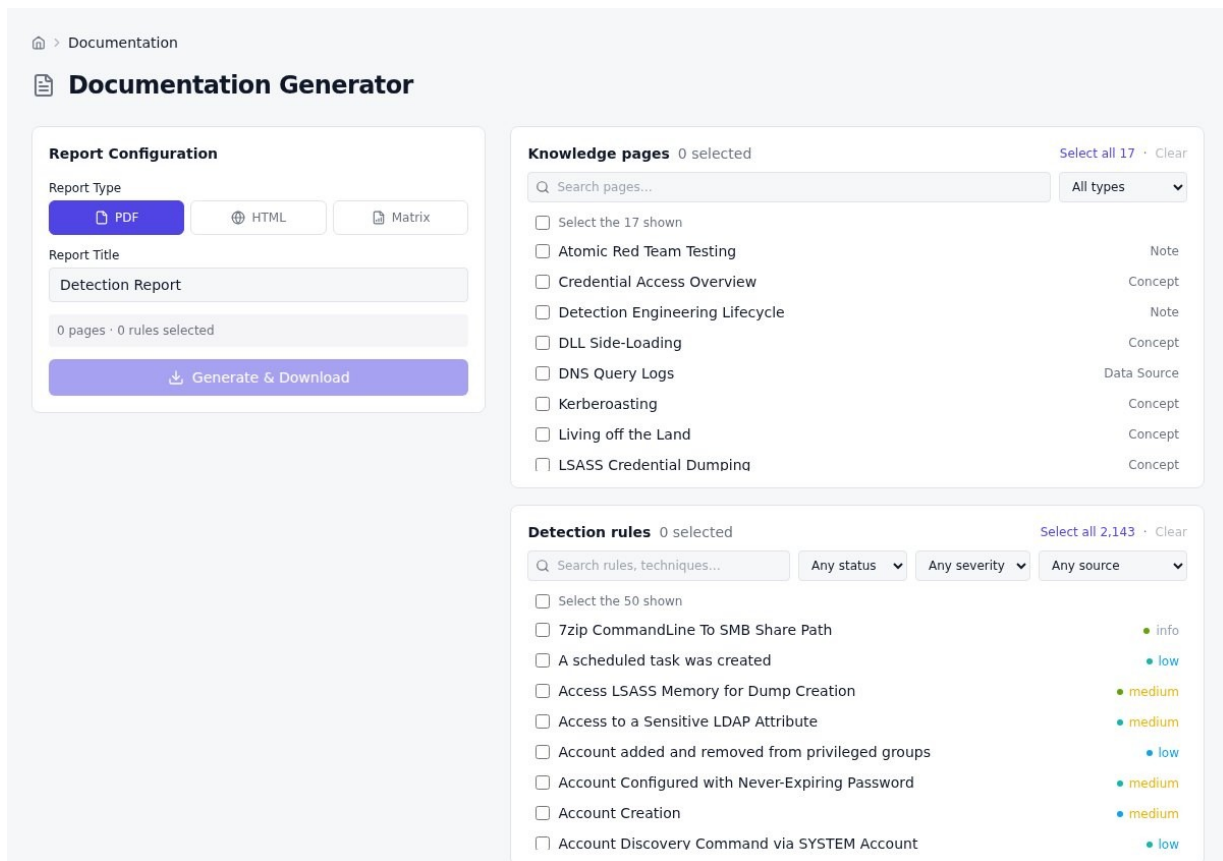
صفحه‌ی **Search** در عنوان و متن همه‌ی صفحه‌ها و قوانین جست‌وجو می‌کند. کلمه‌ی جست‌وجو شده در نتیجه‌ها پررنگ می‌شود و نوع هر نتیجه کنار عنوانش نمایش داده می‌شود. برای جست‌وجوی سریع در هر صفحه، **Ctrl+K** را بزنید (فصل ۲).



شکل ۵۶ – نتیجه‌ی جست‌وجوی mimikatz

ساخت گزارش

صفحه‌ی **Documentation** از صفحه‌ها و قوانین انتخاب‌شده گزارش می‌سازد.



شکل ۵۷ – صفحه‌ی ساخت گزارش

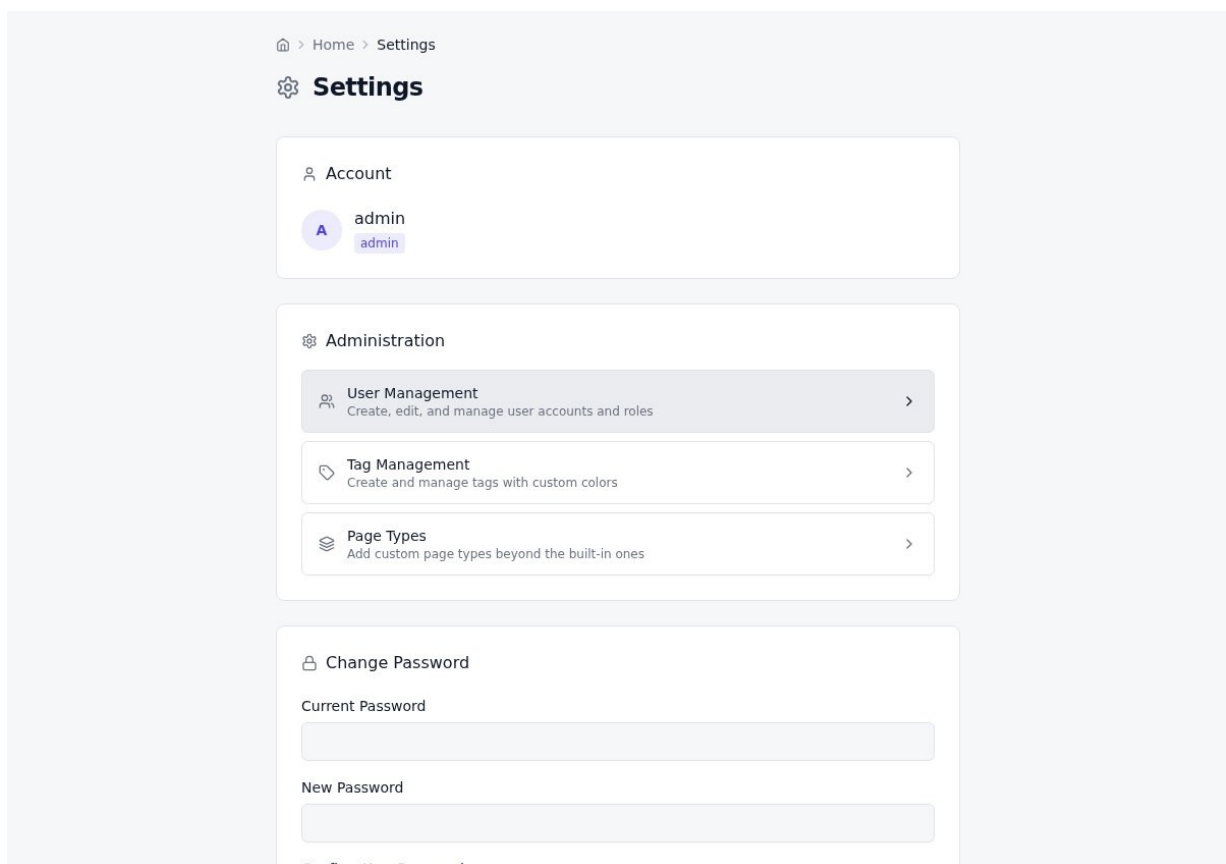
1. نوع گزارش را انتخاب کنید: **HTML**، **PDF** (با فهرست مطالب اختیاری) یا **Matrix** (ماتریس تشخیص بر اساس تکنیک و شدت، با فیلتر تگ اختیاری).
 2. عنوان گزارش را بنویسید.
 3. در **Knowledge pages** و **Detection rules** موارد مورد نظر را انتخاب کنید. هر دو فهرست جست‌وجو و فیلتر دارند (قوانین با وضعیت، شدت و منبع). **Select all N matching** همه‌ی موارد منطبق با فیلتر را یکجا انتخاب می‌کند و **Show more** موارد بیشتری نشان می‌دهد.
 4. **Generate & Download** را بزنید. گزارش ساخته و دانلود می‌شود.
- گزارش‌های ساخته‌شده در جدول **Generated Documents** پایین صفحه می‌مانند و از آن‌جا دوباره دانلود یا حذف می‌شوند.

فصل ۱۵ – مدیریت سامانه

تنظیمات و تغییر رمز

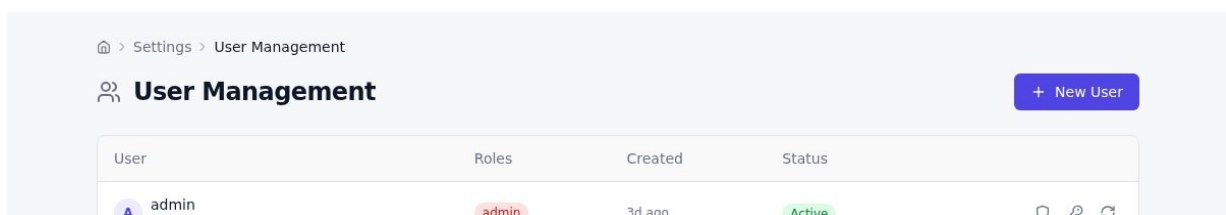
صفحه‌ی **Settings** اطلاعات حساب شما را نشان می‌دهد. در بخش **Change Password** رمز فعلی و رمز جدید را وارد کنید و ذخیره کنید. مدیر در بخش **Administration** به مدیریت کاربران، تگ‌ها و انواع صفحه دسترسی دارد.

قواعد رمز: دست‌کم ۱۰ کاراکتر، حداکثر ۷۲ بایت، بدون نام کاربری، و نه فقط تکرار چند حرف (مثل aaaaaaaaaa). بعد از تغییر رمز، همه‌ی نشست‌های دیگر شما (مثلاً روی رایانه‌ی دیگر) بسته می‌شوند و باید دوباره وارد شوند؛ نشست فعلی باز می‌ماند.



شکل ۵۸ – صفحه‌ی تنظیمات

مدیریت کاربران (مدیر)



شکل ۵۹ – فهرست کاربران

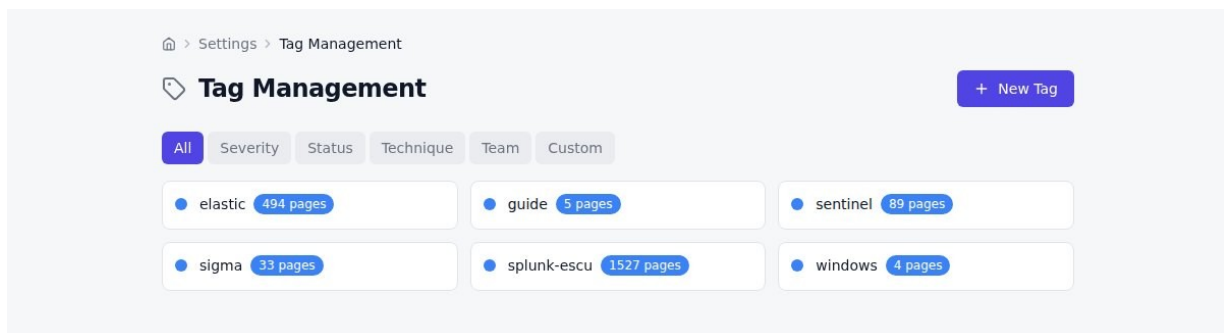
- **New User**: ساخت کاربر جدید با نام کاربری، ایمیل، رمز اولیه و نقش. کاربر در اولین ورود باید رمزش را عوض کند.
- دکمه‌های کنار هر کاربر: **Edit roles** تغییر نقش‌ها، **Reset password** تعیین رمز جدید (کاربر باید دوباره آن را عوض کند، و همه‌ی نشست‌های قبلی‌اش بسته می‌شود)، و **Disable user / Enable user** غیرفعال یا فعال کردن حساب.
- رمز کاربر جدید و رمز بازنشانی‌شده هم باید قواعد رمز را رعایت کنند. نام کاربری فقط حروف انگلیسی، عدد و _ می‌پذیرد.
- مدیر نمی‌تواند نقش admin را از خودش بگیرد یا حساب خودش را غیرفعال کند.

نکته

به جای حذف کاربری که دیگر نباید وارد شود، حسابش را غیرفعال کنید. سوابق فعالیت او در گزارش فعالیت حفظ می‌شود.

تگ‌ها

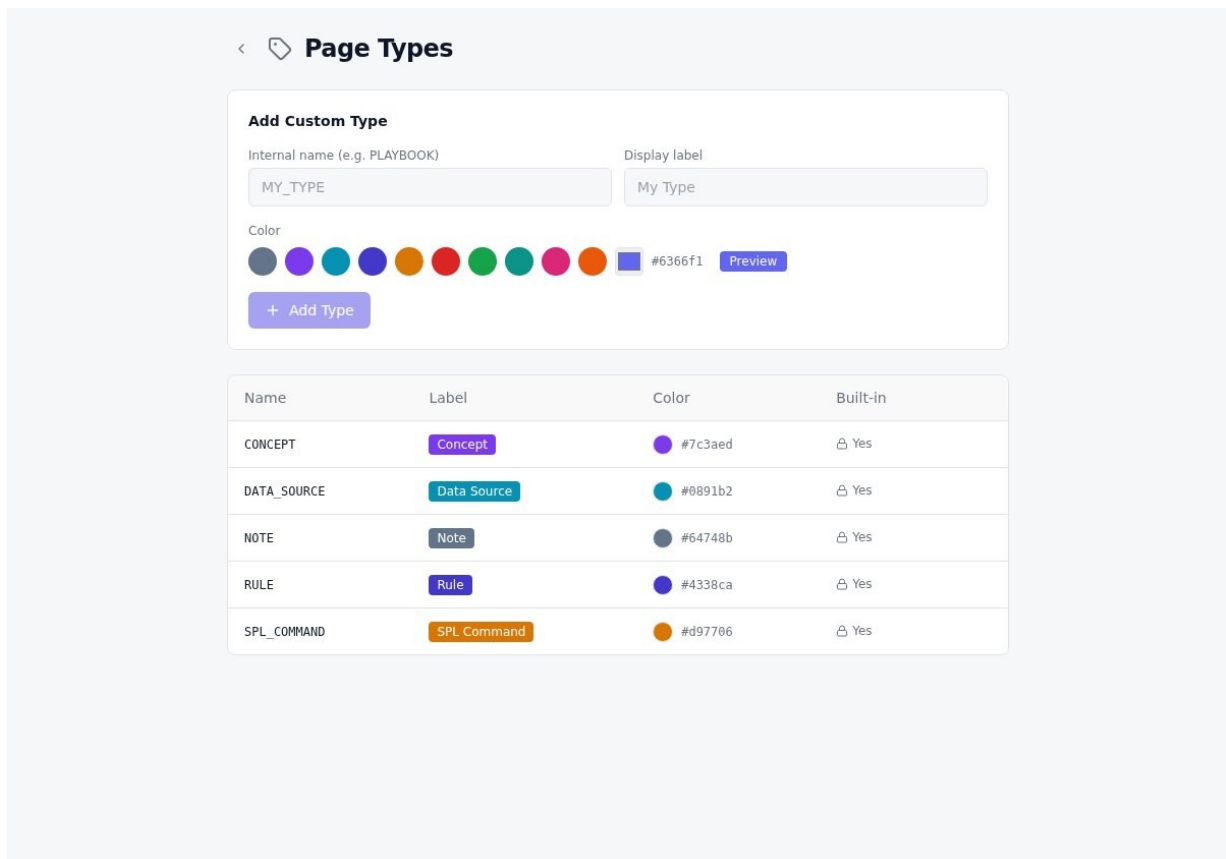
صفحه‌ی **Tag Management** همه‌ی تگ‌ها را با تعداد صفحه‌های هر کدام نشان می‌دهد. با **New Tag** تگ جدید با رنگ و دسته‌ی دلخواه ساخته می‌شود و می‌توانید تگ‌ها را ویرایش یا حذف کنید. تگ‌ها بر اساس دسته (Severity، Status، Technique، Team، Custom) فیلتر می‌شوند.



شکل ۶۰ - مدیریت تگ‌ها

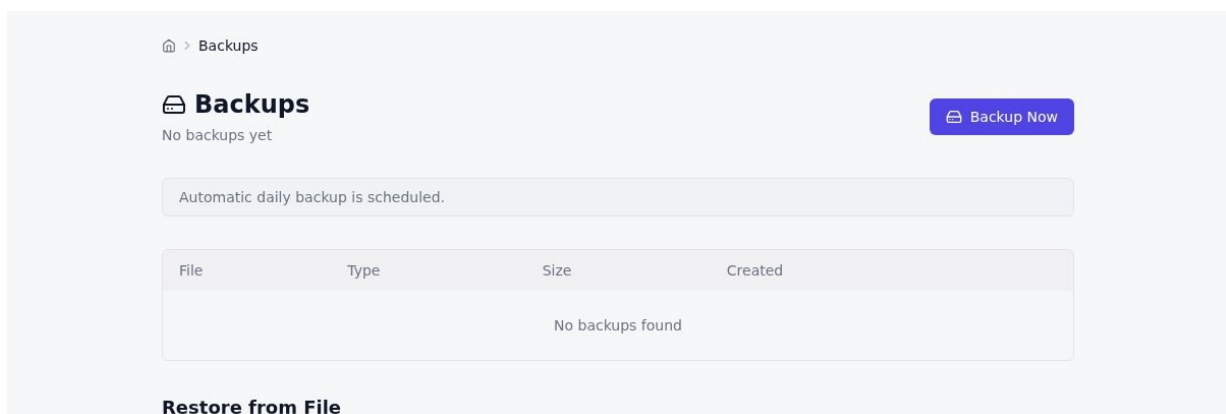
انواع صفحه (مدیر)

غیر از پنج نوع پیش‌فرض (Concept، Data Source، Note، Rule، SPL Command)، می‌توانید نوع دلخواه بسازید، مثلاً **Playbook** برای روال‌های پاسخ به رخداد. در **Add Custom Type** نام داخلی (حروف بزرگ انگلیسی)، برچسب نمایشی و رنگ را تعیین کنید و **Add Type** را بزنید.



شکل ۶۱ – انواع صفحه

پشتیبان‌گیری و بازگردانی



شکل ۶۲ – صفحه‌ی پشتیبان‌گیری

- **Backup Now:** پشتیبان کامل از پایگاه دانش در قالب JSON، شامل نتیجه‌های تست در لب. فایل در فهرست پایین صفحه قرار می‌گیرد و قابل دانلود است.
- سامانه روزانه یک پشتیبان خودکار هم می‌گیرد.
- **Restore from File:** با **Choose JSON file** فایل پشتیبان را انتخاب و **Restore** را بزنید. این کار فقط برای مدیر است.

توجه

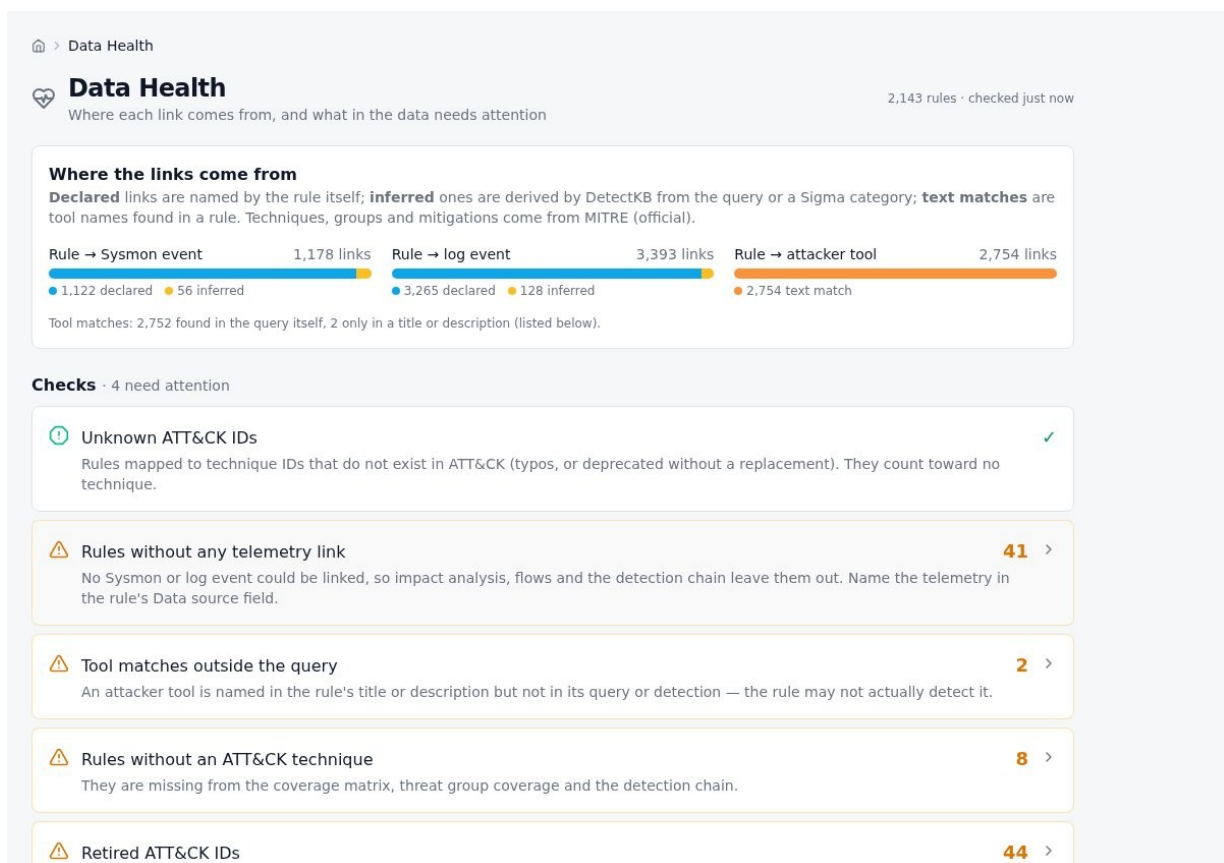
بازگردانی، صفحه‌هایی را که شناسه‌ی آدرس (slug) یکسان دارند بازنویسی می‌کند و قابل بازگشت نیست. قبل از بازگردانی، از وضعیت فعلی پشتیبان بگیرید.

نکته

برای پشتیبان کامل در سطح سرور، دستور `./install.sh update` قبل از هر به‌روزرسانی از دیتابیس MySQL نسخه‌ی پشتیبان می‌گیرد و آن را در پوشه‌ی `backups` ذخیره می‌کند.

سلامت داده

صفحه‌ی **Data Health** در بخش Tools نشان می‌دهد ارتباط‌های سامانه از کجا آمده‌اند و چه چیزی در داده‌ها نیاز به رسیدگی دارد.

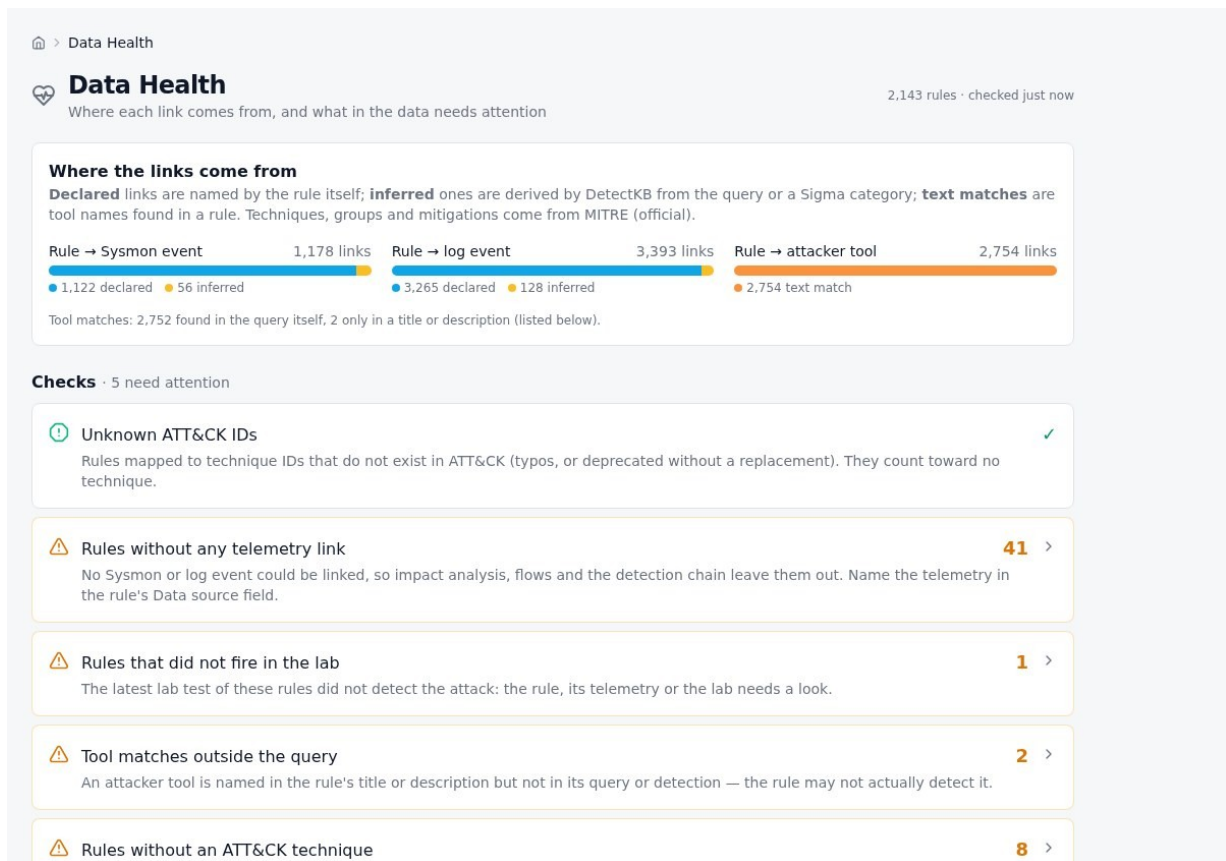


شکل ۶۳ — صفحه‌ی سلامت داده

- **Where the links come from:** سهم ارتباط‌های اعلام‌شده، استنتاجی و تطبیق متنی، برای ارتباط قانون با رویدادهای Sysmon، رویدادهای لاگ و ابزارهای مهاجم.

- **Checks:** هر بررسی تعداد موارد را نشان می‌دهد؛ با کلیک، فهرست قوانین مربوط با لینک به صفحه‌ی هر قانون باز می‌شود. تیک سبز یعنی مشکلی نیست.

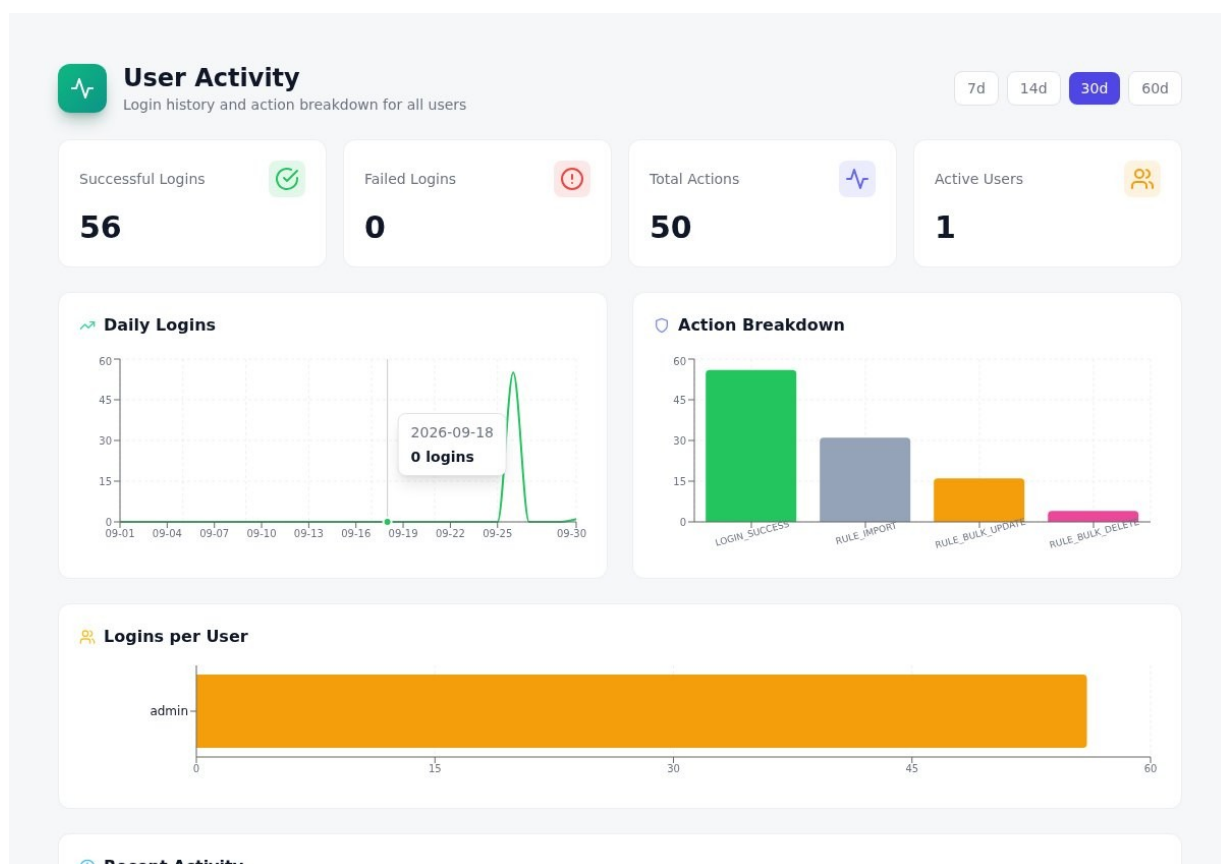
معنی	بررسی
شناسه‌ی تکنیکی که در ATT&CK وجود ندارد؛ معمولاً اشتباه تایپی.	Unknown ATT&CK IDs
آخرین تست این قوانین در لب حمله را تشخیص نداد (فصل ۱۱).	Rules that did not fire in the lab
قوانینی که هیچ منبع لاگی برایشان شناخته نشده؛ در تحلیل اثر و نمودار جریان حساب نمی‌شوند.	Rules without any telemetry link
نام ابزار فقط در عنوان یا توضیح قانون آمده، نه در کوئری؛ شاید قانون واقعاً آن را تشخیص ندهد.	Tool matches outside the query
قوانین بدون نگاشت ATT&CK؛ در پوشش حساب نمی‌شوند.	Rules without an ATT&CK technique
شناسه‌هایی که MITRE بازنشسته کرده است؛ نگاشت را به‌روز کنید.	Retired ATT&CK IDs
همه‌ی منابع لاگ این قوانین استنتاجی‌اند و خود قانون هیچ‌کدام را نام نبرده است.	Telemetry only inferred
قوانینی که شرط AND دارند.	Rules needing several events at once
نام‌هایی در فیلد منبع داده که سامانه نمی‌شناسد؛ این قوانین در تحلیل اثر «در خطر» حساب می‌شوند.	Data sources DetectKB does not know
قانون‌هایی که مخزن اصلی‌شان نسخه‌ی جدیدتری دارد (فصل ۴).	Imported rules changed upstream
کوئری قانون بعد از تست تغییر کرده یا تست قدیمی‌تر از ۹۰ روز است.	Lab results to redo
قوانین Production که هیچ نتیجه‌ی تستی ندارند.	Production rules never tested in the lab
قوانین Production که توضیح مثبت کاذب ندارند.	Production rules without false positives
قوانین هم‌نام؛ اغلب یک قانون که از دو منبع وارد شده است.	Rules with the same title
سناریوهایی که هنوز توضیح ندارند.	Analytic stories without a description
صفحه‌های منبع داده که هیچ رویدادی را نام نمی‌برند.	Data source pages without telemetry



شکل ۶۴ — بررسی‌های اعتبارسنجی در صفحه‌ی سلامت داده

گزارش فعالیت (مدیر)

صفحه‌ی **Activity** فعالیت کاربران را در بازه‌ی ۷، ۱۴، ۳۰ یا ۶۰ روز گذشته نشان می‌دهد: تعداد ورودهای موفق و ناموفق، تعداد عملیات، کاربران فعال، نمودار ورود روزانه، تفکیک نوع عملیات (مثل ورود قانون و تغییر گروهی)، ورود هر کاربر و فهرست آخرین رویدادها.



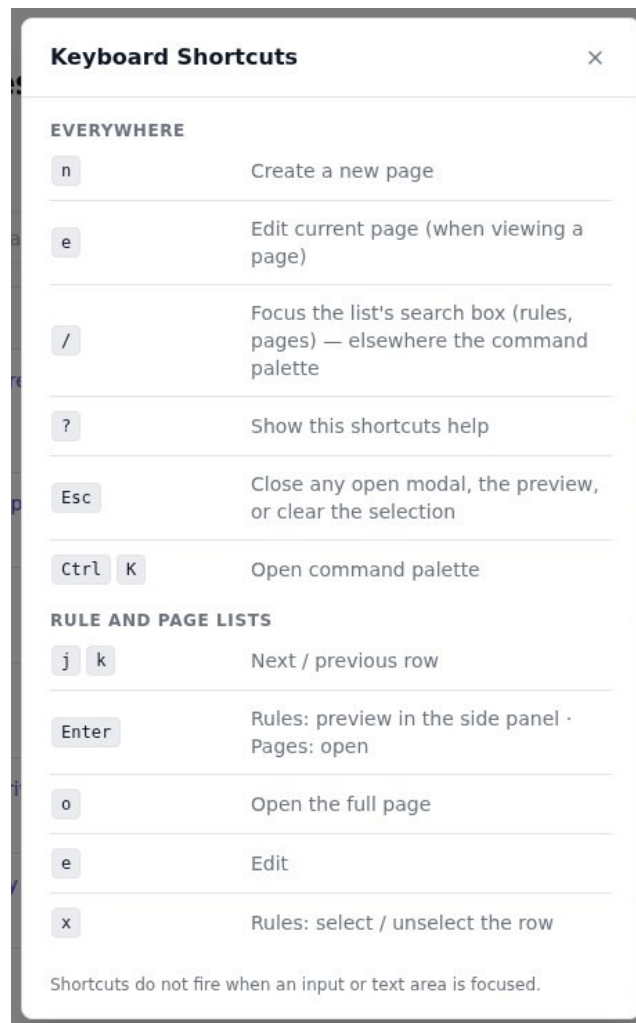
شکل ۶۵ – گزارش فعالیت کاربران

فصل ۱۶ – میانبرهای صفحه‌کلید و ظاهر

با میانبرها، بدون ماوس و سریع‌تر کار می‌کنید. فهرست کامل با کلید **?** در هر صفحه نمایش داده می‌شود.

کلید	کار
Ctrl+K	جست‌وجوی سریع
/	رفتن به جعبه‌ی جست‌وجوی فهرست (قوانین و صفحه‌ها)؛ در صفحه‌های دیگر، جست‌وجوی سریع
n	ساخت صفحه‌ی جدید
e	ویرایش صفحه‌ی فعلی یا ردیف انتخاب‌شده در فهرست
j / k	ردیف بعدی و قبلی در فهرست قوانین و صفحه‌ها. اگر پیش‌نمایش باز باشد، قانون بعدی در آن نمایش داده می‌شود.
Enter	قوانین: باز کردن پیش‌نمایش · صفحه‌ها: باز کردن صفحه
o	باز کردن صفحه‌ی کامل ردیف انتخاب‌شده
x	انتخاب یا لغو انتخاب ردیف (فهرست قوانین)
Esc	بستن پنجره یا پیش‌نمایش؛ بار دوم، پاک کردن انتخاب‌ها
?	نمایش فهرست میانبرها

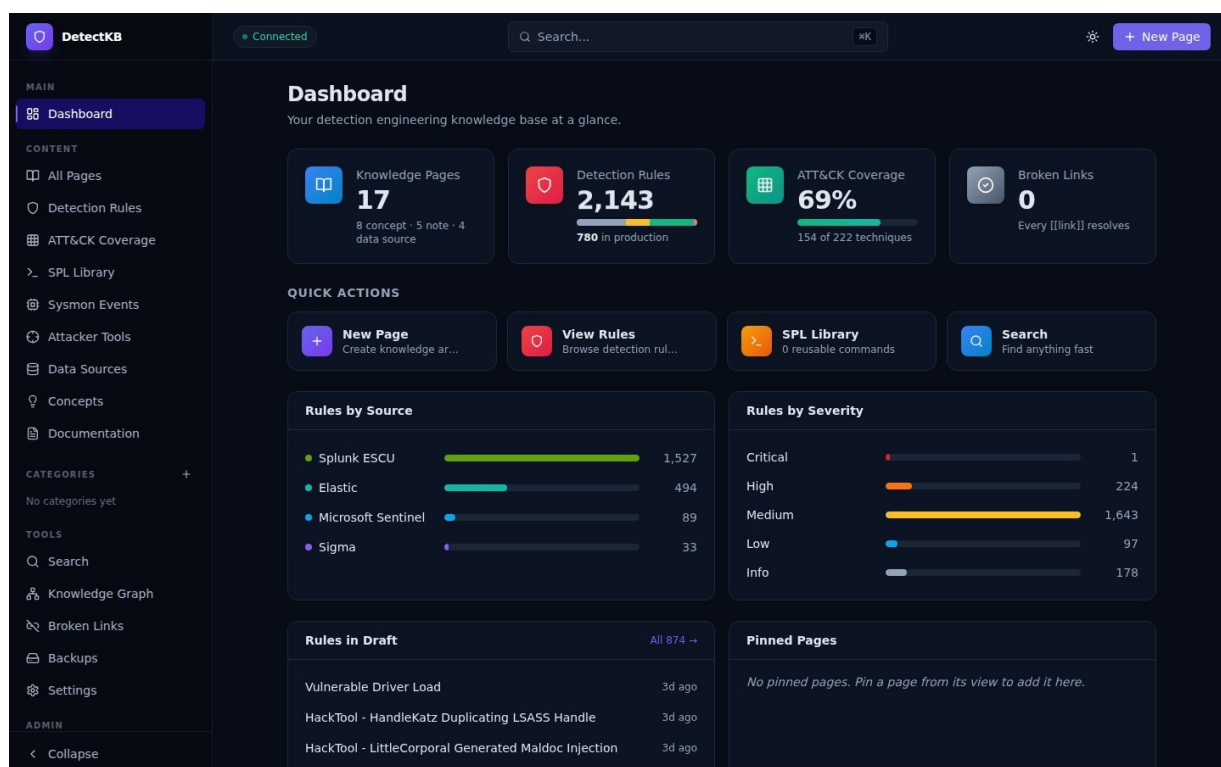
میانبرها وقتی داخل یک جعبه‌ی متن هستید کار نمی‌کنند. برای خروج از جعبه‌ی متن، **Esc** را بزنید یا جای دیگری کلیک کنید.



شکل ۶۶ – پنجره‌ی راهنمای میانبرها

حالت تاریک

با دکمه‌ی ماه یا خورشید در نوار بالا، بین حالت روشن و تاریک جابه‌جا شوید. انتخاب شما در همان مرورگر به خاطر سپرده می‌شود.



شکل ۶۷ – داشبورد در حالت تاریک

فصل ۱۷ – پرسش‌های رایج و عیب‌یابی

چرا قوانینی که وارد کردم در پوشش ATT&CK حساب نشده‌اند؟

پوشش به‌طور پیش‌فرض همه‌ی قوانین به‌جز deprecated را حساب می‌کند. اگر فیلتر وضعیت روی **Production** باشد، قوانین draft حساب نمی‌شوند. همچنین قانون باید در فیلد **MITRE Techniques** شناسه‌ی تکنیک معتبر داشته باشد.

چرا رویداد Sysmon یک قانون تشخیص داده نشده است؟

تشخیص خودکار از کوئری SPL (مثل `EventCode=10` همراه با نام Sysmon) یا logsource قانون Sigma انجام می‌شود. اگر کوئری از ماکرو یا نام دیگری استفاده کند، رویداد را دستی از فرم ویرایش قانون اضافه کنید.

تبدیل Sigma کار نمی‌کند.

اگر پیام **The Sigma conversion service is not running** نمایش داده شود، سرویس تبدیل Sigma اجرا نیست. به مدیر سیستم اطلاع دهید. بقیه‌ی بخش‌های سامانه بدون این سرویس کار می‌کنند.

ابزارهای مهاجم خالی‌اند یا قدیمی شده‌اند.

مدیر باید در صفحه‌ی **Attacker Tools** با **Update from source** داده‌ها را به‌روز کند. روی سرور بدون اینترنت، از **Upload file** استفاده کنید (فصل ۸).

ناگهان از سامانه خارج شدم.

نشست ورود ۲۴ ساعت اعتبار دارد. همچنین اگر رمز شما (توسط خودتان روی دستگاه دیگر یا توسط مدیر) تغییر کند یا حسابتان غیرفعال شود، نشست‌های قبلی بسته می‌شوند. دوباره وارد شوید.

قانونی که تست کرده بودم دوباره Retest شده است.

کوئری قانون بعد از آخرین تست تغییر کرده (حتی با ویرایش یا ورود دوباره‌ی قانون)، یا تست قدیمی‌تر از ۹۰ روز است. تست را دوباره اجرا و نتیجه را ثبت کنید.

تست اجرا شد ولی قانون هشدار نداد.

قبل از اصلاح قانون، بررسی کنید حمله واقعاً اجرا شده، لاگ تولید شده و به Splunk رسیده است. جدول «اگر قانون هشدار نداد» در فصل ۱۱ را ببینید.

رمزم را فراموش کرده‌ام.

از مدیر سامانه بخواهید با **Reset password** برایتان رمز موقت تعیین کند. بعد از ورود، سامانه از شما می‌خواهد رمز جدید انتخاب کنید.

سامانه بالا نمی‌آید و در لاگ خطای P1000 دیده می‌شود (برای مدیر سیستم).

رمز دیتابیس در فایل `env` با رمزی که دیتابیس با آن ساخته شده یکی نیست. این معمولاً وقتی پیش می‌آید که فایل `e`.
`nv` جدیدی کنار دیتابیس قبلی ساخته شود. فایل `env` نصب قبلی را برگردانید، یا اگر به داده‌ها نیاز ندارید، با `docker`
`-v compose down` دیتابیس را پاک و سامانه را دوباره نصب کنید. جزئیات در بخش Troubleshooting فایل
README هست.